

IT-Sicherheit

Prof. Dr. Johannes Freudenmann (DHBW Karlsruhe)
Masterprogramm Informatik

www.dhbw.de

Übersicht Netzwerk-Sicherheit

- Einführung
- Bedrohungen
- Werkzeuge der Angreifer und zur Analyse,
- Sicherheitsmaßnahmen (Schwerpunkt im Netzwerk)
 - Organisatorisch
 - Verschlüsselung
 - Erkennung/Verfolgung
 - Weitere Informationen

Bedrohungen im Netzwerk - Schutzziele

- (1) (Daten-) Integrität (integrity)
- (2) (Informations-) Vertraulichkeit (confidentiality)
- (3) Verfügbarkeit (availability)
- (4) Verbindlichkeit, Nachweisbarkeit (non-repudiation),
Zurechenbarkeit (accountability)
- (5) Authentizität von Subjekten, Objekten
(authenticity)
- (6) Privatheit (privacy), Anonymität (anonymity),
Pseudonymität (pseudonymity)
- Bereits betrachtet:
Was ist das? Wie geht's?
- Genauer: Bemerken? Verhindern?

Bedrohungen im Netzwerk – (1) Integrität

ggf. für Klausur:
Hashverfahren nennen

- Was ist das?
 - Daten werden bei der Übertragung unautorisiert und unbemerkt modifiziert
 - Regel, wer darf was mit welchen Daten tun
- Wie kann das passieren?
 - Jeder dazwischen kann Änderungen an den Daten vornehmen
 - Technische Unzulänglichkeiten (schwache Signale)
- Wie kann ich es bemerken?
 - Crc, Hashwert, Signatur, Paritätsbits
- Wie kann ich es verhindern?
 - Kein Zugang von außen! Also nicht zu 100%!
 - Schutz am Netzeingang - Firewall

Hash: MD5, SHA
↑
nicht mehr sicher

Bedrohungen im Netzwerk – (2) Vertraulichkeit

- Was ist das?
 - Unautorisiert Informationen gewinnen.
 - Daten und Metainformation sind interessant.
 - Regeln wer darf was sehen.
- Wie kann das passieren?
 - Protokollieren/Sniffen der Daten -> s. Folie
- Wie kann ich es bemerken?
 - Gar nicht!
 - Kontrolle der gesamten Infrastruktur
- Wie kann ich es verhindern?
 - Definierter Weg über zuverlässige Netzknoten
 - Verschlüsselung (AnwendungsV, TLS, IPsec, s.Folien)

Bedrohungen im Netzwerk – (3) Verfügbarkeit

- Was ist das?
 - Funktionalität/Benutzbarkeit beeinträchtigt
- Wie kann das passieren?
 - Überlast, Sabotage, DOS, DDOS (s. Folie)
- Wie kann ich es bemerken?
 - Ist meist offensichtlich
- Wie kann ich es verhindern?
 - Ressourcen großzügig. *- Redundanz*
 - Anfragefrequenz begrenzen
 - Netz separieren Intern/extern/Abteilungen, QOS
 - Problem Unterscheidbarkeit berechtigter/unberechtigter Zugriff

Bedrohungen im Netz – (4) Verbindlichkeit, Nachweisbarkeit

- Was ist das?
 - Durchgeführte Handlungen nicht abstreitbar
- Wie kann das passieren?
 - „Ich war's nicht“, nicht meine Mail, Bestellung....
Malware in der Mail.
- Wie kann ich es bemerken?
 - Inkonsistenter Kontext.
- Wie kann ich es verhindern?
 - Signatur, unterschiedliche Anforderungen, je nach erforderlicher (Rechts-)Verbindlichkeit
 - Beweise sichern, protokollieren (Forensik)
 - Problem Zeitaufwand

Bedrohungen im Netzwerk – (5) Authentizität von Subj, Obj

- Was ist das?
 - Echtheit der Identifikation von Subjekten und Objekten durch: PWD, Schlüssel, Biometrie, Smartcards
- Wie kann das passieren?
 - PWD ausgespäht, gecrackt, (s. 2.Teil)
- Wie kann ich es bemerken?
 - Kontext inkonsistent *z.B. 7-Faktor schlägt an, obwohl man nichts getan hat*
- Wie kann ich es verhindern?
 - Bessere Verfahren, mehrere unabhängige Identifikationen, Sperren von Karten, Austausch von Schlössern, *Multi-Faktor*

Bedrohungen im Netzwerk – (6) Privatheit, Anonymität

- Was ist das?
 - Schutz der personenbezogenen Daten, Recht auf Informationelle Selbstbestimmung
- Wie kann das passieren?
 - Zugriff auf Daten nicht ausreichend geschützt.
 - Weiterverkauf für Werbungszwecke
 - Logfiles speichern alles (z.B. Moodle)
- Wie kann ich es bemerken?
 - Daten tauchen in anderem Zusammenhang auf *z.B. Werbung*
- Wie kann ich es verhindern?
 - rechtlich: Datenschutzgesetze, Zweckbindung von Datensammlungen
 - Pseudonyme: Id kennt nur „Notar“
 - Metadaten?

Netzwerksicherheit – Weiterführendes aus den Zielen

- Integrität – Schutz durch Firewall
 - Aufbau, Funktionsweise von Firewalls.
- Vertraulichkeit – Protokollieren/Sniffen
- Vertraulichkeit – Verschlüsselung
 - Wie im Netz organisieren (Key Exchange)
- Verfügbarkeit – Schutz vor DOS/DDOS durch Firewall
- Verbindlichkeit/Nachweisbarkeit – Forensik
- Authentizität – Vertrauen in Passworte
 - Passwort-Crack (rainbow-tables)
- Verletzung der Schutzziele durch Schwachstellen
 - Erkennen und Beheben (Konfig und Update)
- Systeme sicher konstruieren, Sicherheit prüfen.

Netzwerksicherheit – Sniffen

Daten werden nur protokolliert, analysiert, aber nicht verändert.

- Wo abgreifen:
 - Kabel/Faser/Funk (z.B. Tempora)
 - Schicht 2 – Netzwerkkarte, eigener Datenverkehr
 - Management Port am Switch, eigenes LAN
 - Spoofing, eigenes LAN (s. Folie)
 - Protokoll im Router/Switch, Route im Internet (s. Folie)
 - Proxy
- Werkzeuge
 - Diverse, Wireshark

Netzwerksicherheit – Sniffen Werkzeuge Wireshark

- Mächtiges Werkzeug zur Protokollanalyse
- > 2220 Protokolle werden unterstützt (Computerbild).
- Transparente Darstellung der Protokollschichten
- Aufgabe:
 - Wireshark installieren, eigenen Datenverkehr aufzeichnen
 - Werden (meine) Passwörter im Klartext übertragen?
 - Pop3 ??
 - Internet-Shops??
 - Finden Sie drei Beispiele für verschlüsselte Übertragung und drei für eine Klartext-Übertragung und geben Sie dafür eine Alternative an.

Netzwerksicherheit – Sniffen Werkzeuge Spoofing

- „Problem“: Daten sind nicht in Reichweite.
 - LAN: ARP-Spoofing
 - IP:
 - Source Routing (Option im IP-Paket)
 - Falsche Absenderadresse (für DOS, DDOS)
 - Routing Tables Spoofing
 - <https://www.zdnet.com/article/bgp-spoofing-why-nothing-on-the-internet-is-actually-secure/>
 - <https://www.heise.de/newsticker/meldung/Router-luegen-nicht-was-wenn-doch-200283.html>
 - BGP-Routing: <https://www.youtube.com/watch?v=IzLPKuAOe50>,
<https://www.youtube.com/watch?v=t7ilZxXFYYQ>
 - Aktueller: <https://www.manrs.org/2020/04/not-just-another-bgp-hijack/>
 - Aktuell: <https://www.youtube.com/watch?v=u7fig13eW4Q>
 - DNS Spoofing
 - Gefälschte DNS-Server-Einträge (DNSChanger 2007-2011, 2012)
 - s. Folie

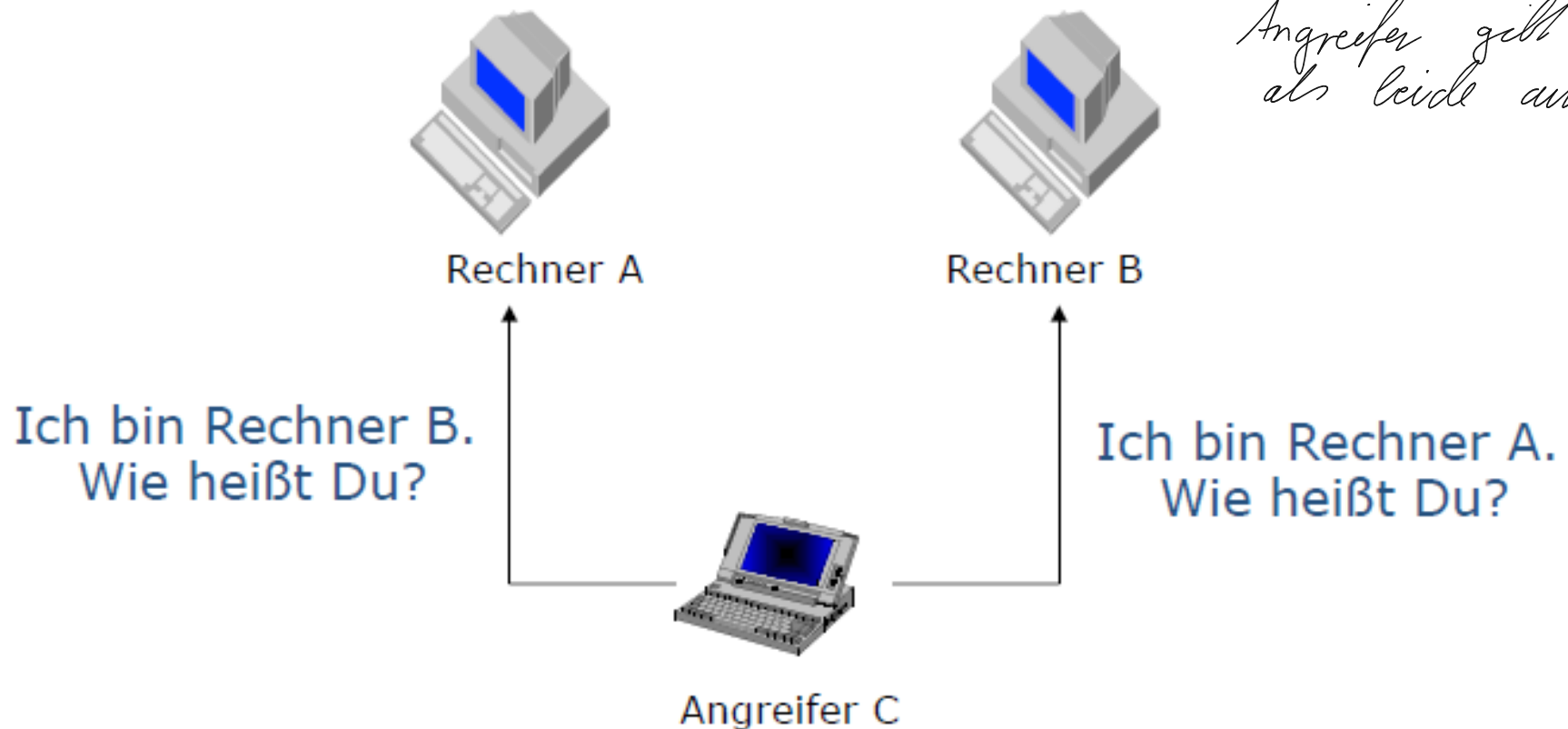
Netzwerksicherheit – Routing Table Spoofing

- Zu sehr im Detail, aber immer relevant.
- <https://www.manrs.org/2022/07/for-12-hours-was-part-of-apple-engineerings-network-hijacked-by-russias-rostelecom/>
Russia's Rostelecom started announcing routes for part of Apple's network.
- Mutually Agreed Norms for Routing Security (MANRS)
<https://www.manrs.org/>

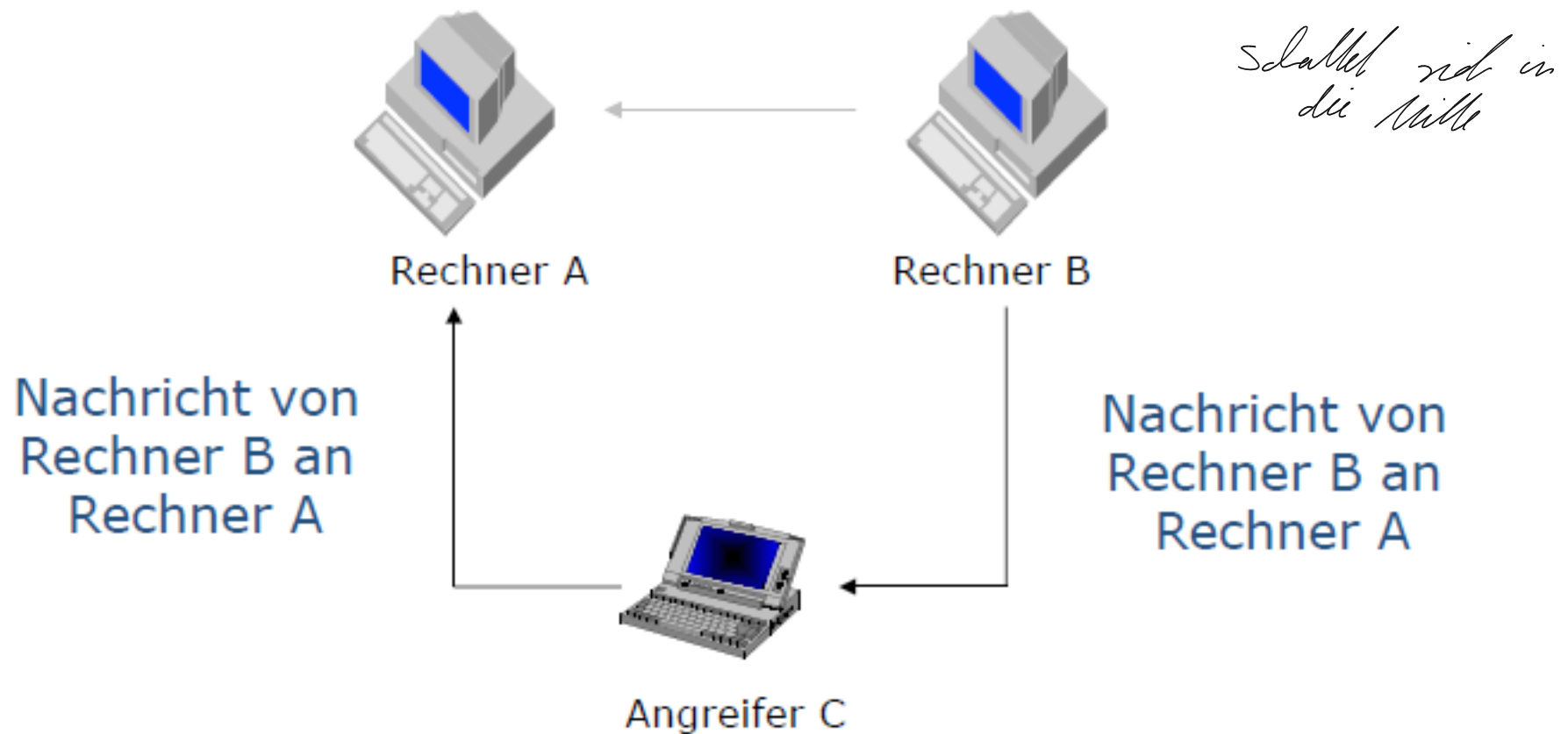
Netzwerksicherheit – Sniffen Werkzeuge ARP Spoofing I

*ARP
Address Resolution Protocol*

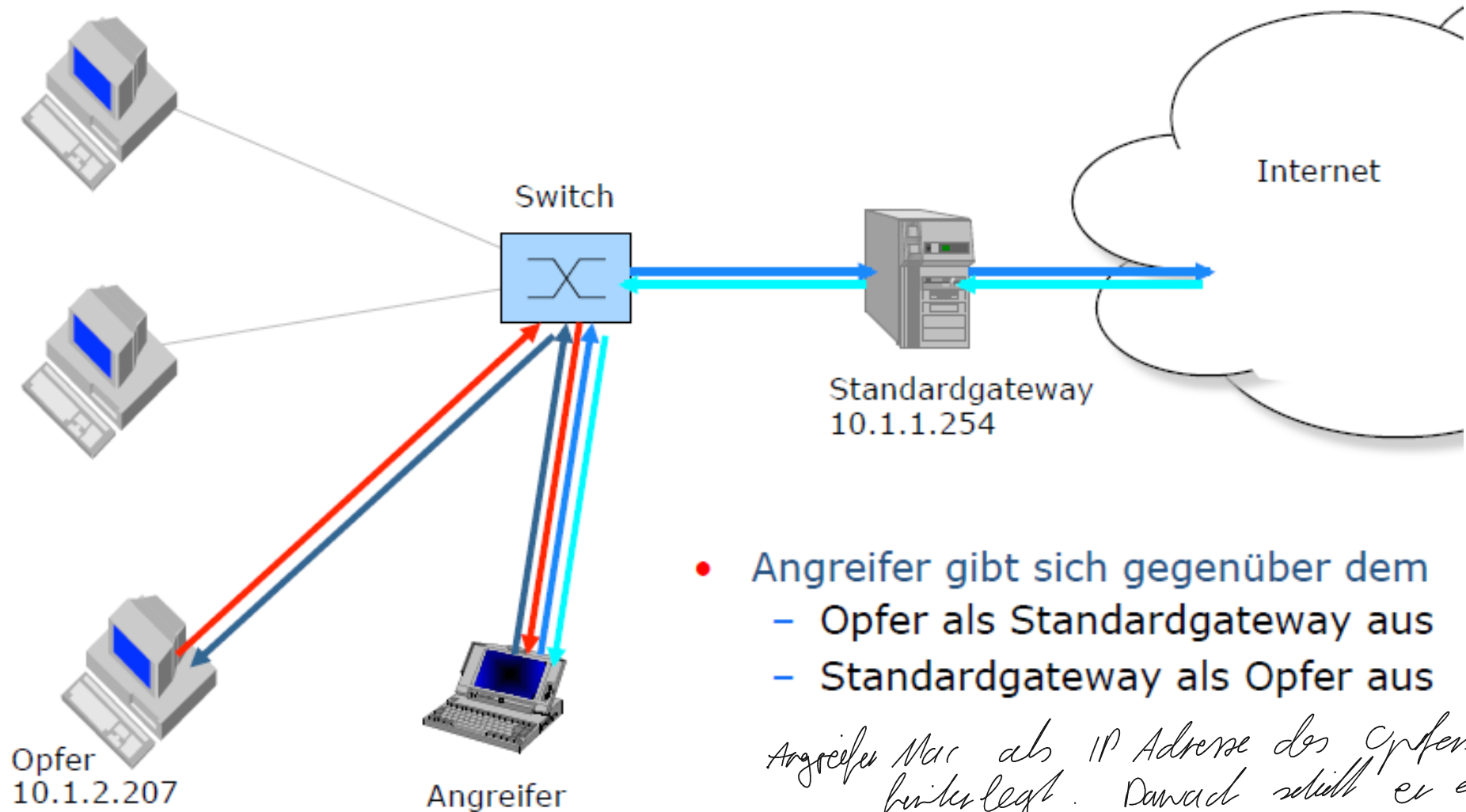
*Angreifer gibt sich
als beide aus*



Netzwerksicherheit – Sniffen Werkzeuge ARP Spoofing II

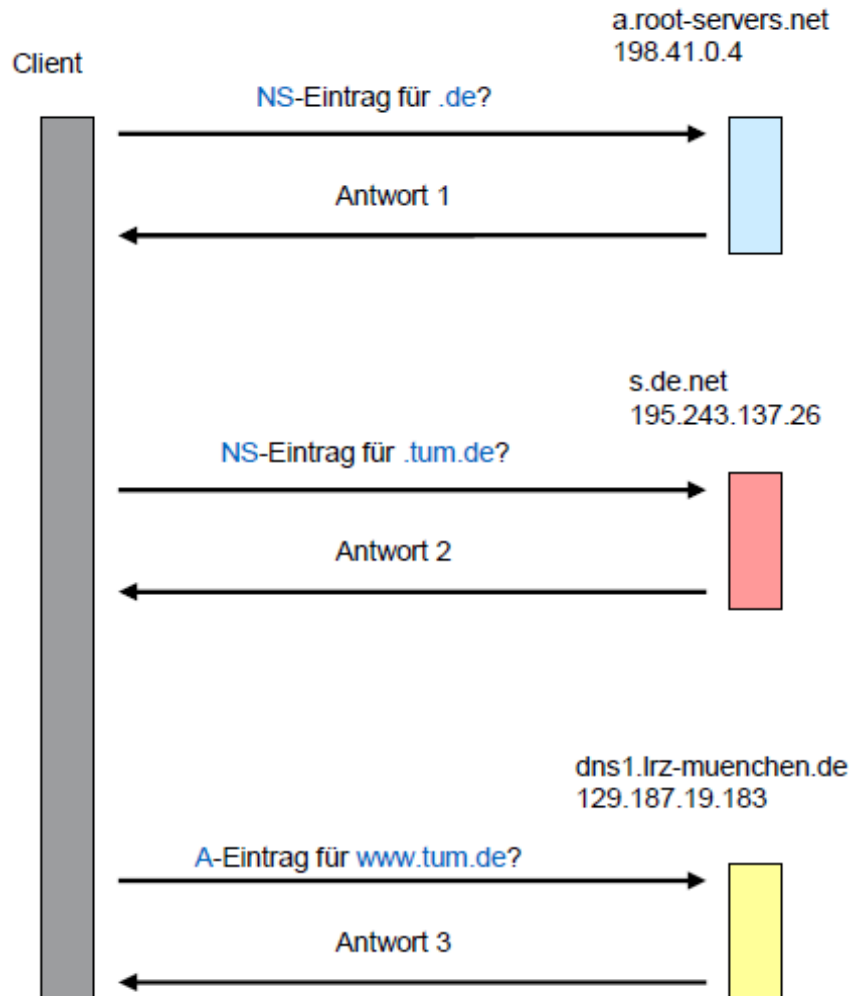


Netzwerksicherheit – Sniffen Werkzeuge ARP Spoofing II



Netzwerksicherheit DNS

- **Beispiel:** Auflösung von `www.tum.de` in IP-Adresse



Antwort 1

```
:: AUTHORITY SECTION:  
de.      IN  NS  a.nic.de.  
de.      IN  NS  c.de.net.  
de.      IN  NS  f.nic.de.  
de.      IN  NS  l.de.net.  
de.      IN  NS  s.de.net.  
de.      IN  NS  z.nic.de.
```

Zuständige
Nameserver

```
:: ADDITIONAL SECTION:  
a.nic.de. IN  A  194.0.0.53  
c.de.net. IN  A  208.48.81.43  
f.nic.de. IN  A  81.91.164.5  
l.de.net. IN  A  77.67.63.105  
s.de.net. IN  A  195.243.137.26  
z.nic.de. IN  A  194.246.96.1
```

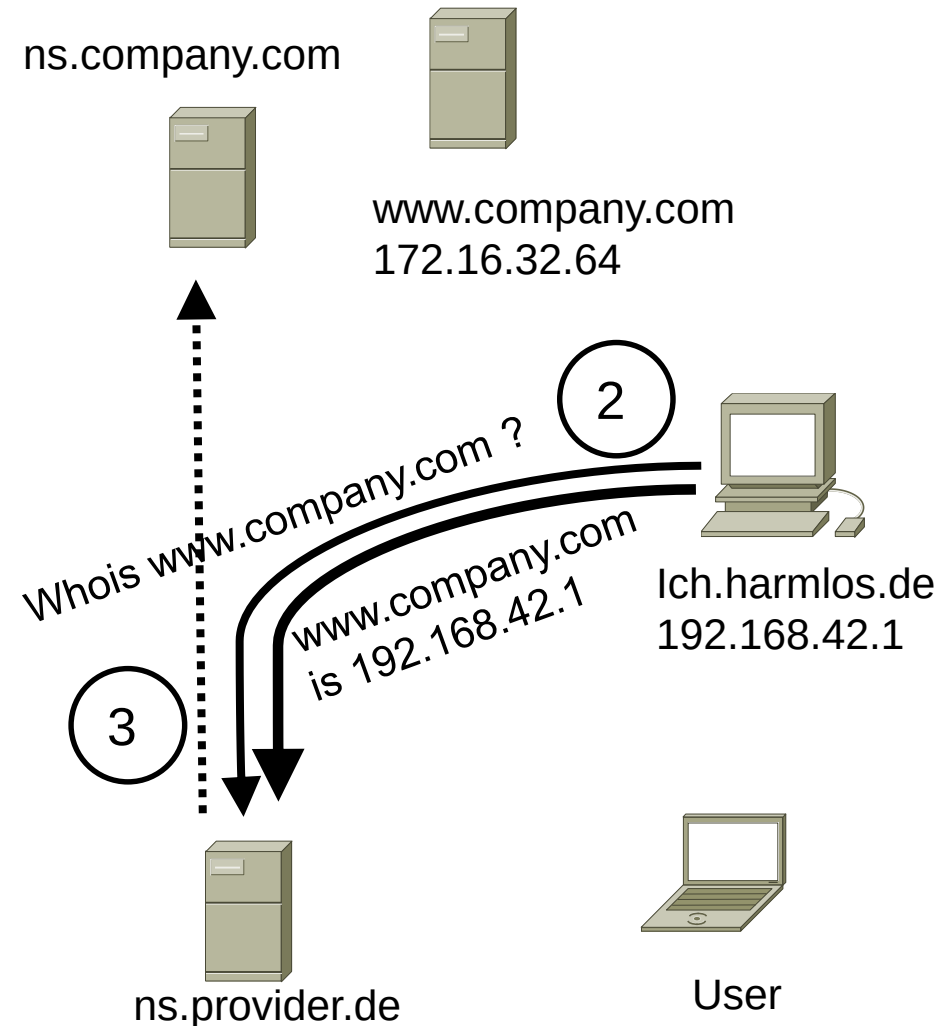
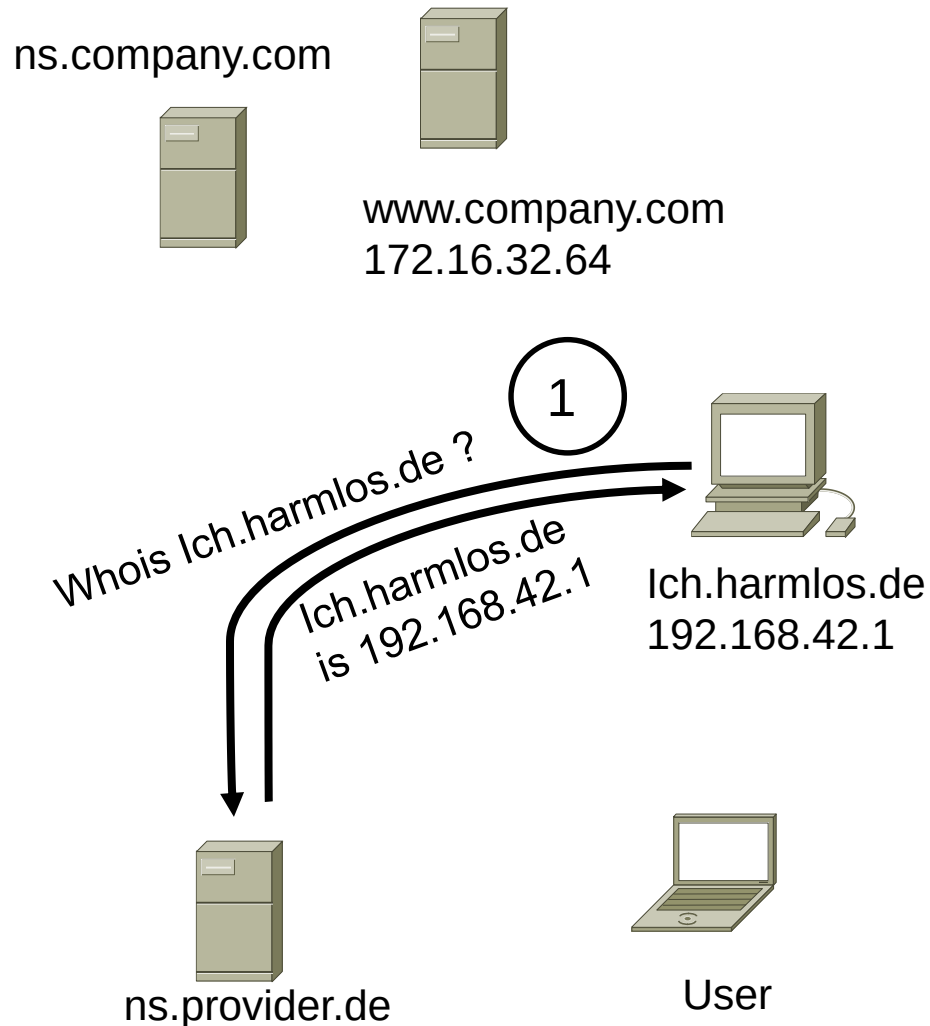
Zugehörige
IP-Adressen

```
:: AUTHORITY SECTION:  
tum.de.  IN  NS  dns1.lrz-muenchen.de.  
tum.de.  IN  NS  dns3.lrz-muenchen.de.  
tum.de.  IN  NS  dns2.lrz-muenchen.de.
```

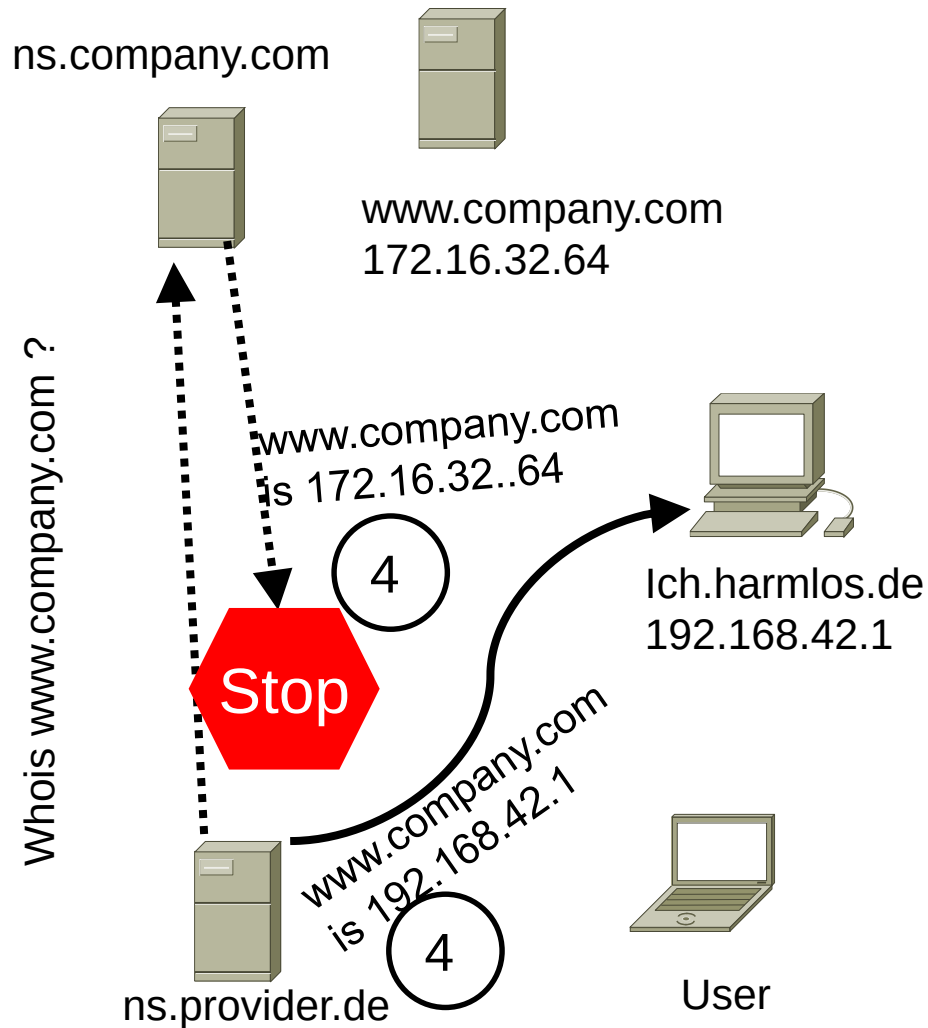
```
:: ADDITIONAL SECTION:  
dns1.lrz-muenchen.de. IN  A  129.187.19.183  
dns2.lrz-muenchen.de. IN  A  141.40.9.211  
dns3.lrz-muenchen.de. IN  A  193.136.2.123
```

```
:: ANSWER SECTION:  
www.tum.de.      IN  CNAME  tum.www.ze.tu-muenchen.de.  
tum.www.ze.tu-muenchen.de. IN  CNAME  tum.www.ze.tum.de.  
tum.www.ze.tum.de. IN  CNAME  portal.mytum.de.  
portal.mytum.de.  IN  A      129.187.39.3
```

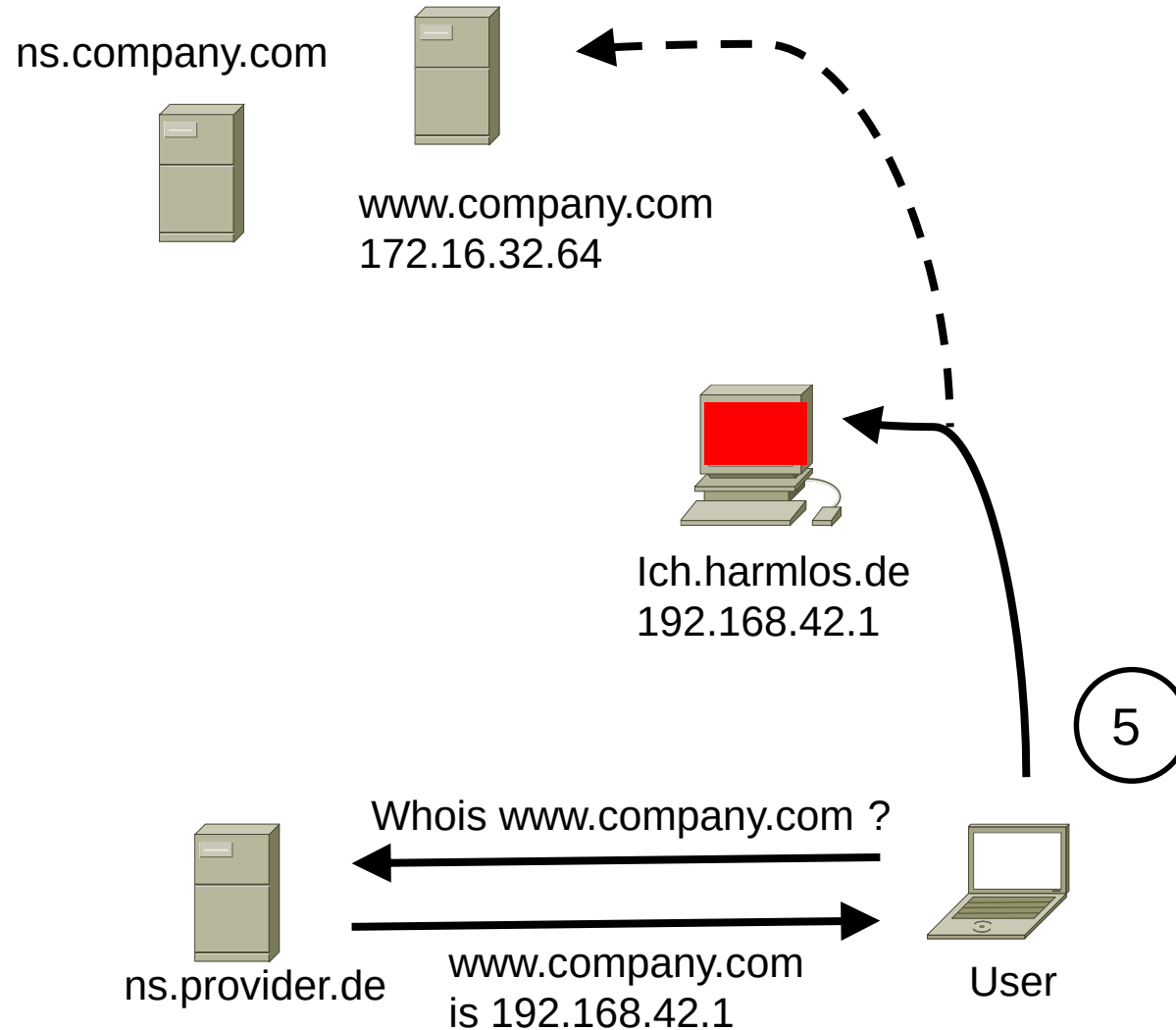
Netzwerksicherheit – Sniffen Werkzeuge DNS Spoofing



Netzwerksicherheit – Sniffen Werkzeuge DNS Spoofing



Netzwerksicherheit – Sniffen Werkzeuge DNS Spoofing



Netzwerksicherheit – Sniffen Werkzeuge DNS Spoofing

- 1. Der Angreifer stellt eine rekursive Anfrage nach seinem eigenen Rechner, um die aktuelle Query-ID zu ermitteln.*
- 2. Der Angreifer fragt nach `www.company.com` und schickt sofort gefälschte Antworten auf den Weg.*
- 3. Anfrage wird an den zuständigen Nameserver weitergereicht und sofort durch die gefälschten Pakete beantwortet.*
- 4. Die echte Antwort kommt zu spät und wird verworfen. Der Provider-Nameserver antwortet mit den gefälschten Informationen.*
- 5. Ein Anwender will auf '`www.company.com`' zugreifen und wird aufgrund der gefälschten Daten umgelenkt.*

IT-Sicherheit - Verschlüsselung

Prof. Dr. Johannes Freudenmann (DHBW Karlsruhe)
Masterprogramm Informatik

www.dhbw.de

Netzwerksicherheit Techniken Verschlüsseln

- Im ISO/OSI-Modell auf jeder Schicht möglich.
- Leitung
- Luftschnittstelle (WEP/WPA-X, GSM/LTE/5G)
- Ende-Ende, IPSec
- TLS – SSL
- SSH
- (Anwendungsebene – Mail, File, ..., -> Straub)

Netzwerksicherheit Techniken Verschlüsseln Leitung

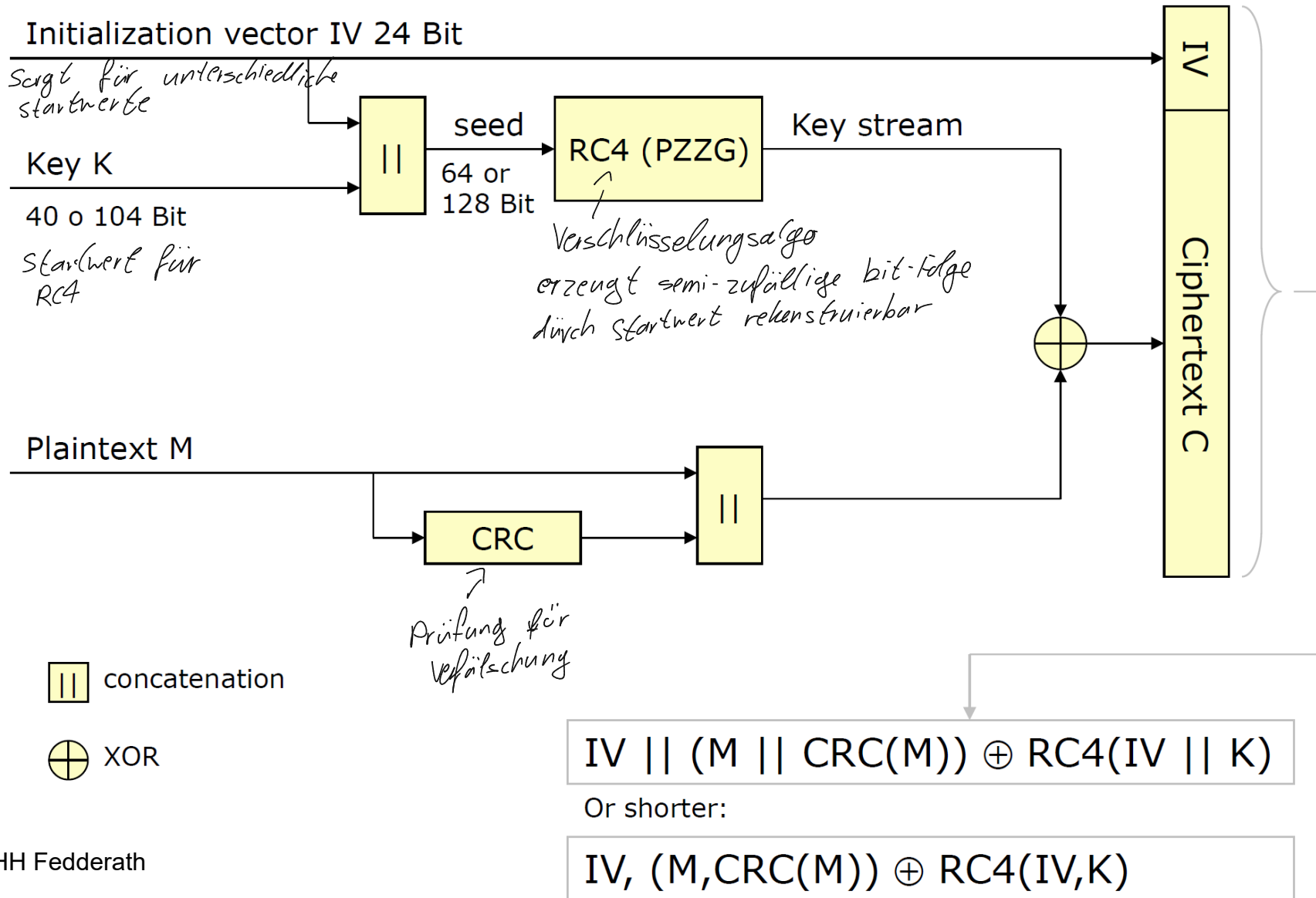
- Verschlüsselungsbox an beiden Enden.
 - Einfache Installation
 - Starker symmetrischer Algorithmus
 - Boxen werden paarweise produziert.
 - Öffnen verhindern, Prozessor gekapselt.
 - Höchste Sicherheitsstufe auch für hohe Sicherheitsanforderungen (Polizei, Nachrichtendienste, Militär)

Netzwerksicherheit Techniken Verschlüsseln WLAN/WEP

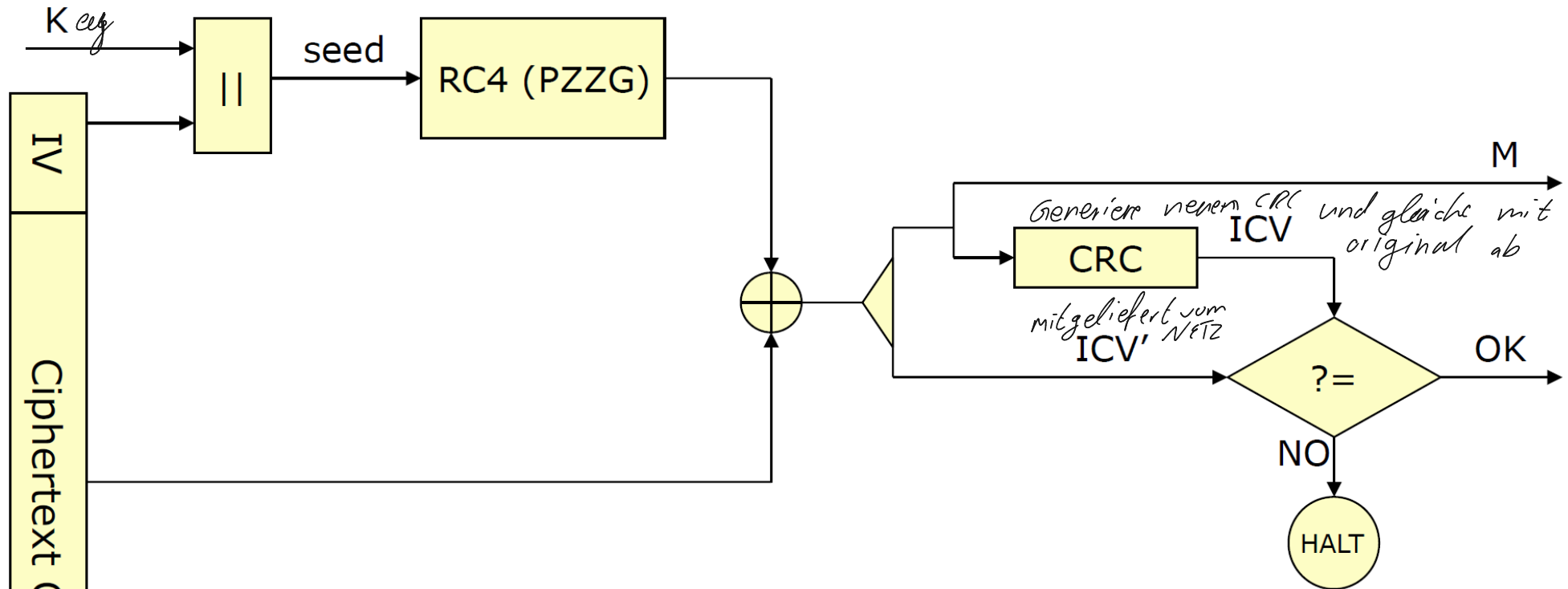
*WEP- Wired Equivalent
Privacy*

- Allgemein
 - Optionaler Teil von IEEE 802.11
 - Verschlüsselung, Integrität und Authentizität
 - 1997 eingeführt, in praktisch allen WLAN-Geräten implementiert (inzwischen nicht mehr unterstützt).
- Verschlüsselung
 - Symmetrisch mit 40 oder 104 bit Schlüssel auf Basis RC4
- Integrität durch CRC
- Authentizität
 - Methode 1: keine
 - Methode 2: Challenge-Response mit PSK

Netzwerksicherheit Techniken Verschlüsseln WEP Encrypt



Netzwerksicherheit Techniken Verschlüsseln WEP Decrypt



concatenation



XOR

2x XOR → original datenstrom



Reverse function of



UHH Fedderath

Initialisierungsvektor wird im Klartext mitgeschickt

Schlüssel K wird an Berechtigte WLAN-Teilnehmer versendet

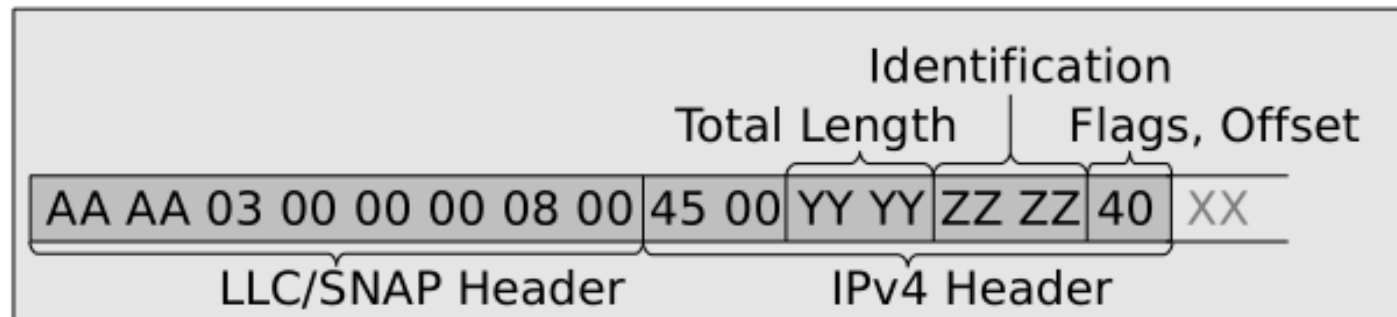
Netzwerksicherheit Techniken Verschlüsseln WEP

- Authentizität wird nur bei shared key geprüft.
 - Challenge vom Access Point
 - Client sendet verschlüsselte Challenge als Response
 - Kein Zugriff bei Fehler.
- Viele Angriffsmöglichkeiten
 - Replay
 - IV zu kurz, zu wenig Alternativen
 - Aus IV und verschlüsselter Nachricht ist key berechenbar (Startet mit SNAP-Pattern 0xAAAA03) *DES* *Nachrichten starten immer gleich*
 - Key 40 bit (Brute Force Attack)
- Abgelöst durch WPA (2004), WPA2 bzw. WPA3

Netzwerksicherheit Techniken WEP Angriffe

- Fluhrer, Mantin und Shamir Angriff (2001)
 - ca. 1.000.000 benötigte Pakete
 - Um die 40 Minuten
- Tews, Pychkine und Weinmann Angriff (2007 TU Darmstadt)
 - 40.000 bis 100.000 Pakete
 - 1-2 Minuten

*Teil CRC manipuliert / geändert,
um Stücke vom Key herauszufinden*



Netzwerksicherheit Techniken WLAN Verschlüsseln WPA

- WEP unsicher
- Neuer Sicherheitsstandard IEEE 802.11i
- 2004 ist WPA Teil des Standards
- Schlüssel dynamisch
TKIP - Temporal Key Integrity Protocol
neuer Schlüssel je Session (3200 sec -120 sec)
- Integrität wird geprüft
MIC - Message Integrity Check
- Authentifizierung
 - PSK – Pre Shared Key
 - EAP - Enterprise Authentication Protocol

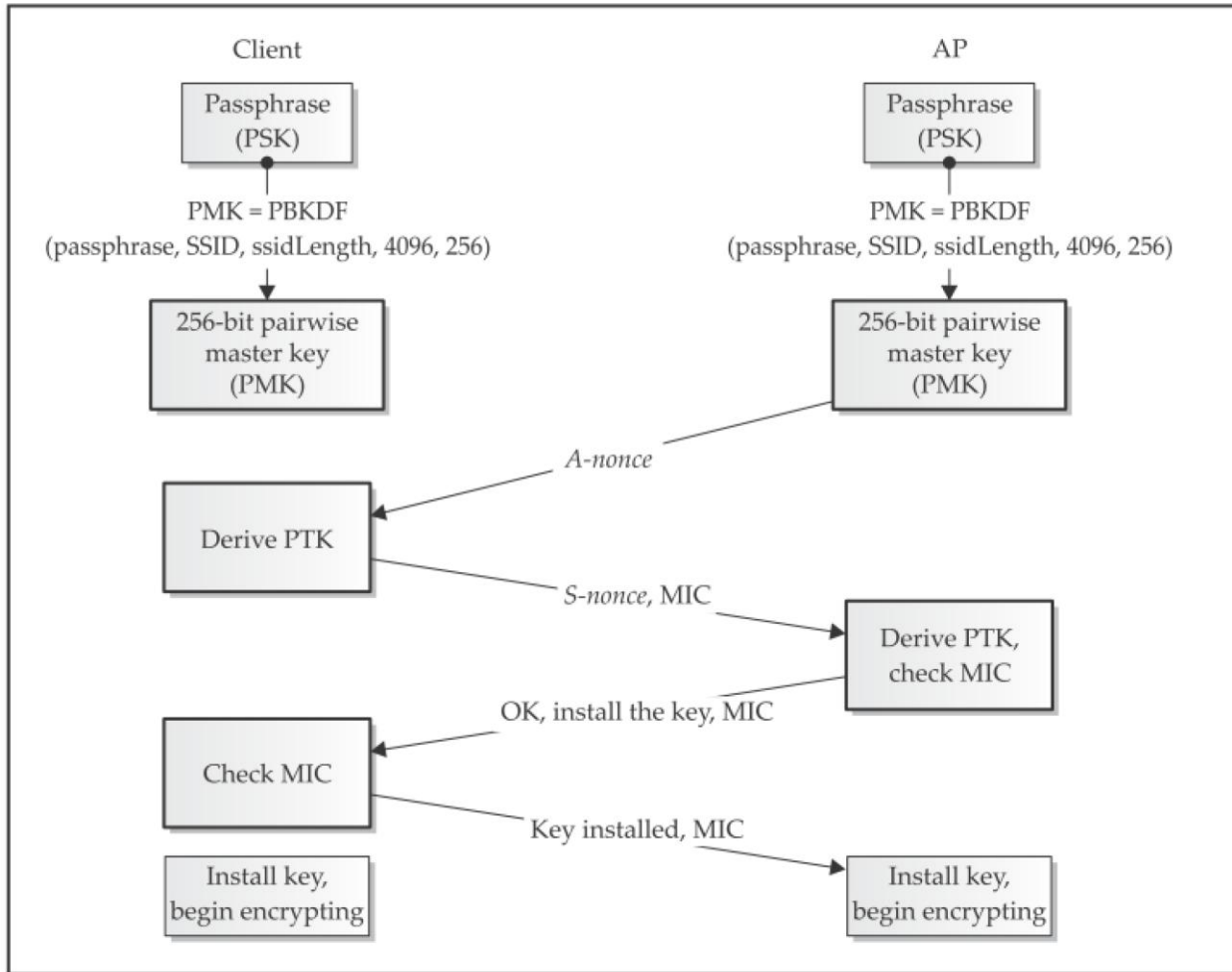
WPA-Personal Übersicht

Access Point
↓

Number only used once
NONCE

Client authentisiert sich direkt gegenüber AP mit PMK

Four-way handshake (alle Infos ausser SSID)



PSK = 8-63 ASCII Zeichen
+ Hash

Pairwise Master Key (PMK)
PMK = SSID x PSK + Hash!

Pairwise Transient Key (PTK)
PTK = PMK, S/A-Nonce, MAC
(Client/AP)

PTK = dynamisch
(Anmeldung & periodisch)

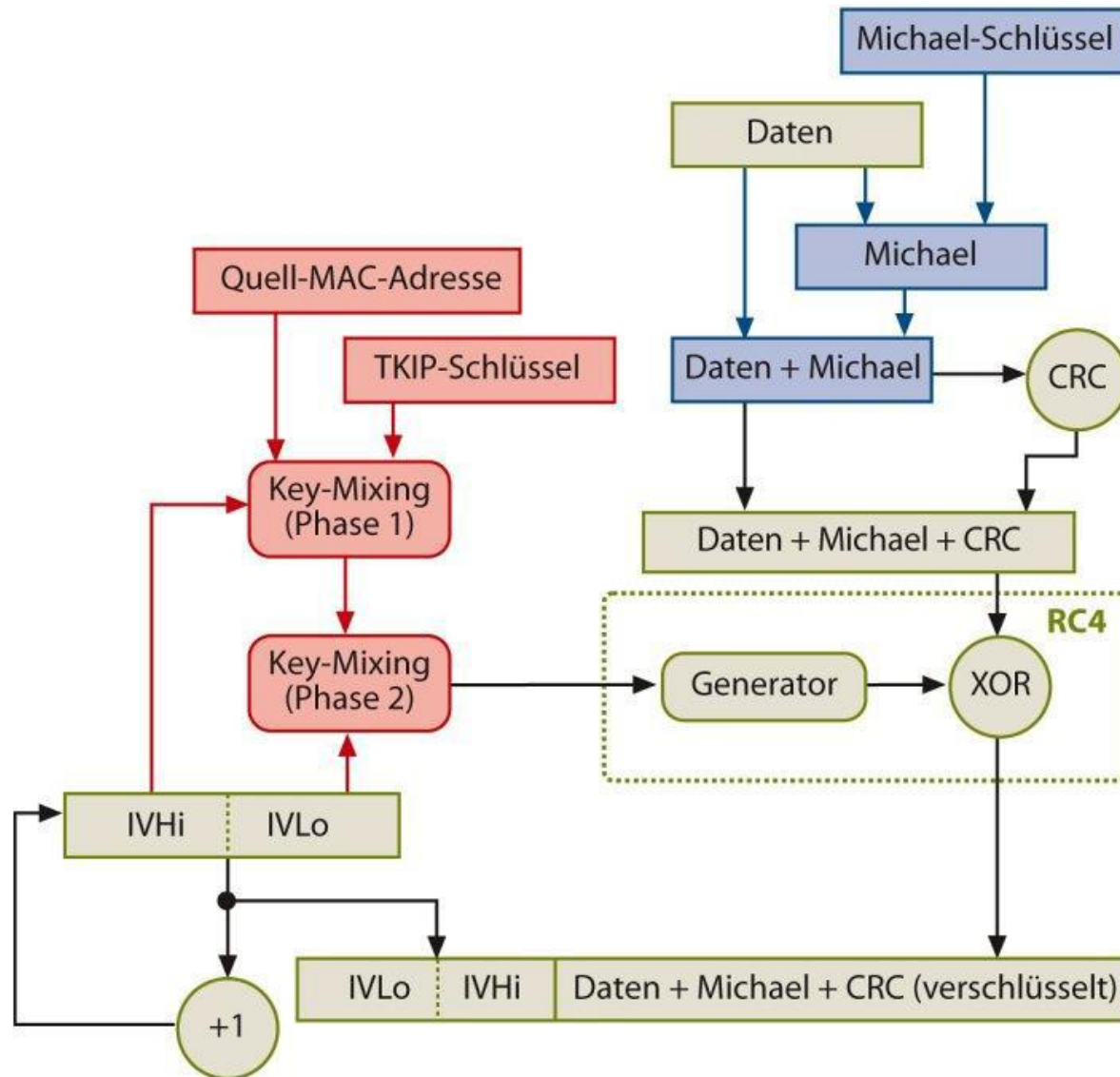
Skizze: Belsoft Security

WPA – Zwischenlösung auf dem Weg zu WPA2

- Wenig leistungsfähige AccessPoints durch Software ertüchtigen und WEP ersetzen.
- Schlüssel öfter ersetzen (s. vorige Folie, ca 10.000 Pakete)
- TKIP (Temporal Key Integrity Protocol)
 - MIC ergänzt CRC. Verfahren Michael (geringer Berechnungsaufwand)
 - Längerer IV und Regelungen für die Verwendung auch als Sequenznummer gegen Replay
 - Weiter RC4 genutzt (Schlüssel auf 64 bit beschränkt)
↳ Backwards compatibility
 - Nicht mehr genutzt bei WPA2

MIC - Message Identity code

WLAN Verschlüsseln WPA



WLAN Verschlüsseln WPA

- Schwachstellen
 - Basis RC4 (Schlüssel nur 64 Bit lang)
 - ARP-Spoofing möglich
 - Angriff auf das Passwort durch Dictionary Attack

Netzwerksicherheit Techniken Verschlüsseln WPA2

- Authentifizierung mit
 - Pre-Shared Key
 - Radius
 - EAP (Extensible Authentication Protocol, RFC5247)
- AES für Verschlüsselung

WPA2 – KRACK Attack

- Angriff auf den 4way Handshake
- KRACK Key Reinstallation attACK.
- Message 3 des Handshake wird wiederholt an den Client gesandt
 - Der gleiche Schlüssel wird neu installiert
 - PacketSendeZähler wird zurückgesetzt
 - EmpfangsReplay Zähler wird zurückgesetzt.
 - Angriffsmöglichkeiten ergeben sich.
- Update des Clients behebt das Problem. *Reaktion: zweiter Handschake ignorieren*
- <https://www.krackattacks.com/>

WPA 3

- Verabschiedet 25. Juni 2018
- Bessere Authentifizierung und Verschlüsselung
- KRACK-Sicherheitslücke behoben durch besseren Handshake
- Höherer Schutz auch bei einfachen Passwörtern
- Einfachere Konfiguration für IoT, z.B. durch QR-Code
- Individuelle Verschlüsselung in öffentlichen Netzen
- Einsatz von 192-bit-Verschlüsselung

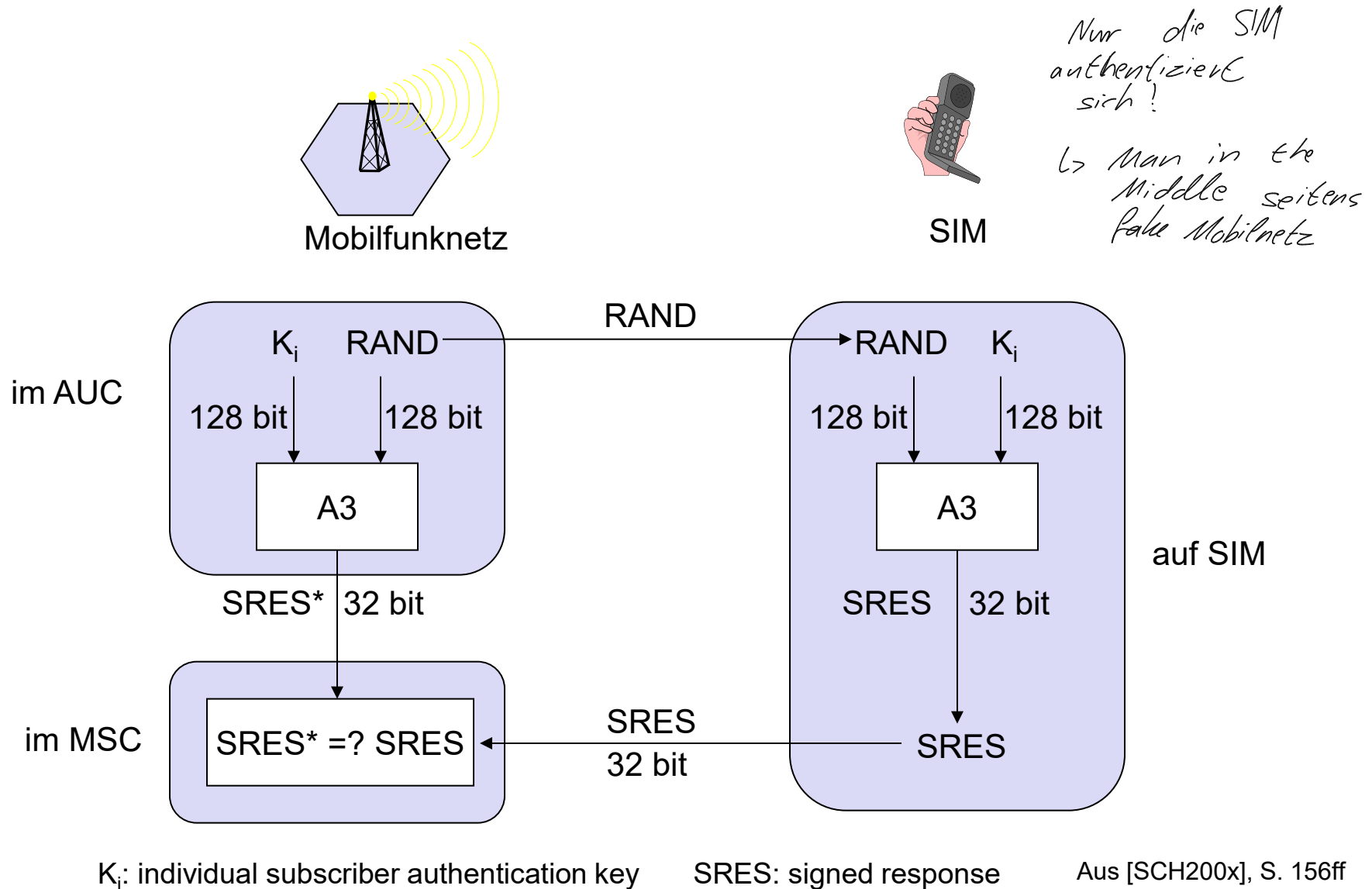
WPA 3

- Höherer Schutz bei einfachen PWD
 - Simultaneous Authentication of Equals (SAE) auf Basis eines Pre Shared Key (PSK).
 - Brute Force Angriff aufwendiger (WPA2 400T/s)
- Individuelle Verschlüsselung
 - Perfect forward secrecy
 - Jede Verbindung verwendet eindeutigen eigenen Schlüssel.
 - In offenen Netzen eigener Schlüssel durch Diffie-Hellman, aber ohne Authentifizierung.

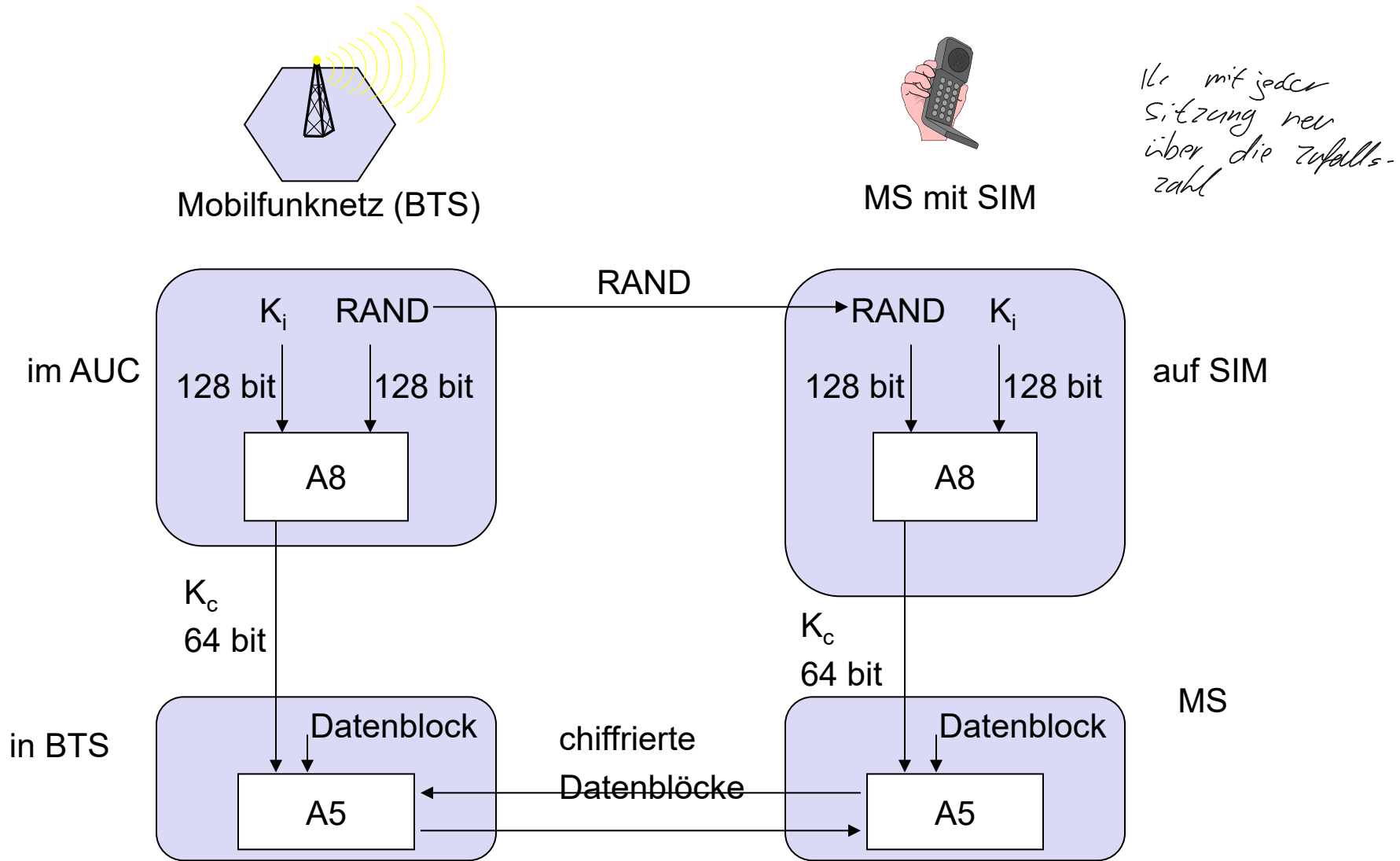
Netzwerksicherheit GSM Sicherheit

- Sicherheitsdienste in GSM
 - Zugangskontrolle / Authentifikation
 - Teilnehmer $\Leftrightarrow$ SIM (Subscriber Identity Module): Geheimnummer PIN
 - SIM $\Leftrightarrow$ Netzwerk: Challenge-Response-Verfahren
 - Vertraulichkeit
 - Sprache und Signalisierungsdaten werden nach erfolgreicher Authentifikation verschlüsselt übertragen.
 - Anonymität
 - Temporäre Teilnehmerkennung TMSI (Temporary Mobile Subscriber Identity)
 - Bei jedem Location Update (LUP) neu vergeben
 - Verschlüsselt übertragen
- 3 Algorithmen in GSM spezifiziert:
 - A3 zur Authentisierung („geheim“, Schnittstelle offengelegt)
 - A5 zur Verschlüsselung (standardisiert)
 - A8 zur Schlüsselberechnung („geheim“, Schnittstelle offengelegt)

Netzwerksicherheit GSM Ablauf Authentifikation

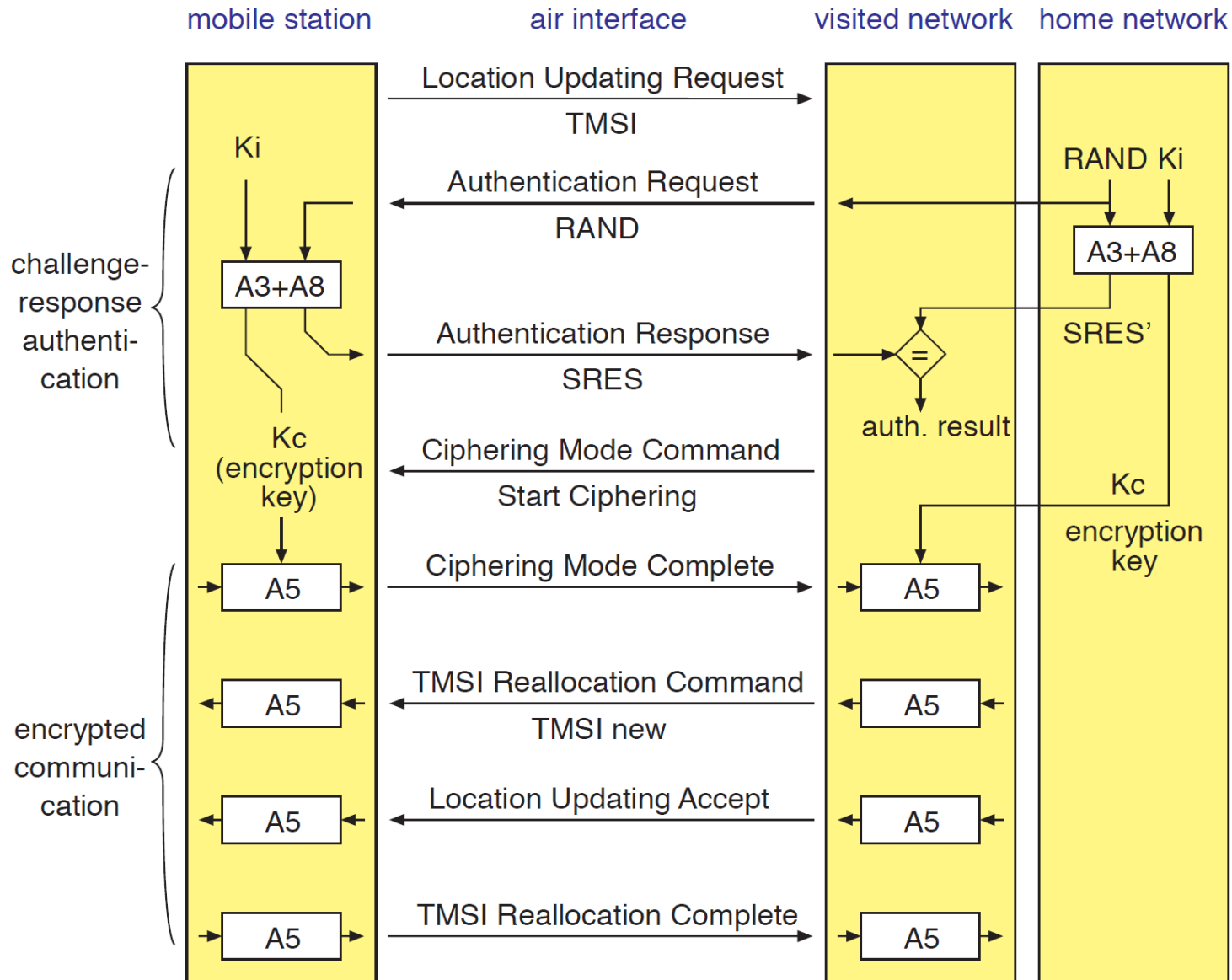


Netzwerksicherheit GSM Ablauf Verschlüsselung

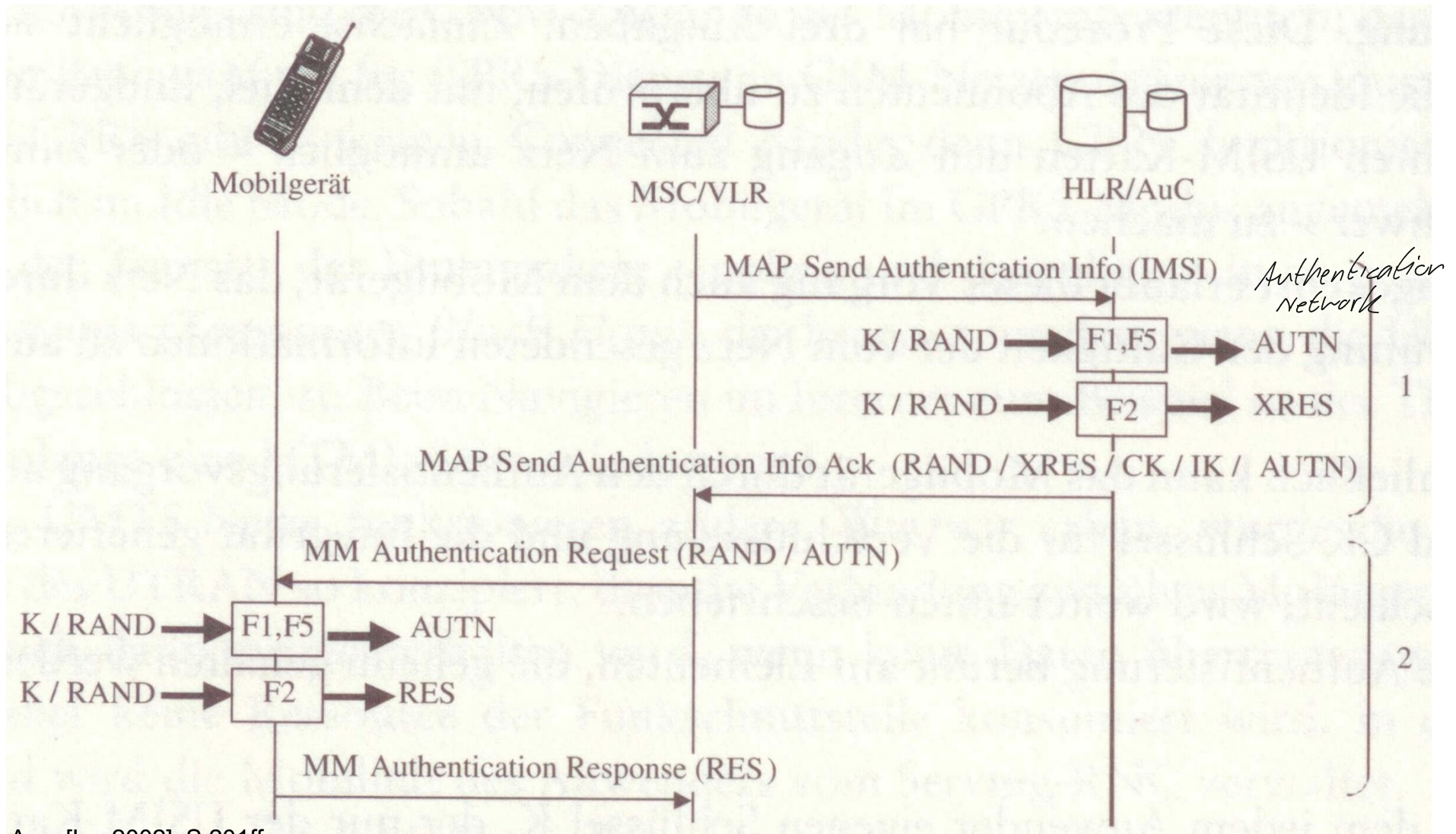


Aus [SCH200x], S. 156ff

Netzwerksicherheit GSM Gesamtablauf

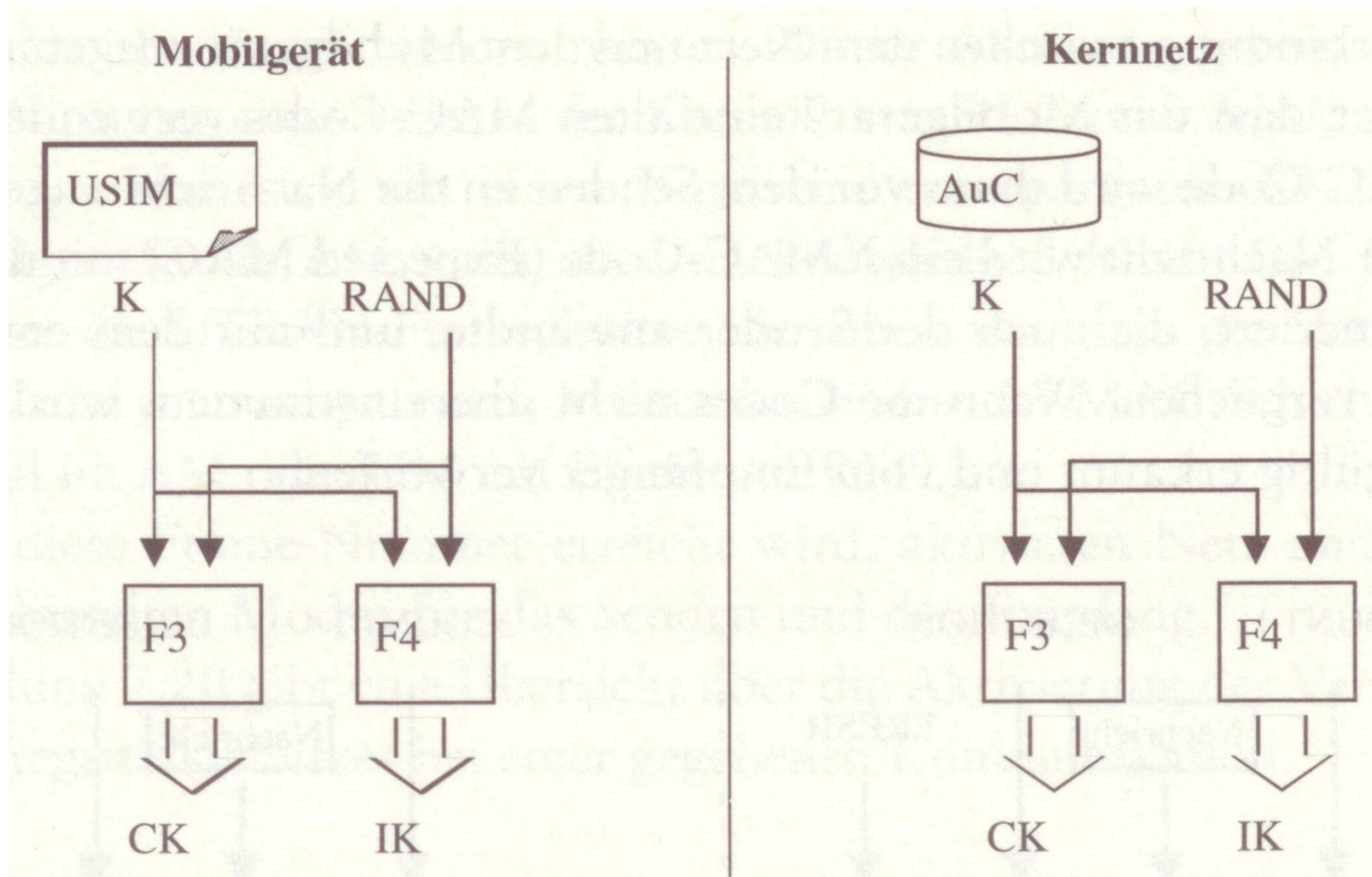


Netzwerksicherheit UMTS Authentisierung



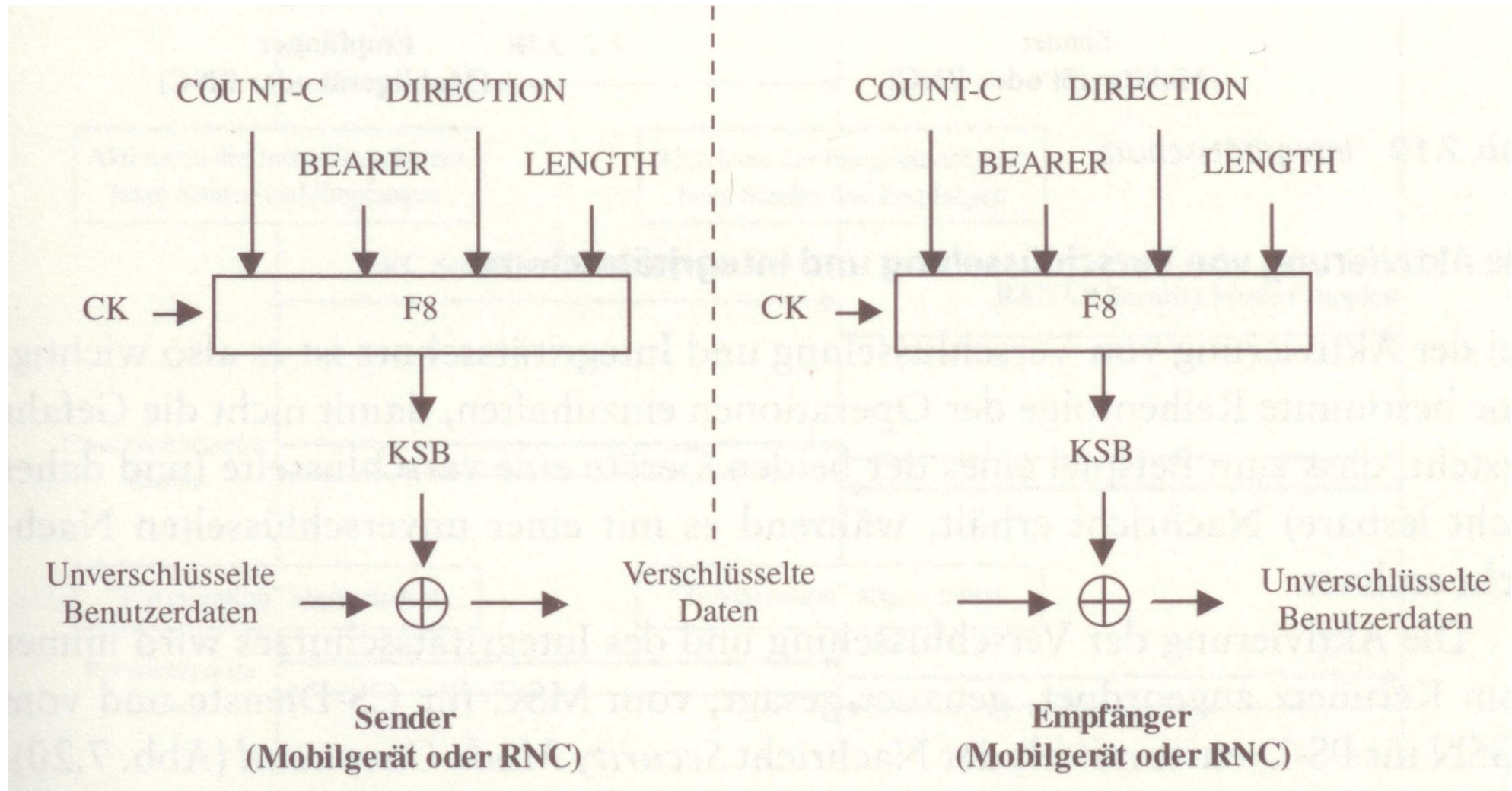
Aus: [Les2002], S.201ff

Netzwerksicherheit UMTS Schlüsselerzeugung



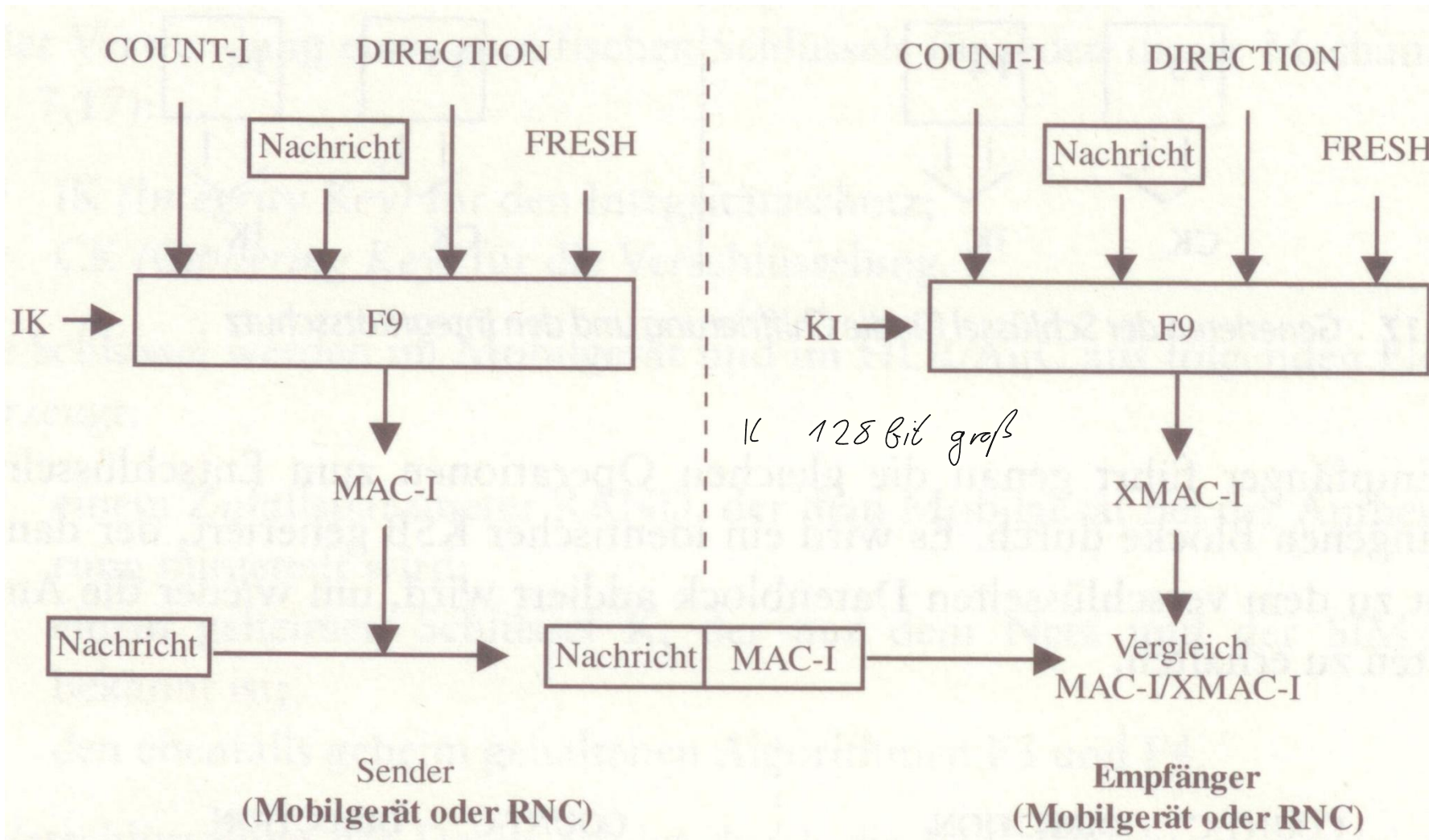
Aus: [Les2002]

Netzwerksicherheit UMTS Verschlüsselung



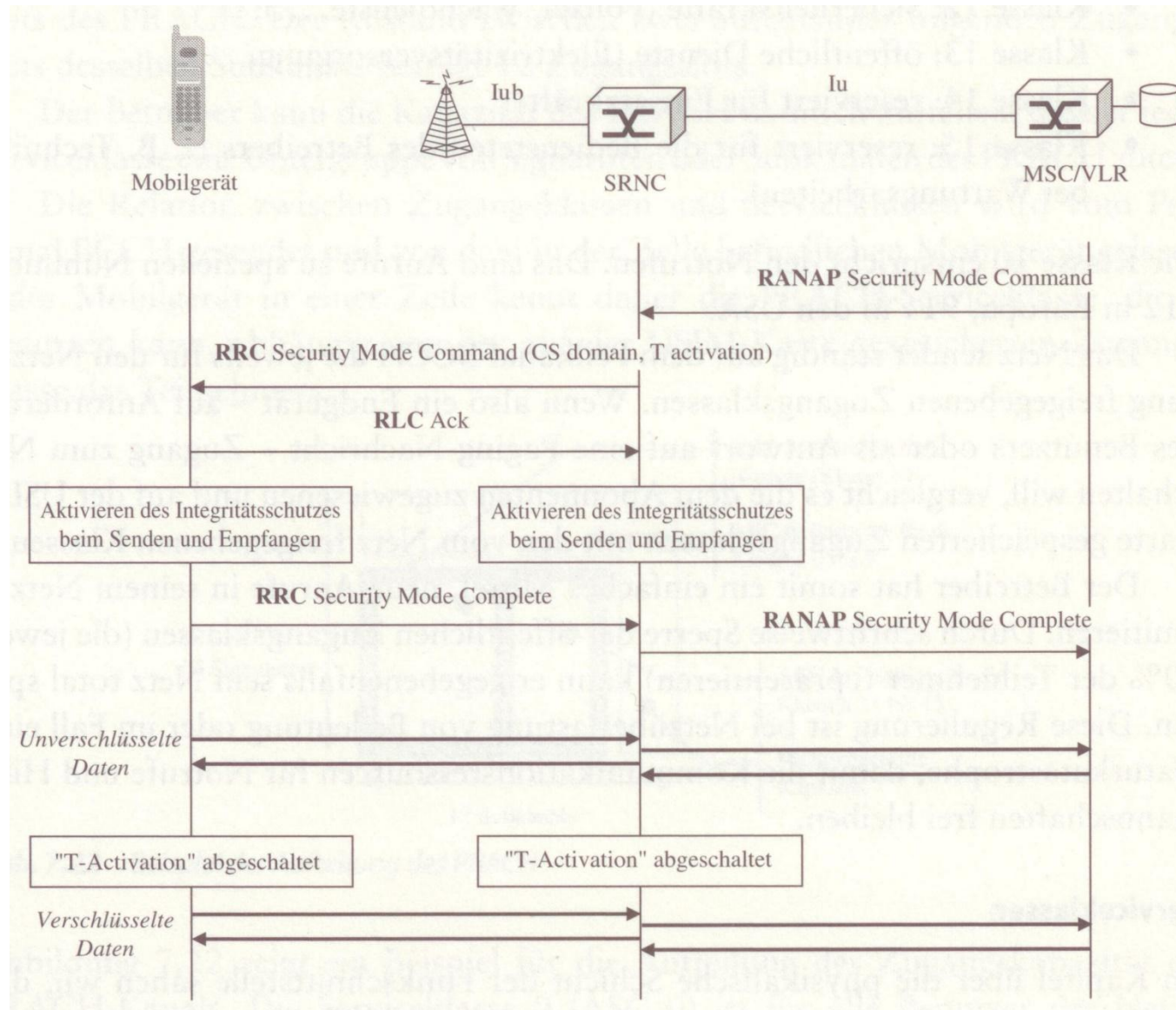
Aus: [Les2002]

Netzwerksicherheit UMTS Integrität



Aus: [Les2002]

Netzwerksicherheit UMTS Gesamtsystem



Aus: [Les2002]

Netzwerksicherheit Techniken Verschlüsseln TLS (SSL)

Transport Layer Security

- 1995 als SSLv2 durch Netscape in Navigator 1.1 eingeführt
- 1996 Überarbeitung von SSLv2 zu SSLv3 (Netscape)
- ‚Quasi-Standard‘ für sichere TCP-Kommunikation
- 1999 Einführung von TLS (Transport Layer Security) v1.0
- IETF Industrie-Standard, eng an SSLv3 angelehnt, aber inkompatibel zu SSLv3 (u.a. HMAC statt MAC, unterschiedliche Berechnung der Schlüssel)
- Open-Source-Implementation unter <http://www.openssl.org>
- RFC 5246->8446 (TLS 1.2)
- RFC 2818 (HTTPS, SSL-basiertes HTTP)
- 21.3.2018 RFC 8446 (TLS 1.3)
- Aktuell ist alles vor TLS1.2 überholt....don't use.



Allgemein



Medien



Berechtigungen



Sicherheit

Website-Identität

Website: de.wikipedia.org

Besitzer: Diese Website stellt keine Informationen über den Besitzer zur Verfügung.

Validiert von: DigiCert Inc

Zertifikat anzeigen

Gültig bis: Dienstag, 6. Oktober 2020

Datenschutz & Chronik

Habe ich diese Website früher schon einmal besucht? Ja, 91 Mal

Speichert diese Website Daten auf meinem Computer? Ja, Cookies

Cookies und Website-Daten löschen

Habe ich Passwörter für diese Website gespeichert? Nein

Gespeicherte Passwörter anzeigen

Technische Details

Verbindung verschlüsselt (TLS_CHACHA20_POLY1305_SHA256, 256-Bit-Schlüssel, TLS 1.3)

Die Seite, die Sie ansehen, wurde verschlüsselt, bevor sie über das Internet übermittelt wurde.

Verschlüsselung macht es für unberechtigte Personen schwierig, zwischen Computern übertragene Informationen anzusehen. Daher ist es unwahrscheinlich, dass jemand diese Seite gelesen hat, als sie über das Internet übertragen wurde.

Hilfe



Allgemein



Medien



Berechtigungen



Sicherheit

Website-Identität

Website: www.dhbw.de

Besitzer: Diese Website stellt keine Informationen über den Besitzer zur Verfügung.

Validiert von: Verein zur Foerderung eines Deutschen Forschungsnetzes e. V.

[Zertifikat anzeigen](#)

Gültig bis: Freitag, 24. April 2020

Datenschutz & Chronik

Habe ich diese Website früher schon einmal besucht? Ja, 104 Mal

Speichert diese Website Daten auf meinem Computer? Ja, Cookies

[Cookies und Website-Daten löschen](#)

Habe ich Passwörter für diese Website gespeichert? Nein

[Gespeicherte Passwörter anzeigen](#)

Technische Details

Verbindung verschlüsselt (TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384, 256-Bit-Schlüssel, TLS 1.2)

Die Seite, die Sie ansehen, wurde verschlüsselt, bevor sie über das Internet übermittelt wurde.

Verschlüsselung macht es für unberechtigte Personen schwierig, zwischen Computern übertragene Informationen anzusehen. Daher ist es unwahrscheinlich, dass jemand diese Seite gelesen hat, als sie über das Internet übertragen wurde.

[Hilfe](#)



Allgemein



Medien



Berechtigungen



Sicherheit

Website-Identität

Website: www.dhbw.de

Besitzer: Diese Website stellt keine Informationen über den Besitzer zur Verfügung.

Validiert von: Verein zur Foerderung eines Deutschen Forschungsnetzes e. V.

[Zertifikat anzeigen](#)

Gültig bis: Mittwoch, 29. Juni 2022

Datenschutz & Chronik

Habe ich diese Website früher schon einmal besucht? Ja, 30 Mal

Speichert diese Website Daten auf meinem Computer? Ja, Cookies und 119 KB Website-Daten

[Cookies und Website-Daten löschen](#)

Habe ich Passwörter für diese Website gespeichert? Nein

[Gespeicherte Passwörter anzeigen](#)

Technische Details

Verbindung verschlüsselt (TLS_AES_256_GCM_SHA384, 256-Bit-Schlüssel, TLS 1.3)

Die Seite, die Sie ansehen, wurde verschlüsselt, bevor sie über das Internet übermittelt wurde.

Verschlüsselung macht es für unberechtigte Personen schwierig, zwischen Computern übertragene Informationen anzusehen. Daher ist es unwahrscheinlich, dass jemand diese Seite gelesen hat, als sie über das Internet übertragen wurde.

[Hilfe](#)

Seiteninformationen - https://www.dhbw.de/startseite

Allgemein Medien Berechtigungen **Sicherheit**

Website-Identität

Website: www.dhbw.de

Besitzer: Diese Website stellt keine Informationen über den Besitzer zur Verfügung.

Validiert von: GEANT Vereiniging [Zertifikat anzeigen](#)

Datenschutz & Chronik

Habe ich diese Website früher schon einmal besucht? Ja, 480 Mal

Speichert diese Website Daten auf meinem Computer? Ja, Cookies und 783 KB Website-Daten [Cookies und Website-Daten löschen](#)

Habe ich Passwörter für diese Website gespeichert? Nein [Gespeicherte Passwörter anzeigen](#)

Technische Details

Verbindung verschlüsselt (TLS_AES_128_GCM_SHA256, 128-Bit-Schlüssel, TLS 1.3)

Die Seite, die Sie ansehen, wurde verschlüsselt, bevor sie über das Internet übermittelt wurde.

Verschlüsselung macht es für unberechtigte Personen schwierig, zwischen Computern übertragene Informationen anzusehen. Daher ist es unwahrscheinlich, dass jemand diese Seite gelesen hat, als sie über das Internet übertragen wurde.

Diese Website entspricht den Vorschriften für Zertifikat-Transparenz.

[Hilfe](#)

Netzwerksicherheit Techniken Verschlüsseln TLS (SSL)

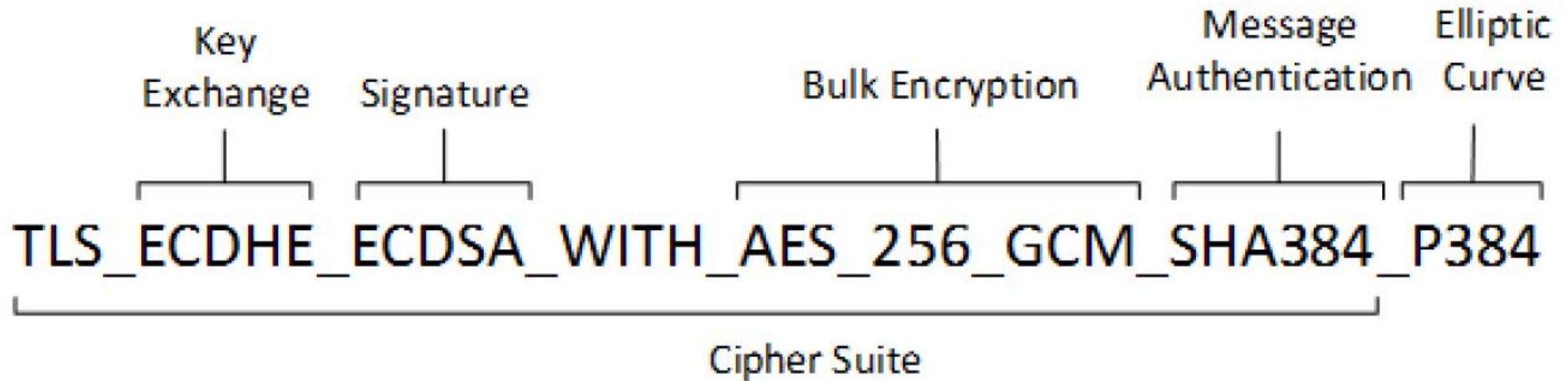
- **SSL/TLS: Konzepte und Schutzziele**
 - Basis: SSL/TLS setzt auf Schicht 4 (Transport) auf
 - Client-Server-Kommunikationsparadigma
- **Session:**
 - Aushandlung von zu verwendenden Krypto-Algorithmen und von einem gemeinsamen Master-Secret (MS),
 - Ggf. mehrere Verbindungen zugeordnet,
 - alle Verbindungen einer Session basieren auf dem MS.
- **Verbindung:** (entspricht einer TCP-Verbindung)
 - individuelle Keys pro Verbindung, abgeleitet aus MS
 - Verwendung der Algorithmen der zugeordneten Session
 - Verbindungsaufbau: vorhandene Session, oder neue

Netzwerksicherheit Techniken Verschlüsseln TLS (SSL)

- Bezug zu **Schutzzielen**
 - Sichere Client-Server-Kommunikation
- Authentifikation:
 - wechselseitig, einseitig (meist nur Server), anonym
 - Mechanismen: X509-Zertifikate, MACs (MD5, SHA-1,...)
- Integrität von Nachrichten
 - mit HMAC/MAC-Verfahren: SHA-1, MD5, SHA256
- Vertrauliche Datenübertragung
 - wählbare **Cipher-Suite**, (siehe nächste Folie)
 - symmetrische Verfahren
- Schlüsselaustausch:
 - Public-Key-Verfahren: RSA, DH

*der Server authentifiziert
sich über Signatur/Zertifizierung*

Windows 10 1709 TLS Suites Beispiele



- `TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA384`
- ...
- `TLS_RSA_WITH_3DES_EDE_CBC_SHA`
- No `TLS_RSA_WITH_NULL_SHA256`

*Gruppe von Verfahren
einer TLS Session*

Windows 10 1709 TLS Suites Beispiele

- TLS_ECDHE_ECDSA_WITH_AES_256_GCM_SHA384
- TLS Version 1.2
- ECDHE – Ephemeral Elliptic Curve Diffie-Hellman key exchange
- ECDSA - Elliptic Curve Digital Signature Algorithm
- AES_256_GCM – Advanced Encryption Standard Galois/Counter Mode
- SHA384 – Secure Hash Algorithm
- Verwendete Elliptic Curve wird noch referenziert.

Windows TLS Cipher Suites

- <https://clienttest.sslabs.com>

Testet die cipher suites, die Ihr Browser zulässt.

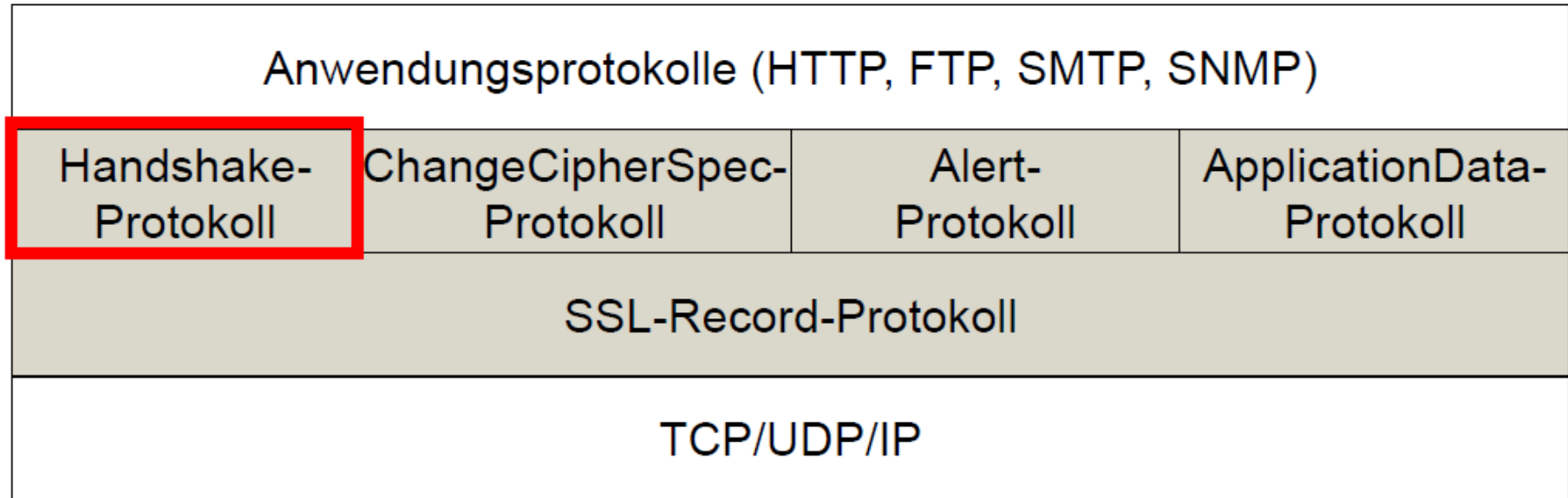
- Einstellung/Einschränkung der Cipher Suites

??

Firefox – about:config – einige Verfahren auswählen.

Netzwerksicherheit Techniken Verschlüsseln TLS (SSL)

- TLS Protokolle



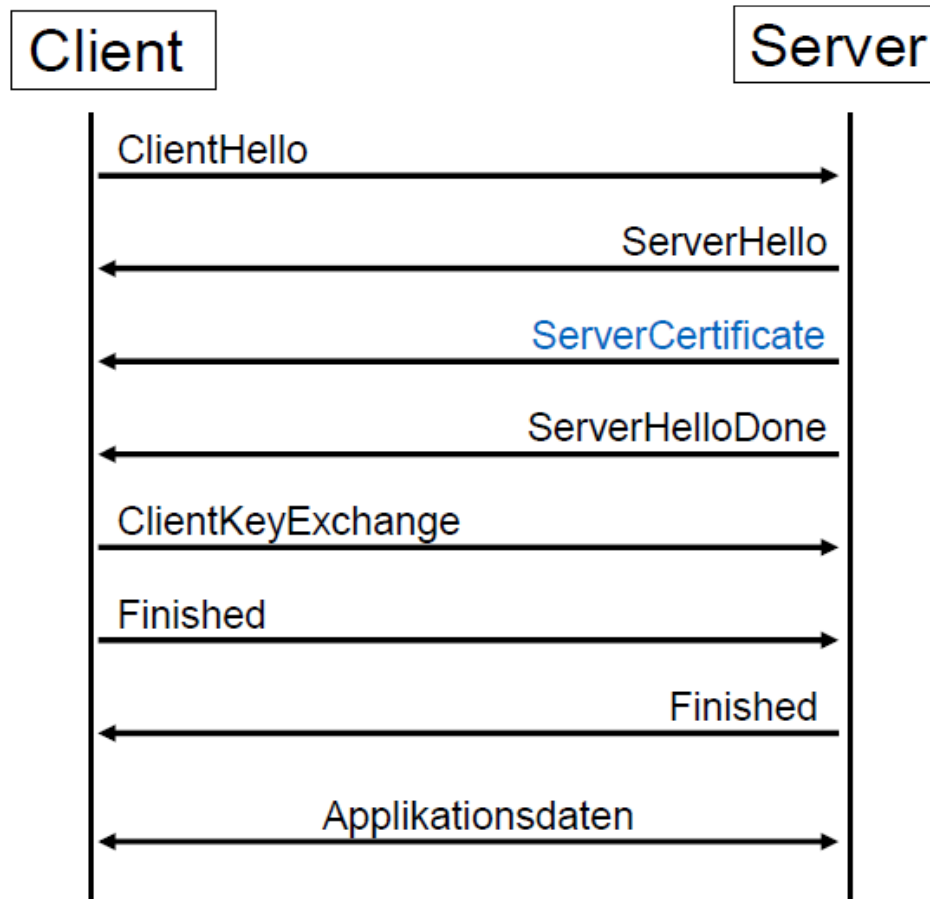
- **ChangeCipherSpec-Protokoll:** 1Byte
 - Zeigt die Verwendung der vereinbarten Verfahren an
- **Alert-Protokoll:** Fehlerbehandlung, (2 Byte)
 - Erstes Byte: Schwere (1=Warnung; 2=Abbruch)
 - Zweites Byte: Fehlertyp (z.B. MAC-Prüfung schlägt fehl)

Netzwerksicherheit Techniken Verschlüsseln TLS (SSL)

- **SSL/TLS-Handshake-Protokoll Aufgaben:**
 - Festlegen der zu verwendenden Krypto-(Suite)
 - Austausch von geheimer Basis-Information
 - unidirektionale Verbindung: mit unterschiedlichen Schlüsseln
 - Authentifikation mittels X509.v3-Zertifikaten
 - Verwaltung von Sitzungsinformationen:
Client/Server kann mehrere offene Sitzungen haben
- **Verschiedene Modi:**
 - Server authentifiziert, Client anonym (u.a. Web-Portale)
 - Server und Client authentifiziert (über Zertifikate)
 - Server und Client anonym

Netzwerksicherheit Techniken Verschlüsseln TLS (SSL)

- **SSL/TLS-Handshake-Protokoll**
 - **Server Auth, Client anon.**



ClientHello:

- Protokollversion
- Randomzahl R_c
- bekannte Verschlüsselungsmethoden
- bekannte Komprimierungsmethoden

ServerHello:

- Protokollversion
- Randomzahl R_s
- gewählte Verschlüsselungsmethoden
- gewählte Komprimierungsmethoden

ServerCertificate:

- Liste der Zertifikate der Zertifizierungskette
- Server-Public-Key, beim RSA-Verfahren

ClientKeyExchange:

- Pre-master Secret mit **Server-Public-Key verschlüsselt**

Finished (Server bzw. Clientkennung):

- Berechnen des Master-Secrets aus Pre-master und den Random-Werten R_c , R_s
- MD5-Hash-Wert mit Master-Secret über die bisher ausgetauschten Nachrichten
- SHA-Hash-Wert mit Master-Secret über die bisher ausgetauschten Nachrichten

Netzwerksicherheit Techniken Verschlüsseln TLS (SSL)

- **SSL-Record-Protokoll**

- Aufteilung der Daten in Fragmente (und Kompression)
- MAC-Berechnung u. Verschlüsseln der Daten

- **Schlüsselerzeugung**

- **Schlüsselberechnung** aus Pre , R_C , R_S
- Berechnen des Master-Secrets durch Client u. Server
- Master-Secret = $MD5(Pre \mid SHA('A' \mid Pre \mid RC \mid RS)) \mid$
 $MD5(Pre \mid SHA('BB' \mid Pre \mid RC \mid RS)) \mid$
 $MD5(Pre \mid SHA('CCC' \mid Pre \mid RC \mid RS))$
- **Master-Secret:** $3 \cdot 128 \text{ Bit} = 384 \text{ Bit} = \mathbf{48 \text{ Byte}}$

- Aus Master-Secret geheime Session- und der MAC-Schlüssel durch mehrmalige Anwendung von MD5 und SHA-1 auf das Master-Secret ableiten

Netzwerksicherheit Techniken Verschlüsseln TLS (SSL)

- TLS unterstützt verschiedene Schlüsselaustauschverfahren
RSA ist eine Möglichkeit
- Alternative: Nutzung des DH-Verfahrens:
 - idR in Kombination mit DSS, wg. Man-in-the-Middle
 - Server generiert temporären DH-Public_Key: KDH
 - Server signiert KDH mit seinem DSS-Signaturschlüssel
 - Server erhält die DH-Parameter des Clients
 - Server und Client berechnen den gemeinsamen DH-Schlüssel KSC
 - der Schlüssel KSC ist dann das Pre-Master-Secret
- Anonymes DH: nur Austausch von DH-Parametern,
 - anfällig gegen Man-in-the-Middle

Netzwerksicherheit Techniken Verschlüsseln TLS (SSL)

- **Client-Authentifikation: optional**
 - Server initiiert die Client-Authentifizierung, d.h. er entscheidet, ob Client-Authentifizierung notwendig ist
 - Server sendet Certificate_Request-Nachricht
 - Client signiert die Daten aus dem Request:
RSA(Request_Data, Private_KeyClient)
 - Client sendet Client-Zertifikat und signierten Request
 - Server prüft die Signatur
- **Session:** das Handshake-Protokoll unterstützt:
 - erneute Verwendung von Session-IDs, z.B. Web
 - Aushandeln neuer Ciphersuites während einer Session
 - Re-Keying Verbindung: Handshake mit frischen Nonces

Netzwerksicherheit Techniken Verschlüsseln TLS (SSL)

- **Probleme, Grenzen von SSL**

- keine Verbindlichkeit: keine Signaturen
- Probleme beim Zusammenwirken mit Firewalls möglich
- Vielzahl von vorkonfigurierten CAs: Vertrauen?

- Werden Zertifikate geprüft? Warnungen ignoriert?
- Stimmt Name im Zertifikat mit URL überein?

- Sichere Speicherung Master-Secrets, der Session-Keys?
- Hacker-Angriffe auf CAs (u.a. DigiNotar 2011): *zertifikatdiebstahl*
- Haftung für CA-Betreiber? (EU-Regelung in Vorbereitung)
- Häufig fehlende Zertifikatprüfung bei non-Browse-Anwendungen (Cloud-Storage, PayPal Payment etc) durch fehlerhafte Nutzung von SSL-Libraries:

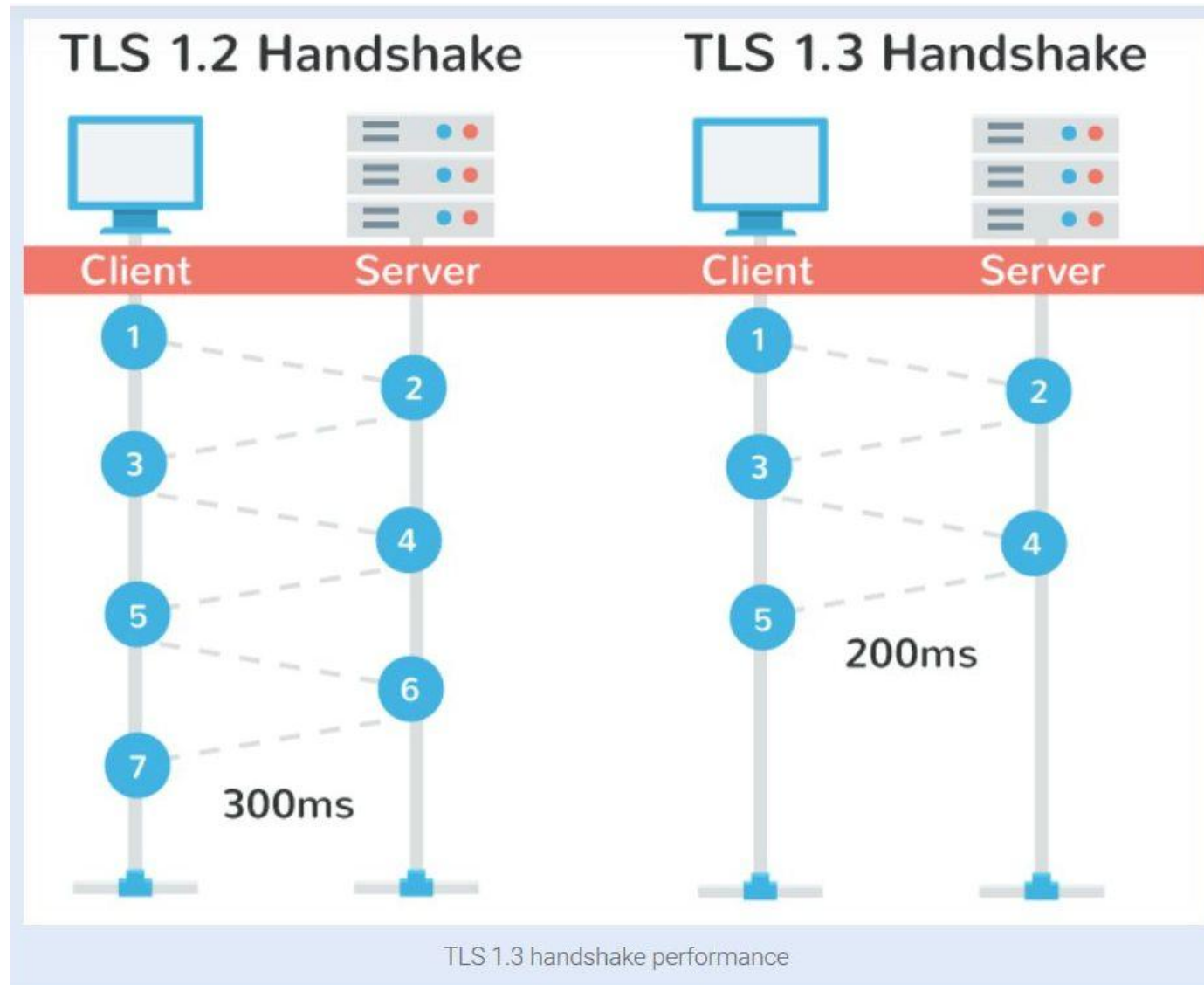
- anfällig gegen MitM Angriffe

Man in the Middle

Netzwerksicherheit Techniken Verschlüsseln TLS 1.3

- Am 21.3.2018 verabschiedet (draft-ietf-tls-tls13-28).
 - Handshake schneller (Schritte eliminiert)
 - Schneller durch moderne Verschlüsselungsprotokolle (forced use)
 - “zero round trip.” (0-RTT) – bekannte Verbindung fortsetzen
 - Unsichere Methoden ausgeschlossen: SHA-1, RC4, DES, 3DES, AES-CBC, MD5..., Export-Verschlüsselung
 - Zeitnah Implementiert in Chrome und Firefox
-
- <https://kinsta.com/blog/tls-1-3/>

Netzwerksicherheit Techniken Verschlüsseln TLS 1.3



<https://kinsta.com/blog/tls-1-3/>

Netzwerksicherheit Techniken Verschlüsseln TLS 1.3

- Cipher Suites eng begrenzt.
- Record Protection und Hash Algorithmus festgelegt.
- TLS_AES_128_GCM_SHA256
- TLS_AES_256_GCM_SHA384
- TLS_CHACHA20_POLY1305_SHA256
- TLS_AES_128_CCM_SHA256
- TLS_AES_128_CCM_8_SHA256

*Ende Vorlesungsblock 1
ab hier Labor*

Netzwerksicherheit Techniken Verschlüsseln IPsec

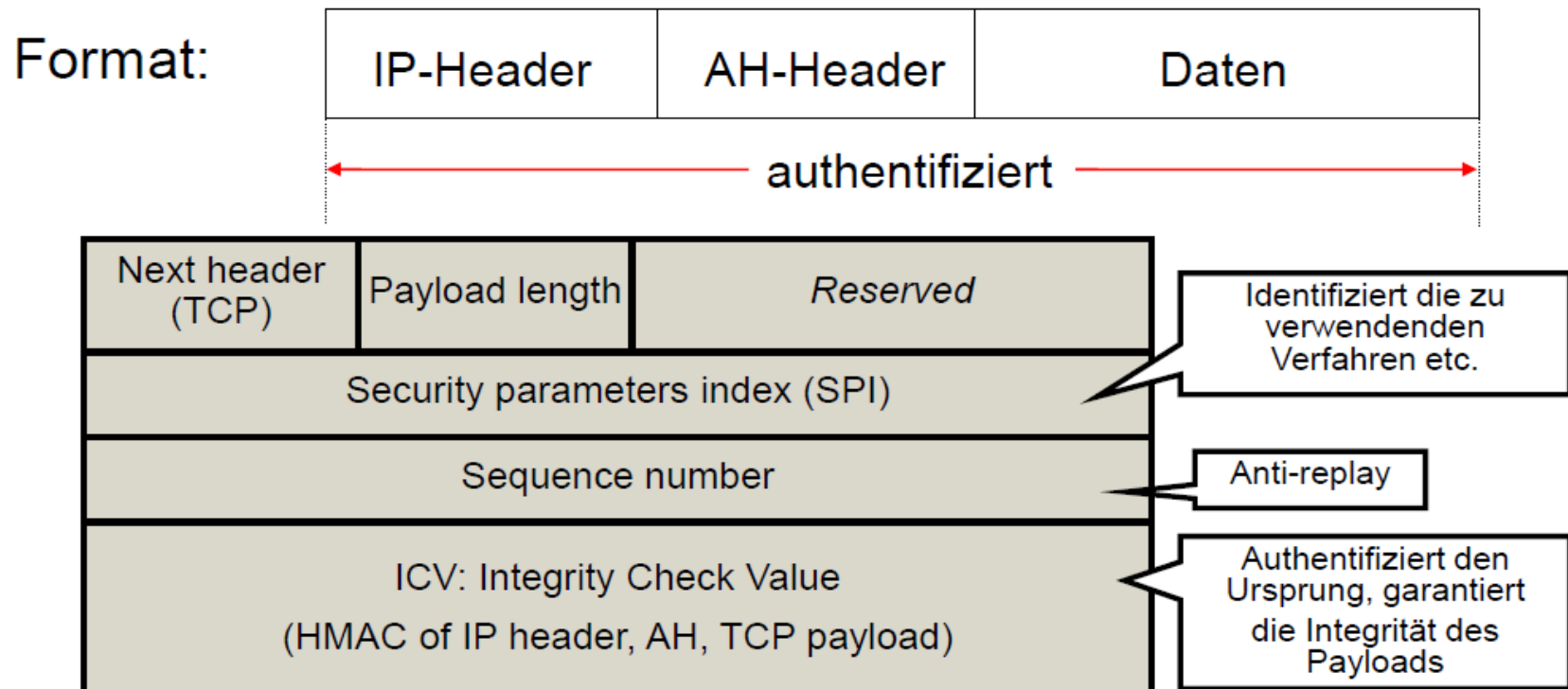
- **IPsec - Standard für Schicht 3**
- **Sicherheitsarchitektur** für Internetprotokolle, seit 1995 verschiedene RFCs: 4302 (AH), 4303 (ESP), 4306 (IKE) ...
 - optionaler Einsatz im IPv4 und **optional** für IPv6 (RFC8504)
 - 2 Modi: Transport und Tunnel-Modus (insbes. bei VPN)
- **Ziel: Gewährleistung von Schutzzielen auf IP-Ebene**
 - Authentizität des Datenursprungs
 - Vertrauliche Datenübertragung (Payload)
 - Integrität u. Schutz vor Replay-Attacken
 - Schlüsselmanagement: Erneuerung, Austausch

Netzwerksicherheit Techniken Verschlüsseln IPsec

- **Protokolle:**
 - AH und ESP: Integrität, Vertraulichkeit angewandt auf einzelne IP-Pakete
 - IKE: Aushandeln der Verfahren und Schlüssel
- **Regelwerk (Policy):** muss konfiguriert werden
 - welche Pakete, von wem, zu wem, mit welchen Verfahren
 - Security-Policy-Database (SPD) (pro IPsec-Rechner)
- **Speicherung der Sicherheitsparameter:**
 - Security-Association (SA): Verfahren, Schlüssel,
 - Verfahren, Schlüssel pro ‚Verbindung‘ : Zustand in IP!
 - Inbound, Outbound-Datenbanken

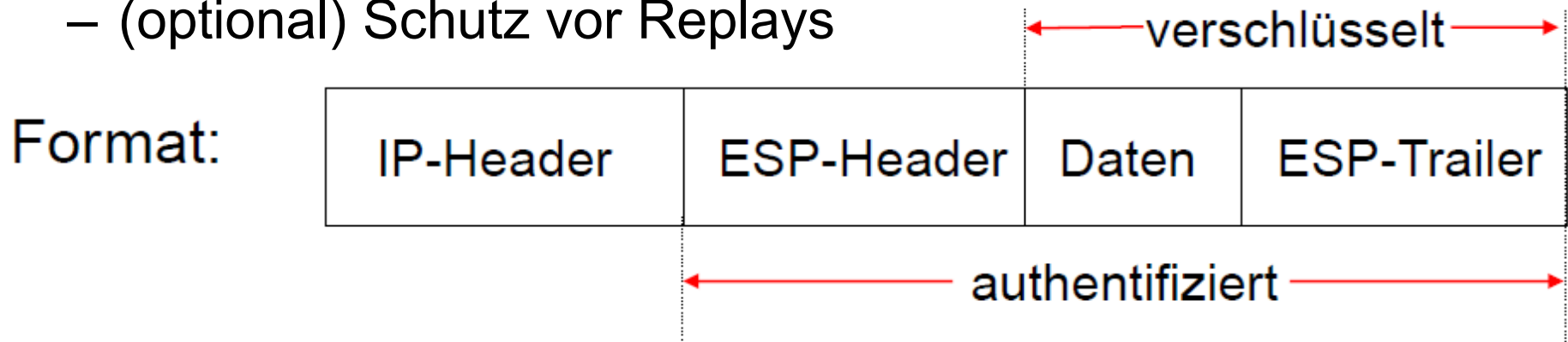
Netzwerksicherheit Techniken Verschlüsseln IPsec

- IP-Protokollerweiterungen: AH und ESP
- Authentication-Header-Protokoll (AH) RFC 4302
 - Authentizität, Integrität des Datenursprung u. Payloads
 - Verhinderung von Replay-Attacken über Sequenznr



Netzwerksicherheit Techniken Verschlüsseln IPsec

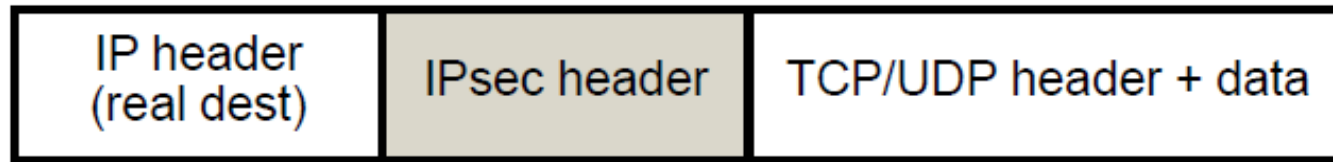
- **Encapsulating Security-Payload (ESP) RFC 4303**
 - Vertraulichkeit der Daten des IP-Datenpakets, Symmetrische Blockchiffre, NULL-Algorithmus zulässig
 - Authentisierung des Payloads mittels HMAC
 - (optional) Schutz vor Replays



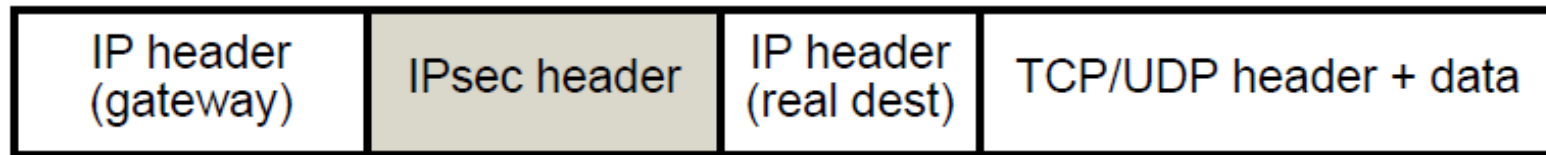
- **Durch IPsec wird ein IP-Paket verändert:**
 - zusätzliche Header
 - Verschlüsseln und/oder Hashen der Daten (Payload)

Netzwerksicherheit Techniken Verschlüsseln IPsec

- **IPsec – 2 Modi: Transport- und Tunnel-Modus**
- **Transport-Modus:** Absichern des Payloads,



- **Tunnel-Modus:** Einkapseln sowohl des IP-Headers als auch des Payloads in IPsec-Paket



- **Geschachtelte Tunnels** sind möglich, z.B. für sichere Verbindung über eine Firewall:
 - Äußerer Tunnel durch das Internet zur Firewall
 - innerer Tunnel, Verb. von Firewall zum Server sichern

Netzwerksicherheit Techniken Verschlüsseln IPsec

- **Security-Association-Datenstruktur (SA)**
 - SAs werden in den SA-DBs von A bzw. B verwaltet
 - SA enthält alle benötigten Informationen für IPsec-Verbindung zwischen zwei Rechnern A und B
 - SAs haben nur unidirektionale Gültigkeit
 - für jedes Protokoll (AH/ESP) eigene SA nötig
 - SAs vorab idR über IKE ausgehandelt und erstellt
 - SA wird beim erstmaligen Verbindungsaufbau angelegt
- **SPI:**
 - jedes IPsec Paket enthält einen Index (SPI), verweist auf einen SA-Eintrag in der SA-DB des Empf.
 - diese SA enthält die notwendigen Verarb.-info.

Netzwerksicherheit Techniken Verschlüsseln IPsec

- **Info in SA**

- IP-Adresse des Empfängers
- AH-Informationen:
 - Algorithmus, Schlüssel, Schlüssellebenszeit
- ESP-Informationen:
 - Algorithmen, Schlüssel, Initialwerte, Lebenszeiten, ...
- Lebenszeit der SA: Zeitintervall oder Bytecounter, nach dem die SA erneuert oder terminiert werden muss und Angabe, welcher dieser Aktionen auszuführen ist
- Sequenzzähler (ab IKEv2 64 Bit, vorher 32 Bit) AH, ESP
- Modus: Transport oder Tunnel
- Anti-Replay-Window, einkommende Replays erkennen
- Security-Level (z.B. für Multi-level sichere Systeme)

Netzwerksicherheit Techniken Verschlüsseln IPsec

- **Security-Policy-Database:** Pro IPsec-Rechner eine SPD:
 - SPD legt Regeln für den Umgang mit IP-Paketen fest
 - individuelle Regeln für eingehende (inbound) und
 - für ausgehende Pakete (outbound)
 - jede Regel wird über einen Selektor spezifiziert:
 - Selektor ist für ein IP-Paket anzuwenden, wenn die Einträge des IP Pakets mit Selektorfeldern matchen
 - ist Selektor anwendbar (match), dann enthält die SPD die mit dem IP-Paket durchzuführende Aktion

From	To	Protocol	Port	Policy
1.1.1.1	2.2.2.2	TCP	80	Transport ESP with 3DES

Netzwerksicherheit Techniken Verschlüsseln IPsec

- **Selektoren**, die einen SPD-Eintrag bestimmen:
 - die IP-Adresse, Adressbereiche oder Wildcard des Empfängers bzw. des Senders
 - Sender-, Empfänger-Ports, Liste von Ports oder Wildc.
 - Name: z.B. DNS-Name, X.500 Distinguished Name,
- **Unterschied** zwischen outbound/inbound Paketen:
 - bei ausgehenden Paketen werden beim Anwenden der Regel die erforderlichen SAs (AH, ESP) etabliert (IKE)
 - inbound Pakete: verwerfen, falls keine SA vorhanden
- **Aktionen**:
 - bypass: direktes Weiterleiten des Pakets
 - apply: IPsec muss angewandt werden, Verweis auf SA
 - discard: das Paket muss vernichtet werden

Netzwerksicherheit Techniken Verschlüsseln IPsec

- **Ablauf** beim Versand eines IPsec-Pakets von A nach B
 - A sucht SA für Verbindung mit B in SA-Datenbank von A
 - A verwendet die dort angegebenen Informationen: Verschlüsselung, Hashen, MAC berechnen, ...
 - Aus SA-Eintrag: SPI zum Empfangen des Pakets in SA_DB_B
 - A trägt diese SPI in IPsec-Header ein

SPD von A

From	To	Protocol	Port	Policy
1.1.1.1	2.2.2.2	TCP	80	Transport ESP with 3DES

SA-DB von A

From	To	Protocol	SPI	SA-Eintrag
1.1.1.1	2.2.2.2	ESP	10	3DES key

Netzwerksicherheit Techniken Verschlüsseln IPsec IKE

- **IKEv2** (Internet-Key-Exchange-Protokoll Version 2)
IKE ist kein integraler Bestandteil von IPsec
- **Schlüsselmanagement:**
 - Aushandeln bzw. Verteilen von Schlüsseln
- **Überblick**
 - IKEv2-Protokoll-Spezifikation: siehe RFC 5996
 - IKE ist Bestandteil von ISAKMP (Internet Security Association and Key Management Protocol)
 - IKE ist eine Ausprägung des allgemeineren Oakley-Protokolls (sehr viele Optionen, Parameter, komplex!)
 - IKE ist generisch, kann auch für andere Protokolle als IPsec verwendet werden, z.B. RIP

Netzwerksicherheit Techniken Verschlüsseln IPsec

Fazit

- Konfigurieren von IPsec-Policies ist sehr komplex
 - fehleranfällig: viele Optionen, viele Freiheitsgrade
 - ggf. Nutzung schwacher Modi, unsichere Auswahl
- Konfigurierungsvarianten führen zu Interoperabilitätsproblemen
- IKE-Pakete werden über UDP übertragen: unzuverlässig und wird von einigen Firewalls blockiert (ggf. kein Aushandeln mögl.)
- Interworking von IPsec und Firewalls ist problematisch
- Mechanismen bereits in Win XP (versteckt) vorgesehen.
- Bei korrekter Nutzung hoher Sicherheitsgrad erreichbar

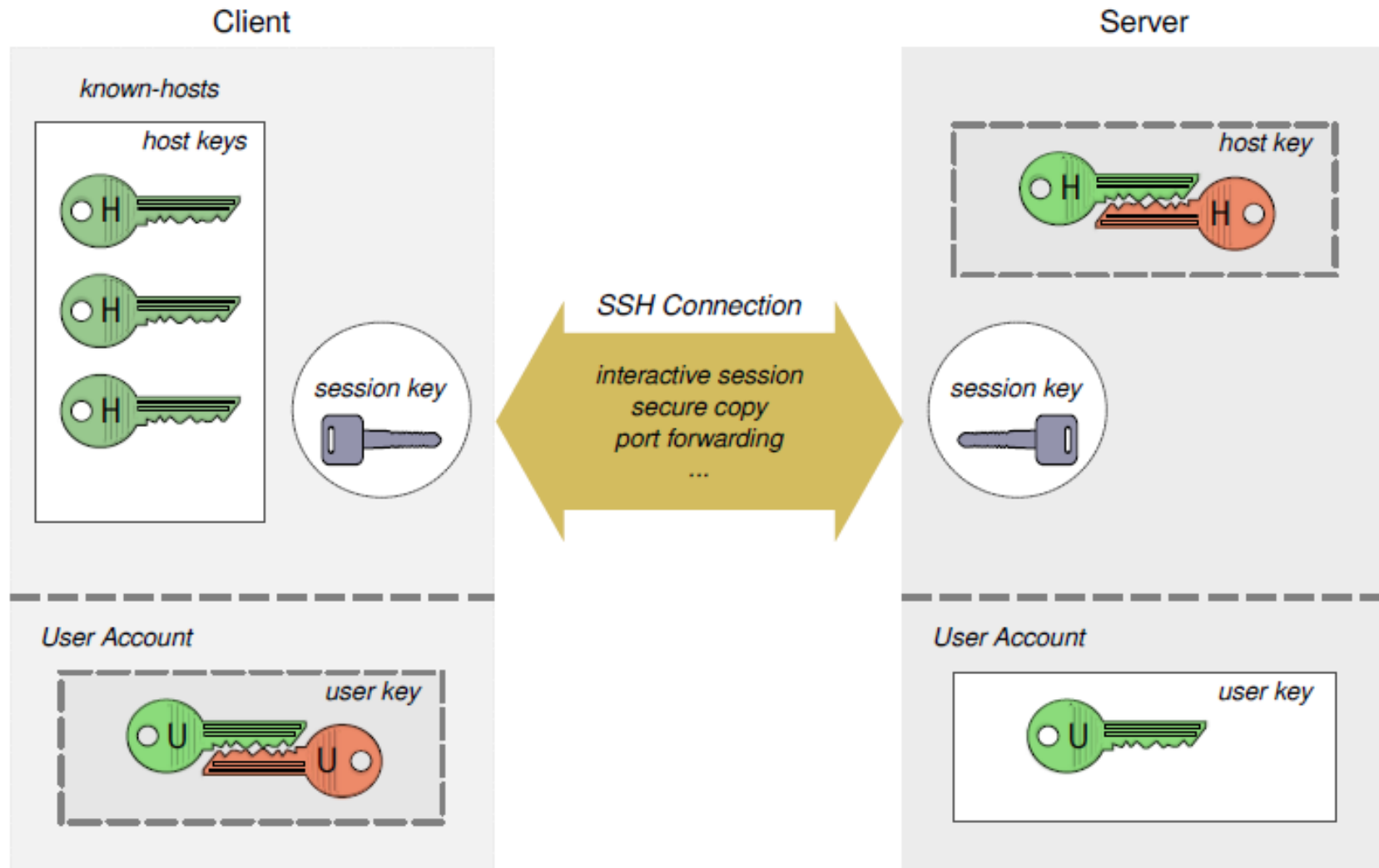
Netzwerksicherheit Techniken Verschlüsseln

- Vergleich IPsec und TLS
 - Unterschiede
 - Vorteile, Nachteile

Netzwerksicherheit Techniken Verschlüsseln SSH2

- Sicherheit in der Anwendungsschicht
 - Anwendungen
 - Sicheres remote login
 - Sichere Dienste (ftp, copy,...)
 - Sicheres port forwarding
 - Vorteile
 - Mehrere Authentifizierungsmethoden (Server: Zertifikat, Client: Zertifikat oder Kennwort)
 - Firewalls können vermieden werden.
 - Starke Verschlüsselung (z.B. AES)
 - Nachteile
 - Punkt-zu-Punkt

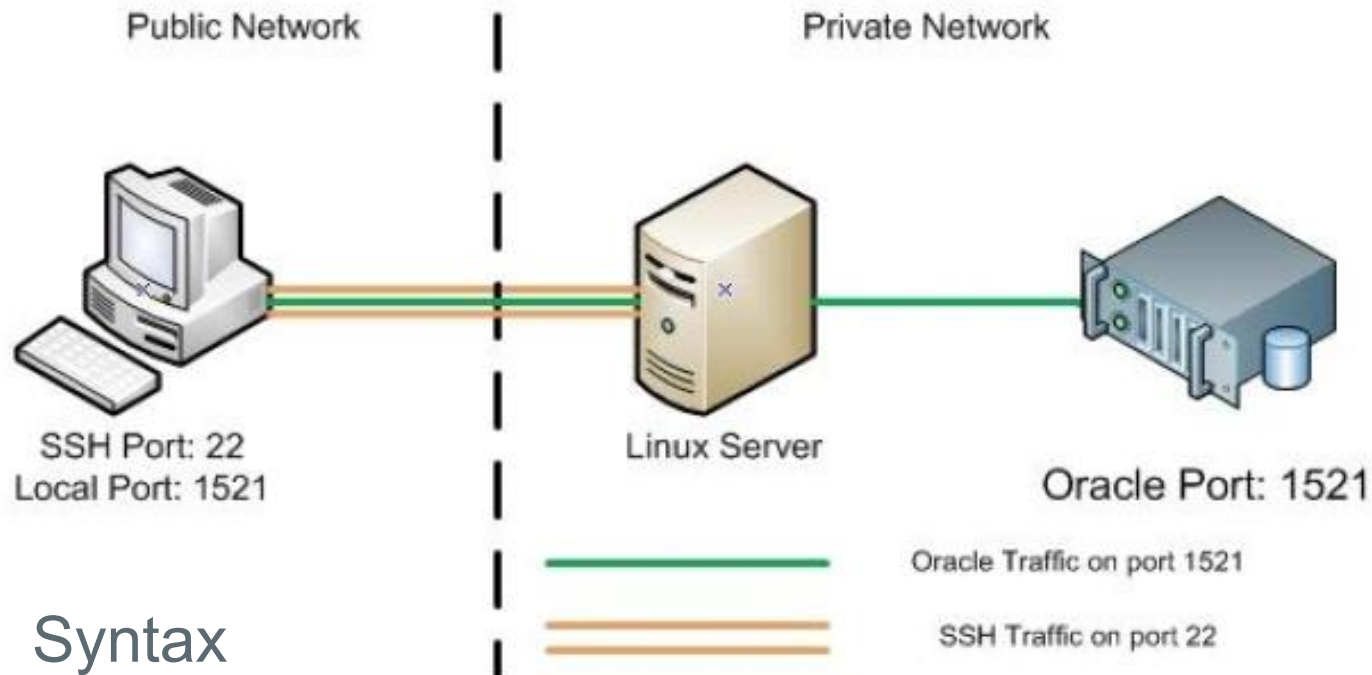
Netzwerksicherheit Techniken SSH Architektur



Netzwerksicherheit Techniken SSH Funktionalität

- Remote Login
 - Username/Password
 - Public Key
- Remote Command Execution
- Remote Copying (rcp)
- Secure ftp Service (sftp)
- Remote Synchronisation (rsync)
- Port Forwarding, Port Tunnel
- Secure File System Mount (sshfs)

Netzwerksicherheit Techniken SSH Port Forwarding



- Syntax
 - Local forwarding
 - `Ssh -L <lport>:<rhost>:<rport> user@host`
 - Remote forwarding
 - `Ssh -R <port>:<lhost>:<lport> user@host`

SSH Local Forwarding

Short form →

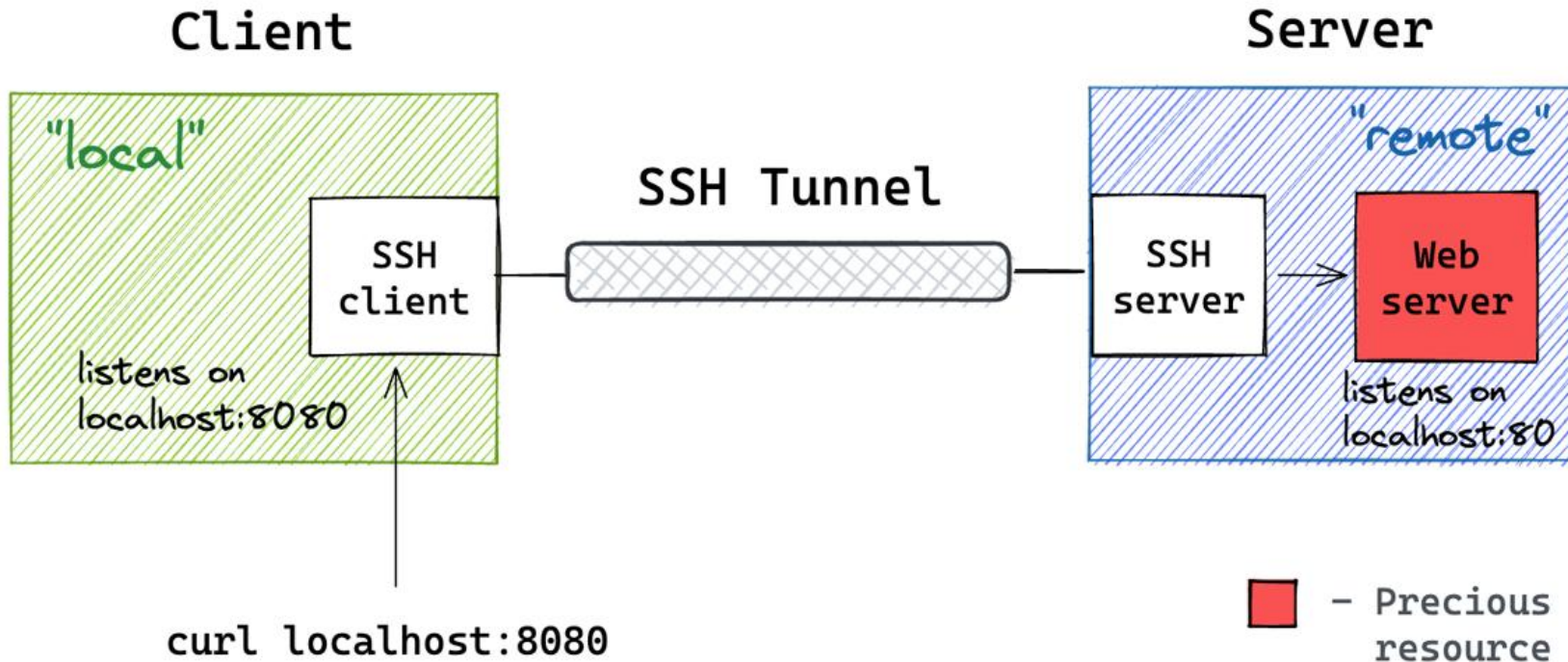
ssh -L 8080 :localhost:80 user@server

ssh -L localhost:8080:localhost:80 user@server

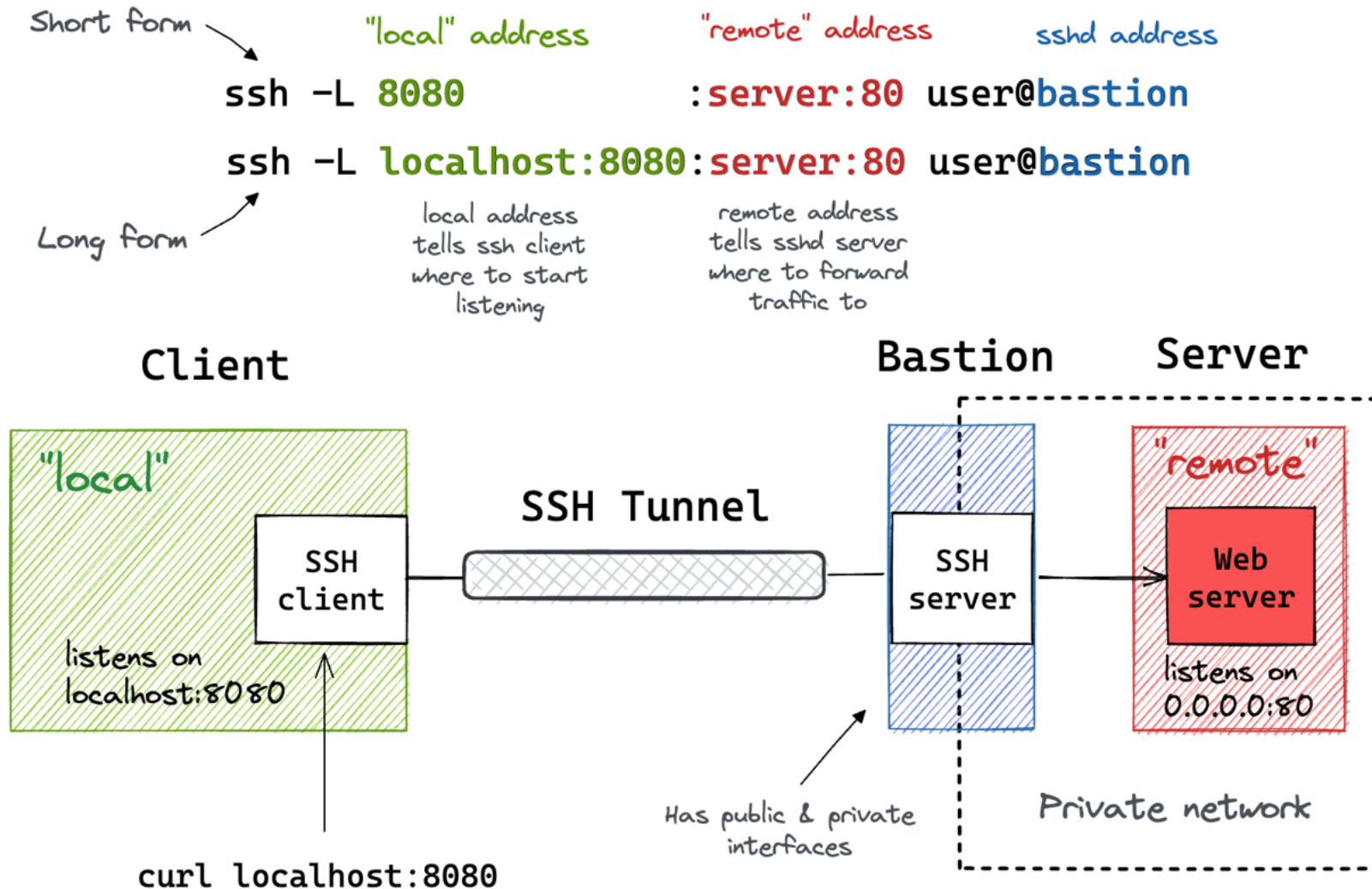
Long form →

local address tells ssh client where to start listening

remote address tells sshd server where to forward traffic to



SSH Local Forwarding



SSH Remote Forwarding

"remote" address

"local" address

sshd address

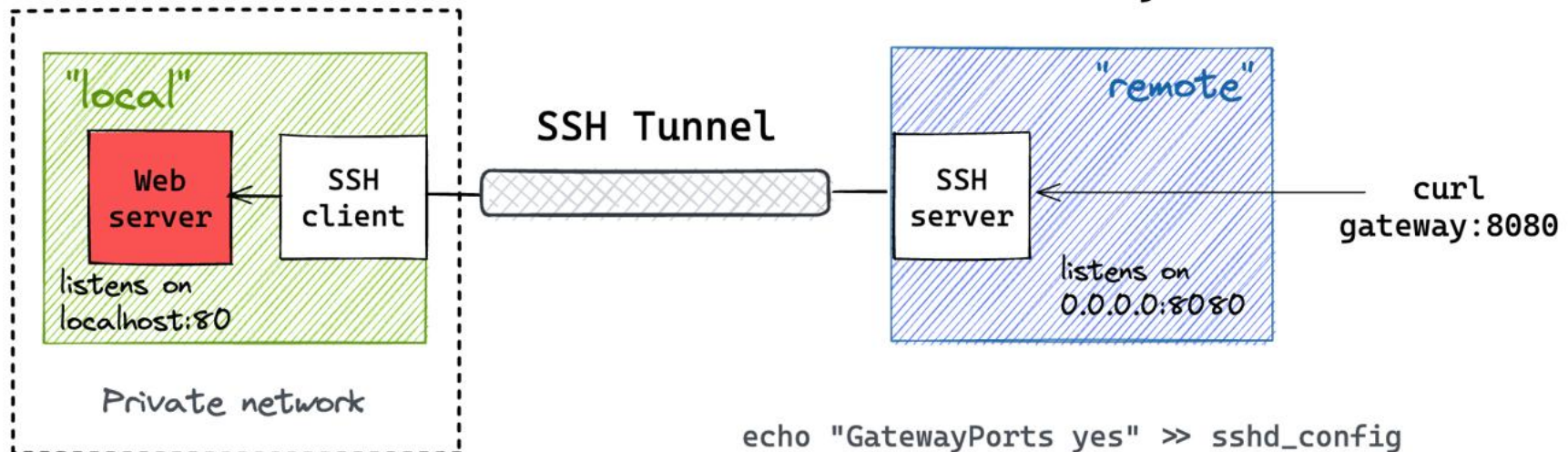
```
ssh -R 0.0.0.0:8080:localhost:80 user@gateway
```

remote address
tells sshd server
where to start
listening

local address
tells ssh client
where to forward
traffic to

Client

Gateway



■ - Precious
resource

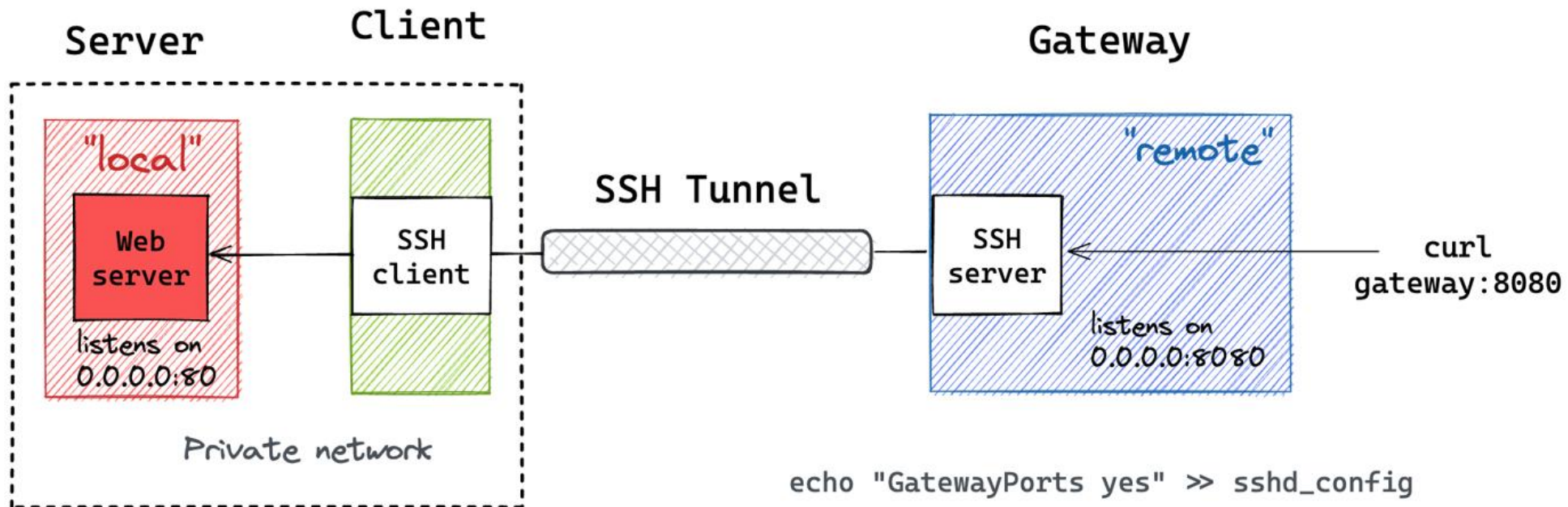
SSH Remote Forwarding

"remote" address "local" address sshd address

```
ssh -R 0.0.0.0:8080:server:80 user@gateway
```

remote address
tells sshd server
where to start
listening

local address
tells ssh client
where to forward
traffic to

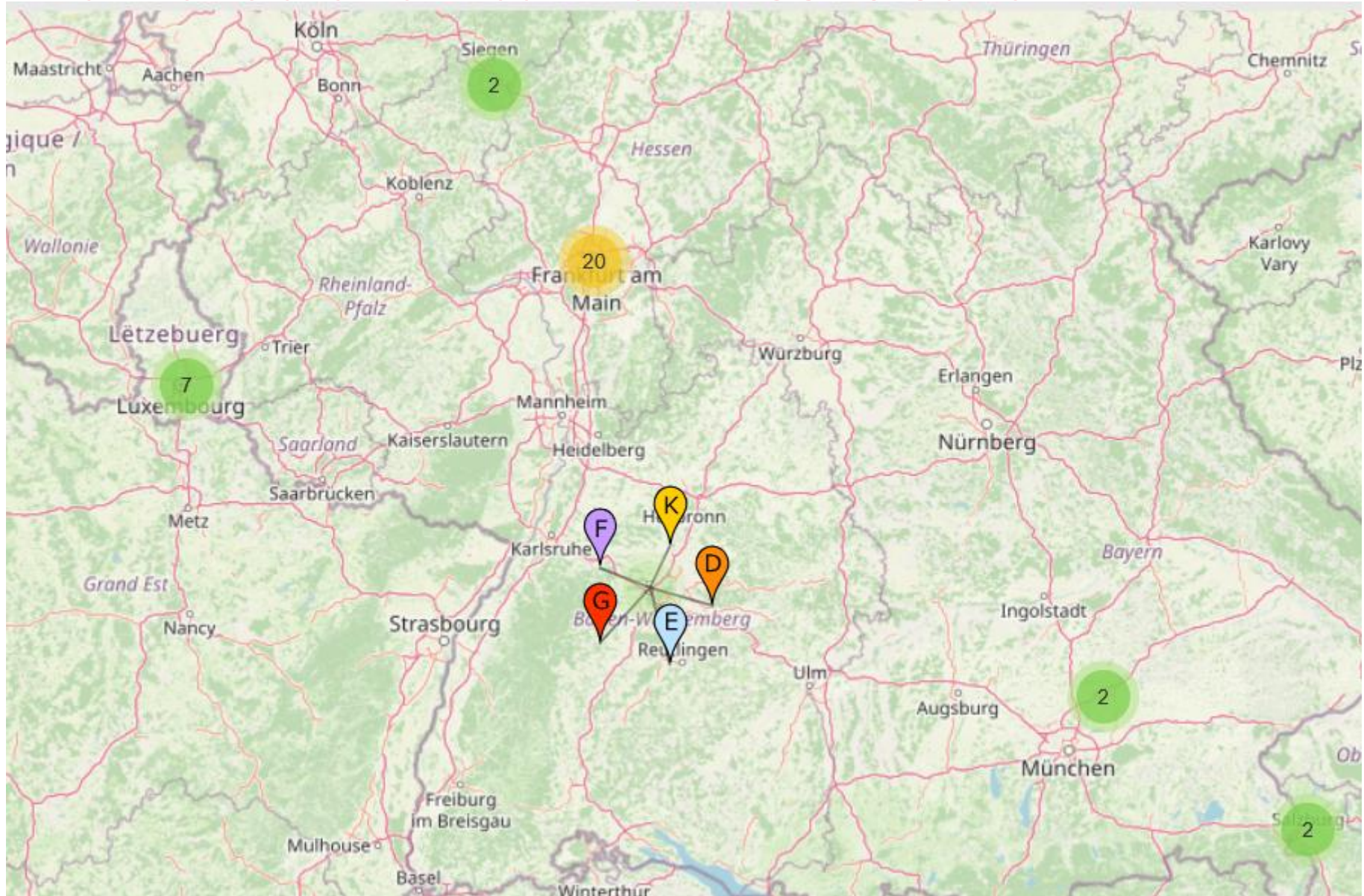


Netzwerksicherheit Techniken DNSSEC

- **DNS-Security-Extensions (DNSSEC)**
 - DNS ist einer der wichtigsten Internetdienste
 - Umsetzung von Domain-Namen in IP-Adressen anhand der Domain-Hierarchie.
 - 13 Root-Server A bis M bilden Wurzel der Hierarchie, verteilt auf derzeit >1900 physische Server weltweit

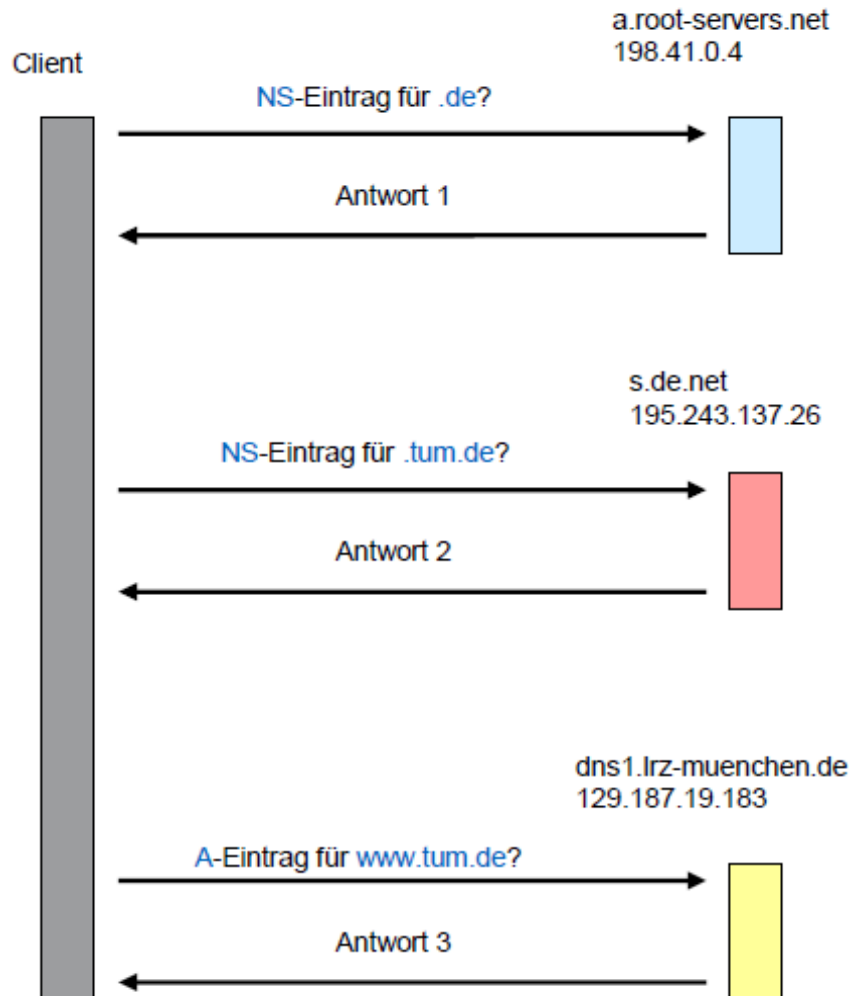


Netzwerksicherheit Techniken DNSSEC Server in DE



Netzwerksicherheit Techniken DNSSEC

- **Beispiel:** Auflösung von `www.tum.de` in IP-Adresse



Antwort 1

```
:: AUTHORITY SECTION:
de.      IN  NS  a.nic.de.
de.      IN  NS  c.de.net.
de.      IN  NS  f.nic.de.
de.      IN  NS  l.de.net.
de.      IN  NS  s.de.net.
de.      IN  NS  z.nic.de.
```

Zuständige
Nameserver

```
:: ADDITIONAL SECTION:
a.nic.de. IN  A  194.0.0.53
c.de.net. IN  A  208.48.81.43
f.nic.de. IN  A  81.91.164.5
l.de.net. IN  A  77.67.63.105
s.de.net. IN  A  195.243.137.26
z.nic.de. IN  A  194.246.96.1
```

Zugehörige
IP-Adressen

```
:: AUTHORITY SECTION:
tum.de.  IN  NS  dns1.lrz-muenchen.de.
tum.de.  IN  NS  dns3.lrz-muenchen.de.
tum.de.  IN  NS  dns2.lrz-muenchen.de.
```

```
:: ADDITIONAL SECTION:
dns1.lrz-muenchen.de. IN  A  129.187.19.183
dns2.lrz-muenchen.de. IN  A  141.40.9.211
dns3.lrz-muenchen.de. IN  A  193.136.2.123
```

```
:: ANSWER SECTION:
www.tum.de.      IN  CNAME  tum.www.ze.tu-muenchen.de.
tum.www.ze.tu-muenchen.de. IN  CNAME  tum.www.ze.tum.de.
tum.www.ze.tum.de. IN  CNAME  portal.mytum.de.
portal.mytum.de.  IN  A      129.187.39.3
```

Quelle: [Eck2018]

Netzwerksicherheit Techniken DNSSEC

- DNS Anfrage und Antworten ungeschützt!
-> DNS-Spoofing
- **DNSSEC, seit 1997 entwickelt! (RFC 4033)**
 - Etablierung einer globalen PKI entlang der Domain-Hierarchie
 - Administrator eines Nameservers signiert die DNS-Einträge in seinem Verwaltungsbereich
 - Empfänger prüft digitale Signatur der DNS-Antworten und kann so Manipulationen erkennen

Netzwerksicherheit Techniken DNSSEC

- **PKI von DNSSEC**

Pro Zone zwei Arten von Public-Key-Schlüssel-Paaren:

- Key-Signing-Key (KSK), empfohlen 2048 Bit, 2-4 Jahre gültig
 - Zone-Signing-Key (ZSK), empfohlen 512 Bit, 1-2 Monate gültig
- ZSK signiert die DNS-Einträge der eigenen Zone
- KSK signiert den Public-ZSK der eigenen Zone
- KSK der übergeordneten Zone signiert den Public-KSK der darunter liegenden Zonen
- Root-Zone selbst ist ebenfalls signiert, Schlüssel wird von VeriSign verwaltet

Netzwerksicherheit Techniken DNSSEC

- Massivste Änderung des DNS in der Geschichte des Internet
 - Root-Zone sowie einige TLDs bereits signiert, Testbetrieb von .de läuft seit 2010
 - Kann Spoofing und Poisoning-Angriffe verhindern
- DNSSEC als Security-Enabler: Globalen, hierarchischen PKI auch für andere Szenarien interessant, Beispiele?
- **Aber:** Viele Endgeräte und Router nach wie vor nicht DNSSEC-fähig, großer Nachholbedarf seitens der Gerätehersteller, z.B. <http://www.ungefiltert-surfen.de/nameserver/de.html>
- <https://blog.apnic.net/2017/12/06/dnssec-deployment-remains-low/>
- <https://rick.eng.br/dnssecstat/>
 - 2022 91% in TLD, aber nur 6% der 2LD, 30% der User
 - 2025 93% in TLD, 7% 2LD, 35% User

Referenzen

- [SCH200x] Schiller, Jochen; Mobilkommunikation; Pearson Studium, 200x, leider vergriffen
- [Les2002] Lescuyer, Pierre; UMTS: Grundlagen, Architektur und Standard, dpunkt, 2002
- [Eck2018] Eckert, Claudia; IT-Sicherheit; deGruyter, 2018, 10. Auflage
- [Eck2023] Eckert, Claudia; IT-Sicherheit; deGruyter, 2023, 11. Auflage

IT-Sicherheit Firewalls

Prof. Dr. Johannes Freudenmann (DHBW Karlsruhe)
Masterprogramm Informatik

www.dhbw.de

Netzwerksicherheit Techniken Firewall

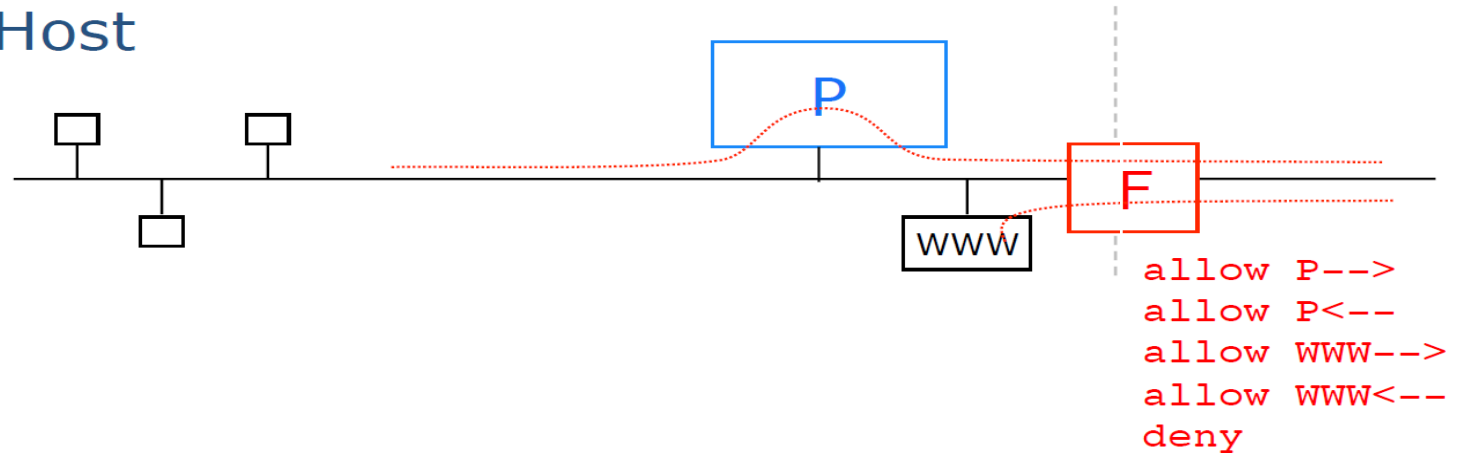
- Sichert den Zugang zu meinem Netz ab. Lässt grundsätzlich von außen (und innen) nur autorisierten/berechtigten Zugriff zu.
- Alle Datenpakete passieren die Firewall
 - Kein 2. Internet-Anschluss!!
 - Problem mobiles Internet/WLAN
- Verschiedene Konfigurationen
 - Struktur
 - Funktion

Netzwerksicherheit Techniken Firewall II

- Verschiedene Konfigurationen - Struktur
 - Lokale Firewall – Zwiebelschalenmodell
 - Einfache Firewall (Screened Host)
 - Firewall mit DMZ (3 Ports)
 - Doppelte Firewall mit DMZ (Screened Subnet)
 - Bastion Host
- Konfiguration – Funktion
 - Paketfilter (transparent)
 - Mit/ohne NAT (interne Struktur verbergen)
 - Proxy-Firewall, Circuit-level (für Anwender transparent)
 - SOCKS-Proxy (Interne Struktur verborgen)
 - Application Level
 - www-Proxy, Spezielle Dienste (interne Struktur verborgen)

Netzwerksicherheit Techniken Firewall Struktur

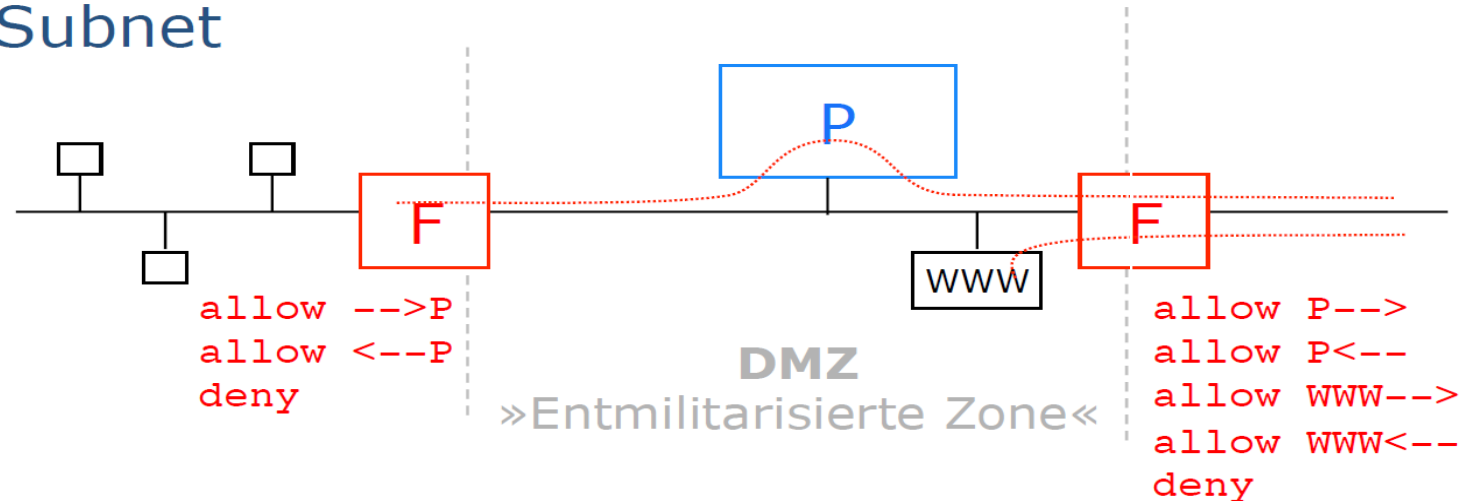
Screened Host



- Einfache Konstruktion.
- Weit verbreitet
- Kein Schutz, falls Server P oder WWW kompromittiert wird.

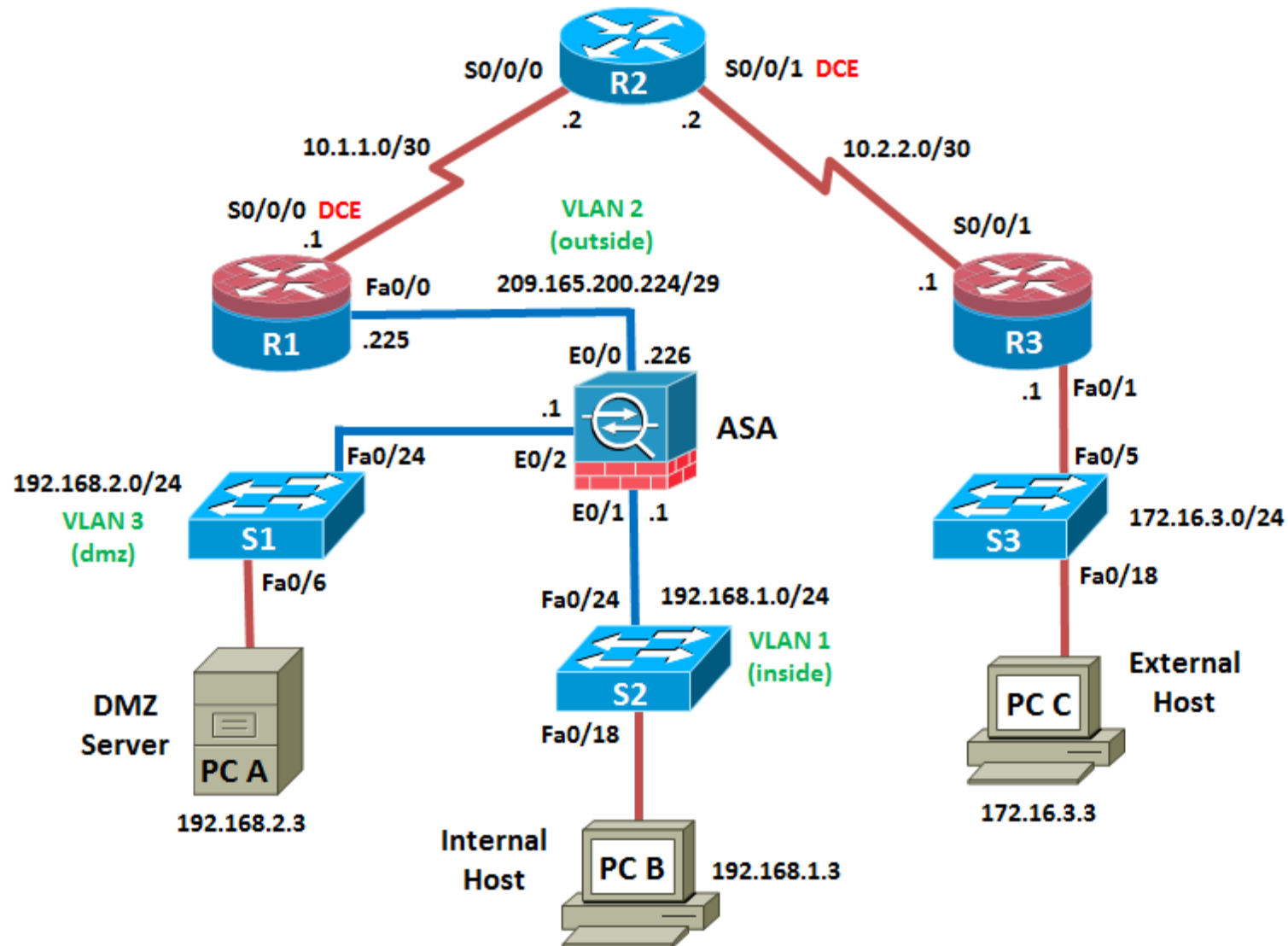
Netzwerksicherheit Techniken Firewall Struktur II

Screened Subnet



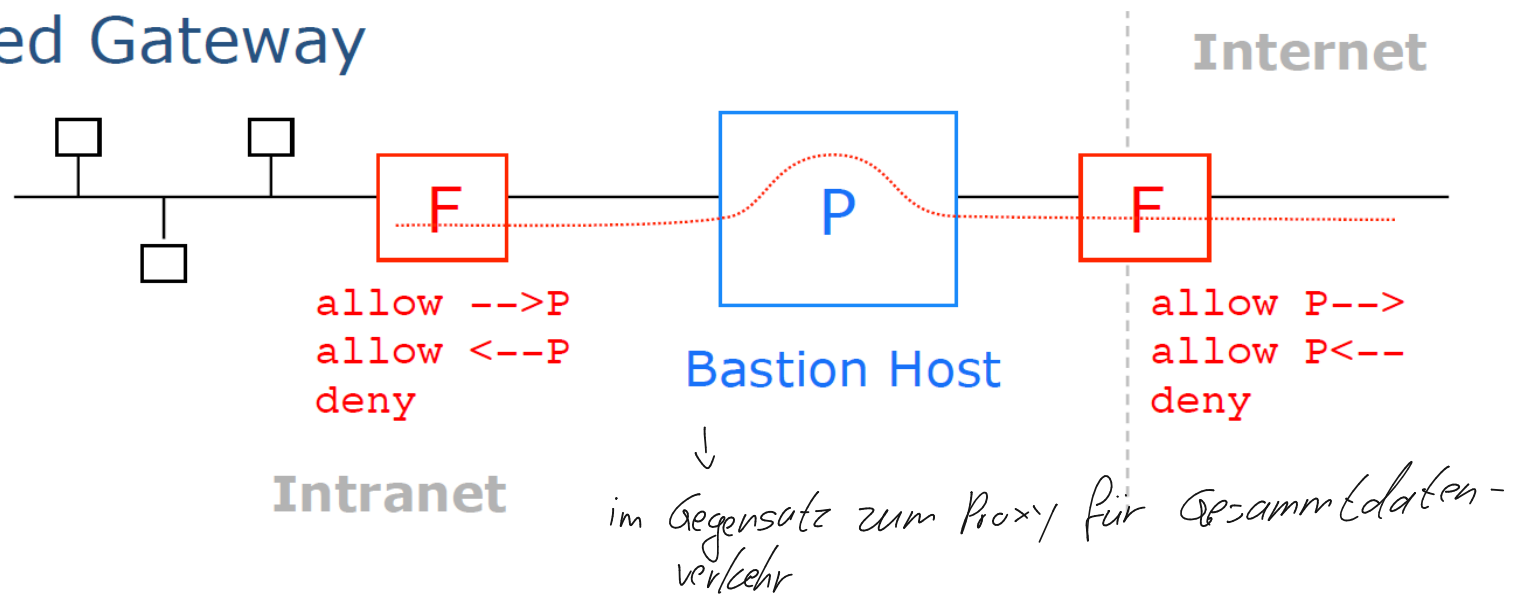
- Standard,
- teilweise auch mit einer Firewall und drei Anschluss Ports realisiert.
- Flexibel bei der Definition der zulässigen Kommunikationsbeziehungen

Netzwerksicherheit Techniken Firewall Vorschlag Cisco



Netzwerksicherheit Techniken Firewall Struktur III

Dual Homed Gateway



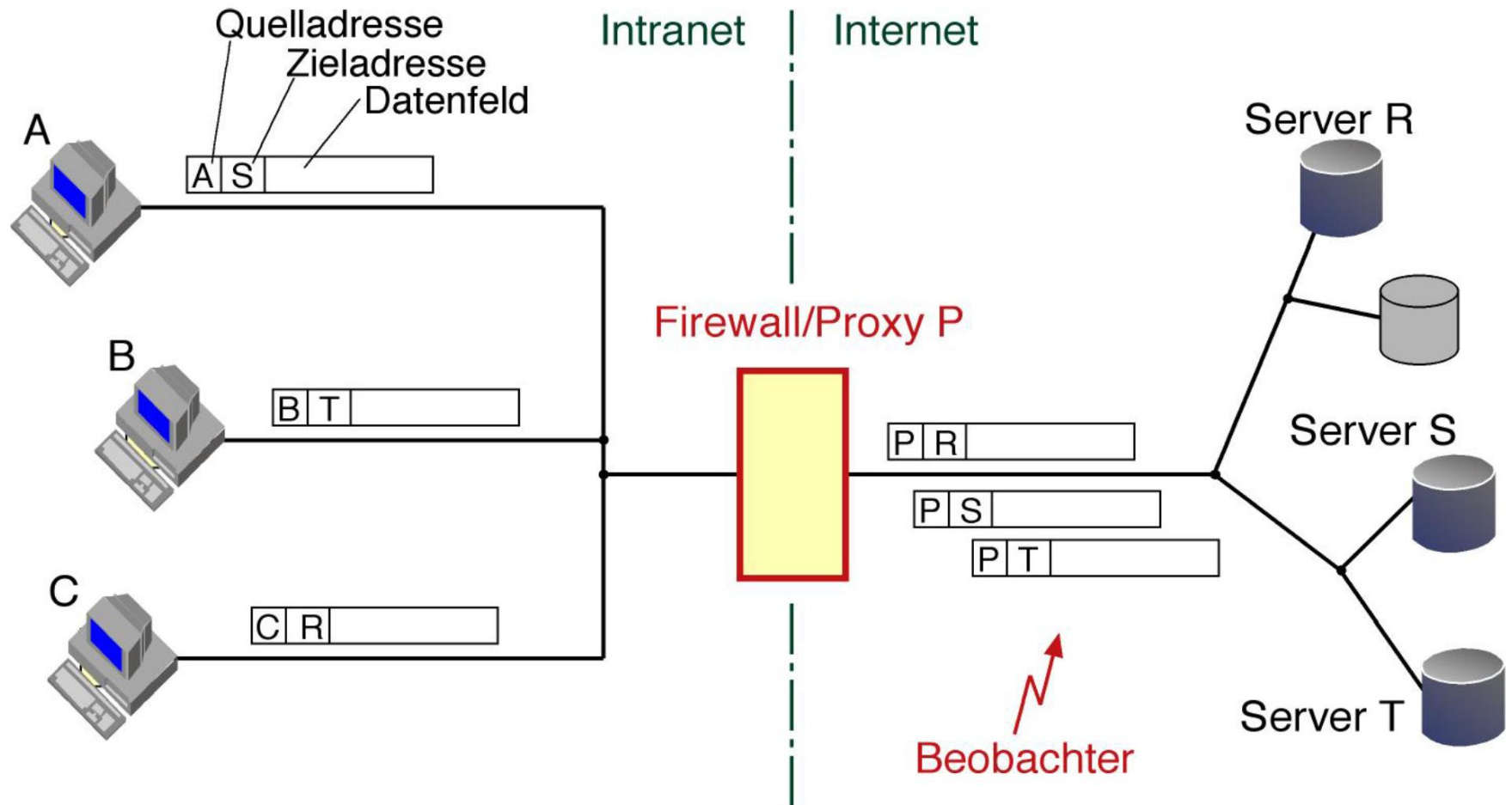
- Sehr sicher, aber unflexibel.
- Teilweise auch ohne Paketfilter (F).
- Keine direkte Kommunikation zwischen innen und außen.

Netzwerksicherheit Techniken Firewall Funktion

- Standard Paketfilter
 - ACL – Access Control List
 - Zugeordnet an bestimmte Schnittstelle inbound/outbound (Router)
 - Ziel-IP-Adresse filtern, Quell-IP filtern
 - Z.B. Permit 10.1.1.0 0.0.0.255
 - Quell-IP/Ziel-IP-Adresse filtern
 - Permit ip any 10.1.1.0 0.0.0.255
 - Ports mit berücksichtigen
 - Permit tcp host 10.1.1.0 host 172.16.1.1 eq telnet
 - Statisch filtern/Dynamisch filtern (TCP-Verbindungen)
 - Spezifische Beziehungen bei Mediendaten filtern
 - Alternativ: Beschreibung der zulässigen Kommunikationsbeziehungen in der Firewall.

Netzwerksicherheit Techniken Proxy-Firewall

- Schutz vor Beobachtung im Internet



Netzwerksicherheit Techniken Firewall WWW-Proxy

- Aufgaben
 - Interne Struktur verbergen
(nur eine Adresse außen sichtbar)
 - WWW-Cache: Häufig aufgerufene Seiten sind sofort verfügbar
 - Weniger Datenverkehr auf (teurem) Internet-Anschluss
 - WWW-Malware-Filter an einer Stelle
 - Einfache Möglichkeit Seiten zu sperren ☹️
 - Einfache Möglichkeit alle Seitenabrufe zu protokollieren ☹️

Netzwerksicherheit Techniken Firewall SOCKetSecure-Proxy

- Ablauf: Authentifizierung, Verbindungsanfrage, Datenaustausch

VER	NMETHODS	METHODS
1	1	1 to 255

VER wird auf die Version, also 0x05, gesetzt.

NMETHODS gibt die Anzahl der vorgeschlagenen Authentifizierungsmethoden an.

METHODS sind dann schließlich die vorgeschlagenen Authentifizierungsmethoden. Es gibt folgende Möglichkeiten:

Byte	Bedeutung	Erklärung
0x00	NO AUTHENTICATION REQUIRED	Keine Authentifizierung benötigt
0x01	GSSAPI	GSSAPI, siehe RFC 2743 . Genutzt u. a. von Kerberos .
0x02	USERNAME/PASSWORD	Authentifizierung mit Benutzername und Passwort
0x03 bis 0x7F	IANA ASSIGNED	Werden von der IANA vergeben
0x80 bis 0xFE	RESERVED FOR PRIVATE METHODS	Für nicht öffentliche Methoden reserviert
0xFF	NO ACCEPTABLE METHODS	Keine akzeptable Methode

Netzwerksicherheit Techniken Firewall SOCKS-Proxy II

- Verbindungsanfrage

VER	CMD	RSV	ATYP	DST.ADDR	DST.PORT
1	1	X'00'	1	Variable	2

- VERsion = 0x05,
- CoManD: 1 = TCP aktiv, 2 = TCP passiv; 3 = UDP
- AdresSTYP: 1 = IPv4; 3 = DNS; 4 = IPv6

- Server-Antwort REPlY statt CMD

- REPlY: 1 = succeeded; 4 = Host unreachable;
diverse weitere Fehler

Netzwerksicherheit Techniken Firewall Abschluss

- Wie gut kann man sich hinter einer Firewall verstecken?
 - # Hosts erkennbar?
 - Best-Practice-Ansatz
 - Je länger im Einsatz, desto mehr Ports geöffnet.
 - Kein Schutz vor internen Angriffen
 - Trojaner können Firewall dadurch umgehen, dass sie einen offenen Port (z.B. 80, www) nutzen
 - Tradeoff : Sicherheit <-> Bequemlichkeit
 - Teamviewer
 - ???
 - Eigene Erfahrungen?

IT-Sicherheit Tools

Prof. Dr. Johannes Freudenmann (DHBW Karlsruhe)
Masterprogramm Informatik

www.dhbw.de

Werkzeuge

- Wireshark – Alle Daten mitschneiden und interpretieren.
- (NMAP – Scan aller offenen Ports
Diverse Scans auf Schwachstellen)
- Nessus -> OpenVAS – Scans auf Schwachstellen im Netz
- BackTrack -> KALI
 - Sammlung von Werkzeugen
- SNORT – IDS IPS.
- Sonstige Tools
 - Cain&Abel – Sniffer,
 - Passwort-Recovery (Caches, ...)
 - ARP-Spoofing

Werkzeuge Wireshark

- Bereits vorne

Werkzeuge NMap

- NMAP – Scan aller offenen Ports
Scans auf viele Schwachstellen
- Festlegen Ziel, Profil
 - Ziel eigener Rechner 127.0.0.1
 - Ziel eigenes Netz 192.168.1.0 255.255.255.0
 - Profile vordefiniert.
 - Eigene Profile erstellen, die Scans und Skripte umfassen
 - Vielzahl von Skripten zum Test von konkreten Situationen, Verwundbarkeiten,..
 - Skriptsprache LUA (portugiesisch Mond)

Werkzeuge Nessus/OpenVAS/Greenbone

- NESSUS, 2005 unter proprietäre Lizenz gestellt.
 - 2014 5.2 55.000 Schwachstellen untersucht.
 - u.a. auch Compliance-Checks
- Alternative weiterentwickelt unter GPL – OPENVAS (Open Vulnerability Assessment System)
 - Integriert u.a. auch Nmap
 - Läuft auf Unix, Bedienung über Web-Interface
 - Konfiguration über CERT-Feed
 - Hinweise auf CVEs
- Seit 2017 Teil des Greenbone Vulnerability Management
 - Online Demo oder Foliensatz
 - <https://www.greenbone.net/jetzttesten/> (VM für VMWare oder VirtualBox)
 - 25.0.1 Version Stand 7.6.2026

Werkzeuge (Backtrack) KALI

- Basis LINUX – als Virtuelle Maschine vorkonfiguriert.
- Penetration Testing, Security Research, Computer Forensics and Reverse Engineering
- Applications – Kali Linux:
 - Wireshark
 - NMAP
 - John, Ophcrack, rainbowcrack – password-attack
 - Aircrack, Kismet – WLAN
 - Metasploit, Snort, Scapy
 - und viele andere
- Webseite: www.kali.org
VMWare: <http://www.offensive-security.com/kali-linux-vmware-arm-image-download/>

Sicherheitsmaßnahmen

- Organisatorisch
 - Struktur
 - Segmente, Switching, Broadcasts, VLAN
 - NAT, DMZ, Bastion Host, Firewall
 - Lokal: Firewall, Virens Scanner für Files und Web.
 - Kontrollen
- Verschlüsselung/Authentifizierung
 - Leitung
 - IPSec
 - TLS, SSH
- Erkennung/Verfolgung
 - Tools <https://sectools.org> (nicht mehr aktuell ?)
 - Forum/Listen <https://seclists.org/>
 - IDS/IPS Snort

IT-Sicherheit

Prof. Dr. Johannes Freudenmann (DHBW Karlsruhe)
Masterprogramm Informatik

www.dhbw.de

Überblick

- Vorstellung der Vulnerabilities (<https://nvd.nist.gov/general/nvd-dashboard>, CVEs, s. Kollege Straub)
- Sicherheitsmechanismen in Betriebssystemen
 - Passworte (Ergänzung rainbowtables), ACL
- System Hardening (Empfehlungen)
 - CIS Security Benchmarks
 - NIST CCE (analog zu CVE, aber nicht zeitnah gepflegt)
- Security Engineering (Eckert Kap. 4) -> Straub
 - Überblick, Bedrohung STRIDE, Risiko DREAD
- Bewertung der IT-Sicherheit (Eckert Kap. 5)
 - CC – Common Criteria ISO 15408 TUM 7/22-34
- Überprüfung der Sicherheit – Penetration Testing
 - OpenVAS

CIS Company

- CIS – Center for Internet Security (www.cisecurity.org/)
nonprofit organization focused on enhancing the cyber security
- CIS Security Benchmarks Division
cost-effective, internationally recognized solutions
to improve cyber security
 - Members: Commercial; Government; Academic
Siemens, O2, SWIFT, Berkeley, NASA, NIST, HP, IBM, Symantec...
 - CIS Benchmarks: best practice secure configuration
 - globally used, de facto user-originated standard
 - freely available for download in PDF format.
 - Security Metrics: eigenen Status messen
 - CIS-CAT Security Assessment Tool
Übereinstimmung mit Benchmarks prüfen

CIS Benchmarks

- Diverse Betriebssysteme und Anwendungen
 - Apple iOS/OSX, Windows, Linux, Android, VMWare, Xen
 - Checkpoint, Cisco
 - Kerberos, Radius
 - Opera, Firefox, IE
 - MySQL, DB2, Oracle
 - IIS, Apache
 - Cloud Provider
 - ...

CIS Benchmarks

- Scoring Information

A scoring status indicates whether compliance with the given recommendation impacts the assessed target's benchmark score.

- Scored

Failure to comply with "Scored" recommendations will decrease the final benchmark score. Compliance with "Scored" recommendations will increase the final benchmark score.

- Not Scored

Failure to comply with "Not Scored" recommendations will not decrease the final benchmark score. Compliance with "Not Scored" recommendations will not increase the final benchmark score.

CIS Security Profiles

Profile Definitions

- Level 1

Items in this profile intend to:

- be practical and prudent;
- provide a clear security benefit; and
- not inhibit the utility of the technology beyond acceptable means.

- Level 2

This profile extends the "Level 1" profile. Items in this profile exhibit one or more of the following characteristics:

- are intended for environments or use cases where security is paramount
- acts as defense in depth measure
- may negatively inhibit the utility or performance of the technology

CIS Benchmark Bsp. Windows 10

- *1.1.4 (L1) Ensure 'Minimum password length' is set to '14 or more character(s)' (Scored)*
- **Profile Applicability:**
Level 1 (L1) - Corporate/Enterprise Environment
- **Description:** This policy setting determines the least number of characters that make up a password for a user account. There are many different theories about how to determine the best password length for an organization, but perhaps "pass phrase" is a better term than "password." In Microsoft Windows 2000 and newer, pass phrases can be quite long and can include spaces. Therefore, a phrase such as "I want to drink a \$5 milkshake" is a valid pass phrase; it is a considerably stronger password than an 8 or 10 character string of random numbers and letters, and yet is easier to remember. Users must be educated about the proper selection and maintenance of passwords, especially with regard to password length. The recommended state for this setting is: **14 or more character(s)**

CIS Benchmark Bsp. Windows 10

- **Rationale:**

Types of password attacks include dictionary attacks (which attempt to use common words and phrases) and brute force attacks (which try every possible combination of characters). Also, attackers sometimes try to obtain the account database so they can use tools to discover the accounts and passwords.

- **Audit:**

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

- **Remediation:**

To establish the recommended configuration via GP, set the following UI path to 14 or more character(s):

CIS Benchmark Bsp. Windows 10

- **Impact:** Requirements for extremely long passwords can actually decrease the security of an organization, because users might leave the information in an insecure location or lose it. If very long passwords are required, mistyped passwords could cause account lockouts and increase the volume of help desk calls. If your organization has issues with forgotten passwords due to password length requirements, consider teaching your users about passphrases, which are often easier to remember and, due to the larger number of character combinations, much harder to discover.
- **Note:** Older versions of Windows such as Windows 98 and Windows NT 4.0 do not support passwords that are longer than 14 characters. Computers that run these older operating systems are unable to authenticate with computers or domains that use accounts that require long passwords.
- **Default Value:** 7 characters on domain members. 0 characters on stand-alone workstations.
- **References:** 1. CCE-33789-9

CIS Benchmark

- Aktuelle Beispiele
 - Windows 11
 - Docker
 - Apache Tomcat
 - Apple iOS 26
 - Google Android

CCE Common Configuration Enumeration

- Erstellt von MITRE (Wurzel: MIT Research, heute US-weit)
- Seit 30 Mai 2013 bei US-NIST
 - **<https://nvd.nist.gov/config/cce/index>**.
- Format: Excel und XML.
- Aktuell Version 5, 2/2013, 4/2021, 7/2022 und 12/2025
- Server und Clients
 - Apache, Exchange, Windows Server, IIS
 - MS Office, Windows
 - Letzter Update iOS, macOS
- Beispiel Apache httpd 2.2, 176 Einträge.
- Wird von NIST wohl nicht sehr gut gepflegt.

- Bewertung der IT-Sicherheit

Bewertung der IT-Sicherheit

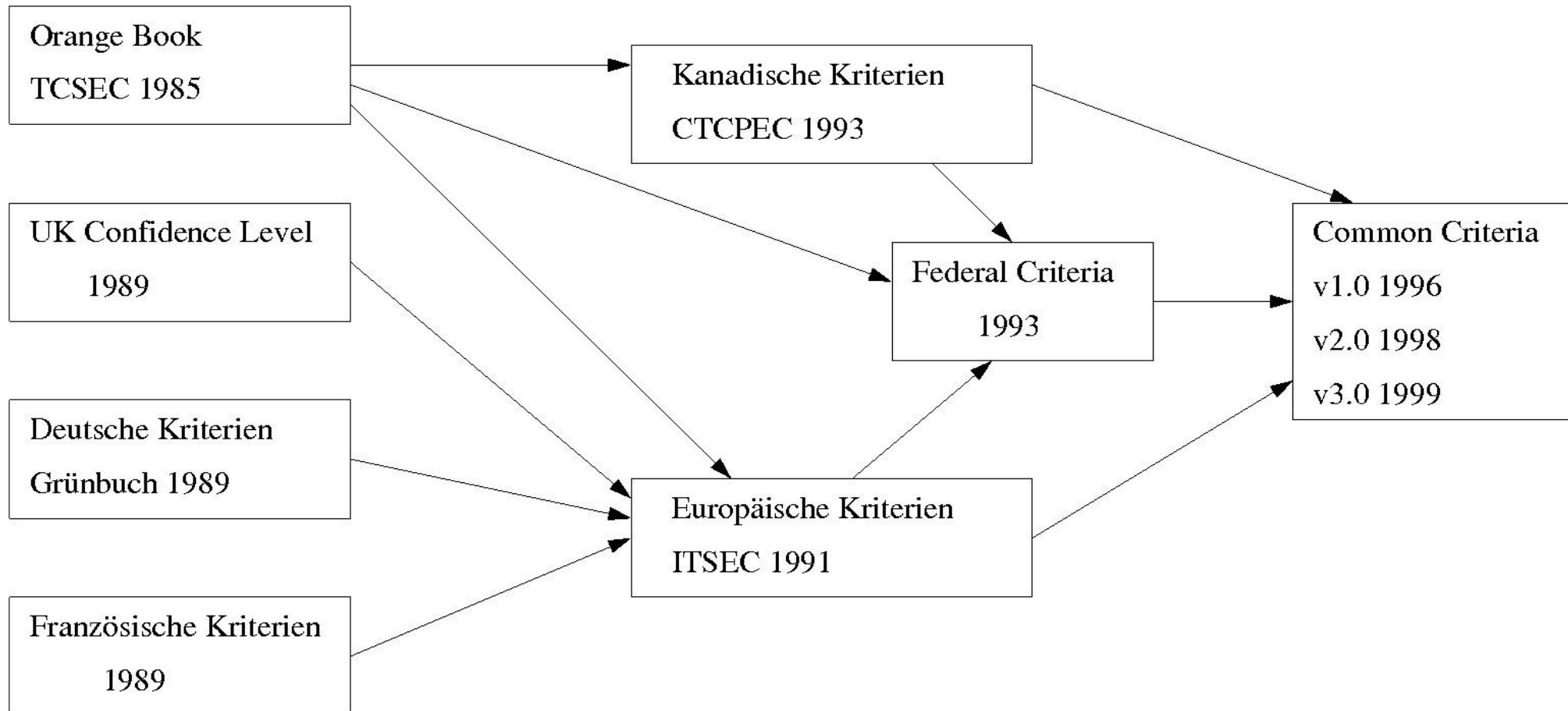
Ziele: Einheitliche Bewertungskataloge, Vergleichbarkeit

- Maßnahmenkatalog: Menge von Sicherheitsgrundfunktionen
- Qualität (der Realisierung):
z.B. getestet, ..., formal verifiziert
- Güte (der verwendeten Mechanismen):
ungeeignet, ..., unüberwindbar
- Bewertung durch unabhängige Stelle:
Evaluation und Zertifizierung, Beispiele für Zert.-Instanzen?
- Leitlinien für Hersteller bzw. Entwickler:
worauf ist zu achten
- Leitlinien für Anwender bei Produktwahl:
Vergleichbarkeit, ...

Bewertung der IT-Sicherheit Entwicklung

- Trusted Computer System Evaluation Criteria (Orange Book)
 - 1980 entwickelt
 - 4 Sicherheitsstufen (Hierarchie): (D < C1 < ... < B3 < A1)
 - fehlende Trennung zwischen Funktion und Qualität
- Deutsche IT-Kriterien (Grünbuch): 1989
 - Bewertung der eingesetzten Mechanismen: ungeeignet, schwach, mittel, stark, sehr stark, unüberwindbar
 - Funktionsklassen F1–F10
 - Qualitätsstufen Q0–Q7 (unzureichend - formal verifiziert)
- Europäische ITSEC-Kriterien
- Internationale Common Criteria (CC) for Information Technology Security Evaluation: seit 1996
(<https://www.commoncriteriaportal.org/>)

Bewertung der IT-Sicherheit Überblick



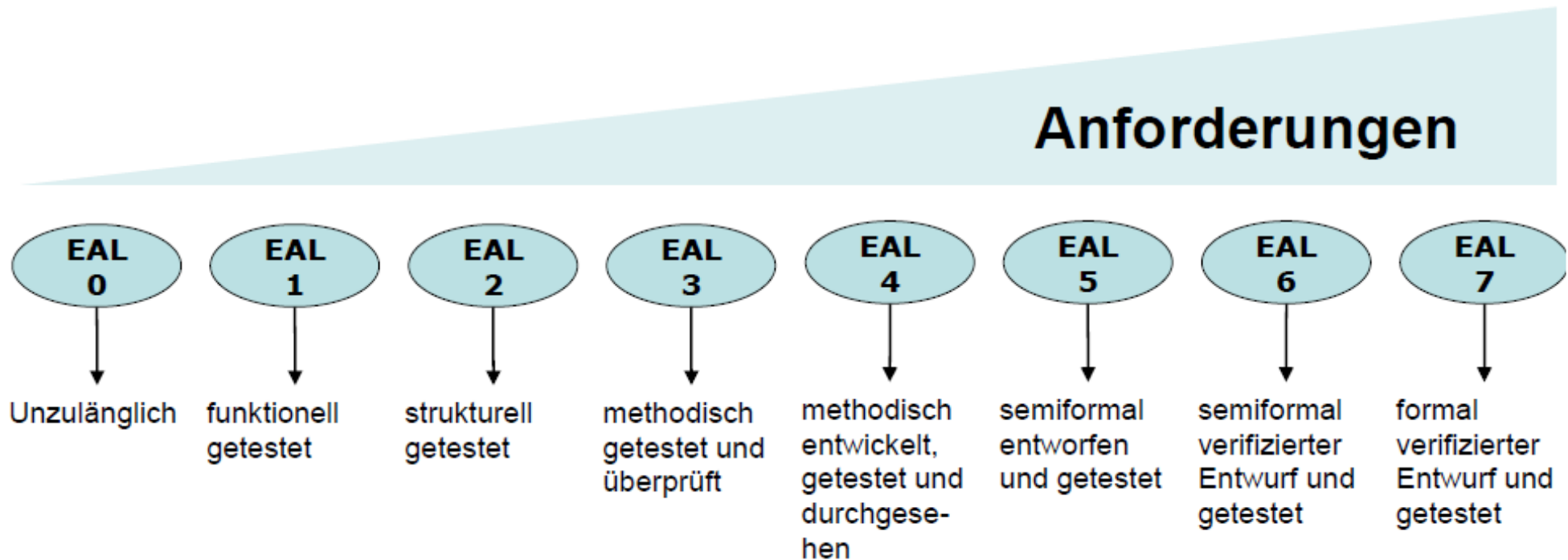
Bewertung der IT-Sicherheit: Common Criteria

- Target of Evaluation (TOE): IT-Produkt oder -System und die zugehörige Begleitdokumentation, die zu evaluieren sind. auf deutsch: **EVG: Evaluationsgegenstand**
- Security Target (ST): Menge von **Sicherheitsanforderungen**, die Grundlage der Evaluation eines TOE sind.
- Protection **Profile** (PP): Implementierungsunabhängige Menge von Sicherheitsanforderungen eines TOE.
- TOE Security Policy (TSP): **Regelwerk**, beschreibt, wie ein Asset im TOE verwaltet, geschützt und verteilt wird.
- TOE Security Function (TSF): Hardware, Software u. Firmware, die zur **Durchsetzung** der TSP benötigt werden.
- Evaluation Assurance Level (**EAL**): **Evaluationsstufe**

Bewertung der IT-Sicherheit: Common Criteria EAL

8 Evaluationsklassen EAL (Evaluation Assurance Level)

- **Beispiel:** RFID-Chip in nPA: EAL5 hoch zertifiziert



Bewertung der IT-Sicherheit: CC Funktionsklassen

- Funktionale Sicherheitsanforderungen sind strukturiert
- 11 Funktionsklassen mit funktionellen Familien
- Familien enthalten Komponenten
- Komponenten bestehen aus Elementen
- Beispiel: Klasse FIA - Identification and authentication
 - Enthält u.a. user authentication family (FIA_UAU)
 - FIA_UAU enthält u.a. Komponente Fälschungssichere Authentifizierung (FIA_UAU.3)
 - Element FIA_UAU.3.2 verhindert die Nutzung von kopierten Authentifizierungsdaten.

Bewertung der IT-Sicherheit: CC Funktionsklassen

- Komponente/Element einer Klasse definiert konkrete Anforderungen: z.B. Identifikation, Zugriffskontrolle, Beweissicherung
- Sicherheitsanforderungen spiegeln Best-Practice wider
- empfohlen zur Beschreibung der Funktionalität von Produkten bzw. Systemen
- **Klasse FIA:** Identification and authentication
- **Klasse FAU:** Security Audit:
Protokollieren und Analysieren sicherheitsrelevanter Events
- Weitere Klassen

Bewertung: CC Schutzprofile PP

Schutzprofile (Protection Profiles) -> PP

- anerkannte Lösung für Standard-Sicherheitsprobleme einer Produktgruppe, z.B. derzeit PP für Smart Meter
- implementierungsunabhängig,
- Verallgemeinerung der CC-Sicherheitsvorgaben
- PPs beschreiben ein Sicherheitskonzept

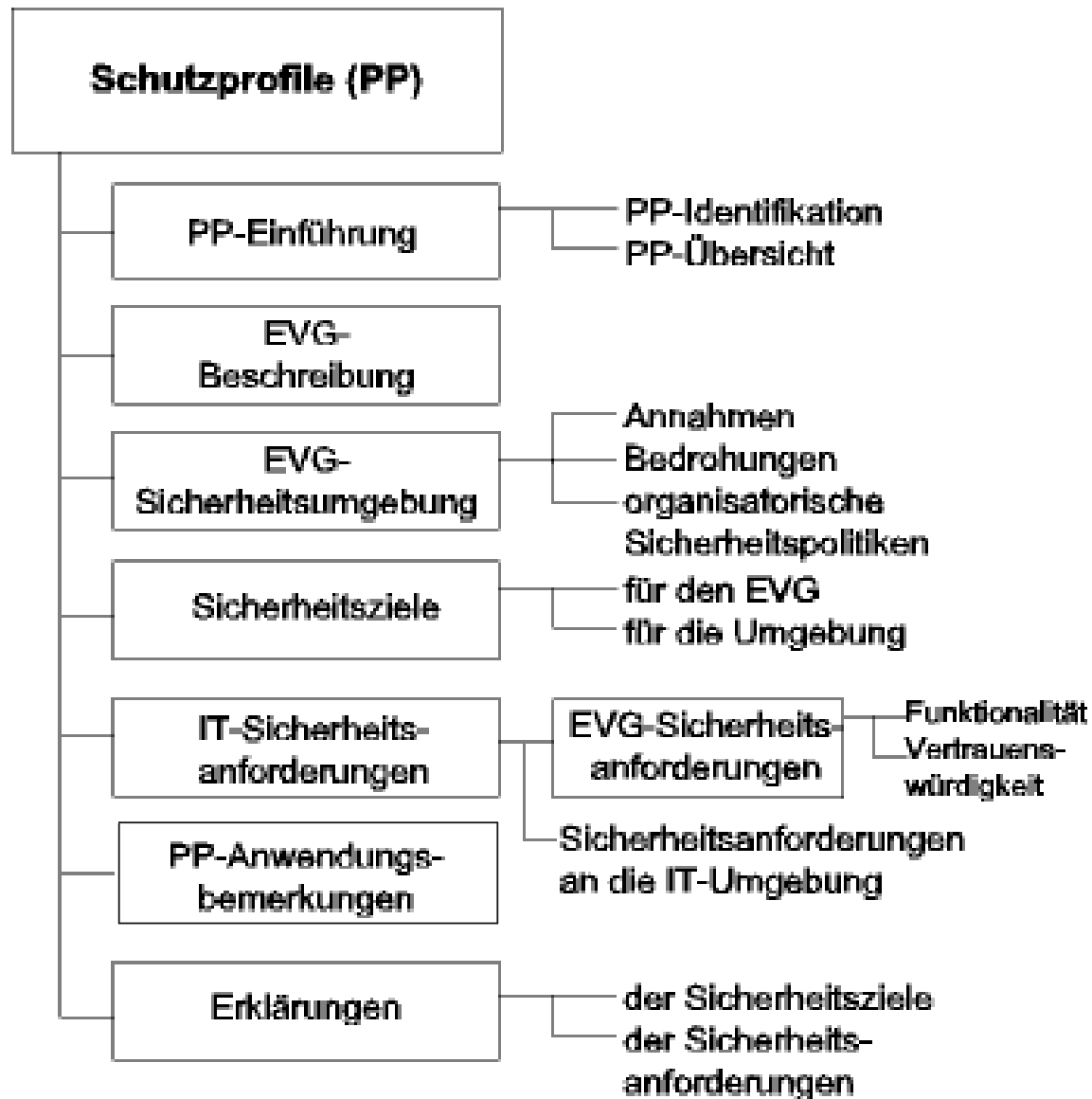
Anwender-Sicht:

- gute Vergleichbarkeit verschiedener Produkte, die auf Basis des Schutzprofils entwickelt und evaluiert wurden

IT-Hersteller-Sicht:

- erfolgreiche Evaluierung eines Schutzprofils bescheinigt, dass das PP ein sinnvolles, im Markt gewünschtes Konzept für ein IT-Sicherheitsprodukt darstellt

Bewertung: CC PP Aufbau



Bewertung: CC PP Aufbau

- **PP-Einführung:**
 - eindeutige Identifikation und allgemeiner Überblick über das Schutzprofil **EVG-Beschreibung:**
 - Beschreibung des EVG bzw. der Produktgruppe, auf die sich das Schutzprofil bezieht
 - Einsatzmöglichkeiten, die allgemeinen IT-Sicherheitseigenschaften und Grenzen der Benutzung
- **EVG-Sicherheitsumgebung:**
 - Beschreibung der Sicherheitsaspekte der beabsichtigten Einsatzumgebung und die erwartete Art der Nutzung des EVG

Bewertung: CC PP Aufbau

- **EVG-Sicherheitsumgebung (Forts.)**
 - Durchführung einer Art Risikoanalyse
 - Identifikation möglicher Angriffe und Schutzmethoden
 - Identifikation der Bedrohungen, denen nicht durch den EVG entgegengewirkt wird
 - organisatorische Sicherheitspolitiken: Annahmen über den sicheren Betrieb des EVG
- **Sicherheitsziele:**
 - Definition der Sicherheitsziele des EVG in seiner Einsatzumgebung
 - Angaben, wie den Bedrohungen entgegengewirkt wird bzw. die Sicherheitspolitiken erfüllt werden sollen

Bewertung: CC PP Aufbau

- **IT-Sicherheitsanforderungen:**
 - Definition der Anforderungen an die Funktionalität und an die Vertrauenswürdigkeit des EVG
 - Rückgriff auf die Anforderungen der Teile 2 und 3 der CC oder freie Formulierung
- **PP-Anwendungsbemerkungen:** optionale Informationen
- **Erklärungsteil des PP:**
 - Zeigen, dass ein zu diesem Schutzprofil konformer EVG eine wirksame Menge von IT-Sicherheitsmaßnahmen in seiner Sicherheitsumgebung bereitstellt: Sicherheitskonzept ist in sich schlüssig
 - Beziehungen zw. Sicherheitsumgebung, den Sicherheitszielen und den IT-Sicherheitsanforderungen werden beschrieben

Bewertung: CC Fazit

- 4-stufiger Prozess der Bewertung der Vertrauenswürdigkeit des Entwicklungsprozesses
 - Anforderungen, Architekturentwurf, Feinentwurf und Implementierung
- Wirksamkeit:
Eignung und Zusammenwirken der Funktionalität
 - Stärke der EVG-Sicherheitsfunktionen entspricht Mechanismenstärke: niedrig, mittel oder hoch
 - getrennte Prüfung und Bewertung der Funktionalität und der Vertrauenswürdigkeit.
- **Pros/Cons CC-Evaluierung?**
+ Sicherheit / Qualität, bei KRITIS notwendig, | - Aufwendig, kostet Geld, preisgeben von
pfl. (cyber resilience act) | Interna des Produkts

Bewertung: CC

- **Beispiele CC evaluierter Systeme?**
 - **SUSE Linux Enterprise Server Version 15**
(Version 12 war EAL4+)
 - **Microsoft Windows 11 and Windows Server 2022**
Protection Profile für Betriebssysteme
 - <https://www.commoncriteriaportal.org/>
 - (Nur) Zwei Produkte EAL7+
seit 16.7.2010 (aktualisiert 2023, zweites 2021)
Boundary Protection Devices and Systems

CC Statistik

1834 Certified Products by Category *		
Category	Products	Archived
Access Control Devices and Systems	22	139
Biometric Systems and Devices	2	3
Boundary Protection Devices and Systems	39	226
Data Protection	45	207
Databases	10	88
Detection Devices and Systems	6	75
ICs, Smart Cards and Smart Card-Related Devices and Systems	782	1455
Key Management Systems	5	53
Mobility	43	93
Multi-Function Devices	223	526
Network and Network-Related Devices and Systems	231	717
Operating Systems	40	210
Other Devices and Systems	321	845
Products for Digital Signatures	50	137
Trusted Computing	15	56
Totals:	1834	4830
Grand Total:		6664

CC Statistik II

Certified Products by Assurance Level and Certification Date												
EAL	2016	2017	2018	2019	2020	2021	2022	2023	2024	2025	2026	Total
Basic	0	0	0	0	0	4	13	15	8	4	9	53
EAL1	0	0	0	0	0	2	2	0	7	4	2	17
EAL1+	0	0	0	0	0	0	2	2	0	3	0	7
EAL2	0	0	0	0	1	18	12	14	14	14	15	88
EAL2+	0	0	0	0	0	15	30	33	21	31	11	141
EAL3	0	0	0	0	0	2	0	2	3	3	0	10
EAL3+	0	0	0	0	0	8	29	15	9	9	11	81
EAL4	0	0	1	0	1	2	2	3	1	5	2	17
EAL4+	1	1	1	1	2	46	52	89	59	80	45	377
EAL5	0	0	0	0	1	0	4	2	1	1	4	13
EAL5+	0	8	5	7	16	26	34	79	69	75	66	385
EAL6	0	0	0	0	0	0	1	1	0	0	0	2
EAL6+	0	0	0	0	2	21	31	33	49	33	9	178
EAL7	0	0	0	0	1	0	1	1	0	0	2	5
EAL7+	0	0	0	0	0	0	0	1	0	0	1	2
Medium	0	0	0	0	0	0	0	0	0	0	0	0
None	0	0	0	0	0	40	52	69	124	132	41	458
US Standard	0	0	0	0	0	0	0	0	0	0	0	0
Totals:	1	9	7	8	24	184	265	359	365	394	218	1834

CC Statistik III

Certified Products by Scheme and Assurance Level																			
Scheme	B	EAL1	EAL1+	EAL2	EAL2+	EAL3	EAL3+	EAL4	EAL4+	EAL5	EAL5+	EAL6	EAL6+	EAL7	EAL7+	M	N	S	Total
Australia	0	0	0	4	4	0	0	0	0	0	0	0	0	0	0	0	23	0	31
Canada	0	0	0	0	18	0	1	0	8	0	0	0	0	0	0	0	103	0	130
Germany	9	0	3	11	12	7	45	5	84	2	20	0	55	0	1	0	1	0	255
Spain	4	2	0	11	13	0	4	2	19	1	11	0	1	0	0	0	9	0	77
France	1	0	0	0	23	0	6	1	86	4	248	2	70	5	0	0	0	0	446
India	1	0	0	6	1	0	0	0	0	0	0	0	0	0	0	0	0	0	8
Italy	0	1	1	1	13	0	3	0	27	0	2	0	0	0	0	0	20	0	68
Japan	7	0	0	16	10	0	0	0	0	0	0	0	0	0	0	0	76	0	109
Republic of Korea	0	6	1	4	0	0	0	0	2	0	5	0	0	0	0	0	34	0	52
Malaysia	0	5	0	13	6	0	0	0	0	0	0	0	0	0	0	0	0	0	24
Netherlands	7	0	0	1	18	0	12	4	119	6	94	0	52	0	1	0	0	0	314
Norway	0	0	0	0	0	0	0	1	4	0	4	0	0	0	0	0	0	0	9
Poland	0	0	0	1	0	1	0	1	2	0	0	0	0	0	0	0	0	0	5
Qatar	0	1	0	1	0	0	0	0	0	0	0	0	0	0	0	0	0	0	2
Sweden	24	1	2	14	15	2	10	3	9	0	0	0	0	0	0	0	3	0	83
Singapore	0	1	0	2	8	0	0	0	9	0	0	0	0	0	0	0	0	0	20
Turkey	0	0	0	3	0	0	0	0	8	0	1	0	0	0	0	0	0	0	12
United States	0	0	0	0	0	0	0	0	0	0	0	0	0	0	0	0	189	0	189
Totals:	53	17	7	88	141	10	81	17	377	13	385	2	178	5	2	0	458	0	1834

Prof. Dr. Johannes Freudenmann (DHBW Karlsruhe)
Masterprogramm Informatik

DNS-Scanner

www.dhbw.de

DNS-Scanner

Anwender nutzen viele Dienste im Internet.
Probleme mit Malware nehmen immer mehr zu.
Wie kann ich meine Anwender besser schützen?

- URL – Filter.

Probleme:

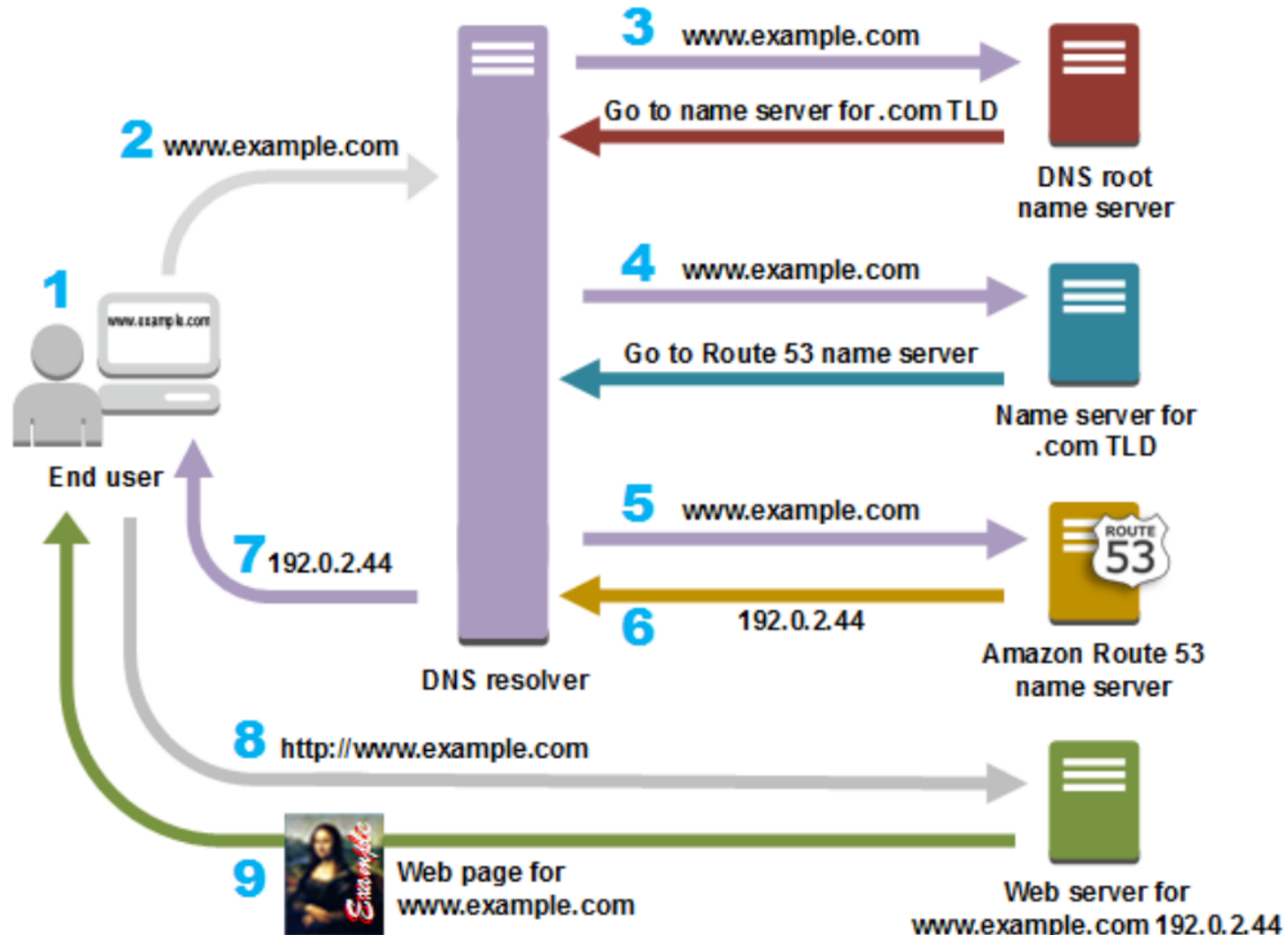
- Schutz nur für Webserver
- Probleme bei Verschlüsselung

Alternative: Kopplung an DNS.

- Alternativer DNS-Server wird konfiguriert
- Bsp. Umbrella von Cisco
- Dienst auch von anderen Stellen verfügbar.

DNSSense, DFN/DNS-RPZ, ????

Erläuterung DNS (Erinnerung)



Umbrella Security Settings

- ☒ **Malware**
Websites and other servers that host malicious software, drive-by downloads/exploits, mobile threats and more.
- ☒ **Newly Seen Domains**
Domains that have become active very recently. These are often used in new attacks.
- ☒ **Command and Control Callbacks**
Prevent compromised devices from communicating with attackers' infrastructure.
- ☒ **Phishing Attacks**
Fraudulent websites that aim to trick users into handing over personal or financial information.
- ☐ **Dynamic DNS**
Block sites that are hosting dynamic DNS content.
- ☐ **Potentially Harmful Domains**
Domains that exhibit suspicious behavior and may be part of an attack.
- ☒ **DNS Tunneling VPN**
VPN services that allow users to disguise their traffic by tunneling it through the DNS protocol. These can be used to bypass regarding access and data transfer.
- ☒ **Cryptomining**
Cryptomining allows organizations to control cryptominer access to mining pools and web miners.

Umbrella Content selection

Categories [SELECT ALL](#)

- | | | |
|---|---|--|
| ☐ Adult | ☐ Hate Speech | ☐ Politics |
| ☐ Advertisements | ☐ Health and Medicine | ☐ Pornography |
| ☐ Alcohol | ☐ Humor | ☐ Private IP Addresses as Host |
| ☐ Animals and Pets | ☐ Hunting | ☐ Professional Networking |
| ☐ Arts | ☐ Illegal Activities | ☐ Real Estate |
| ☐ Astrology | ☐ Illegal Downloads | ☐ Recipes and Food |
| ☐ Auctions | ☐ Illegal Drugs | ☐ Reference |
| ☐ Business and Industry | ☐ Infrastructure and Content Delivery Networks | ☐ Regional Restricted Sites (Germany) |
| ☐ Cannabis | ☐ Internet of Things | ☐ Regional Restricted Sites (Great Britain) |
| ☐ Chat and Instant Messaging | ☐ Internet Telephony | ☐ Regional Restricted Sites (Italy) |
| ☐ Cheating and Plagiarism | ☐ Job Search | ☐ Regional Restricted Sites (Poland) |
| ☐ Cloud and Data Centers | ☐ Lingerie and Swimsuits | ☐ Religion |
| ☐ Computer Security | ☐ Lotteries | ☐ SaaS and B2B |
| ☐ Computers and Internet | ☐ Miscellaneous | ☐ Safe for Kids |

Umbrella Meldung





Diese Seite ist aufgrund einer Phishing-Bedrohung blockiert.

www.internetbadguys.com

Phishing ist der betrügerische Versuch, unter Vorspiegelung falscher Tatsachen persönliche Informationen von Ihnen zu erhalten.

PLEASE READ CAREFULLYAccess to this web page is blocked in accordance with ATS Security Policies. If you believe this page you are attempting to access is appropriate and is improperly rated, please contact your IT Administrator.

Diese Website wurde aufgrund der folgenden Kategorien blockiert: **Phishing**

[> Diagnoseinformationen](#)

Umbrella Anmerkungen

- Realisierbar einfach durch Eintrag des DNS-Server.
- Beschränkt auf die Auswahl von Domänen. Keine Differenzierung zwischen verschiedenen Webseiten auf demselben Server.
- Positivlisten, Negativlisten, Künstliche Intelligenz, ... einsetzbar.
- Policy abhängig vom Betreiber.
- Ergänzung
 - Lokaler Client -> differenzierte weitere Auswahl möglich

IT-Sicherheit - OpenVAS

Prof. Dr. Johannes Freudenmann (DHBW Karlsruhe)
Masterprogramm Informatik

www.dhbw.de

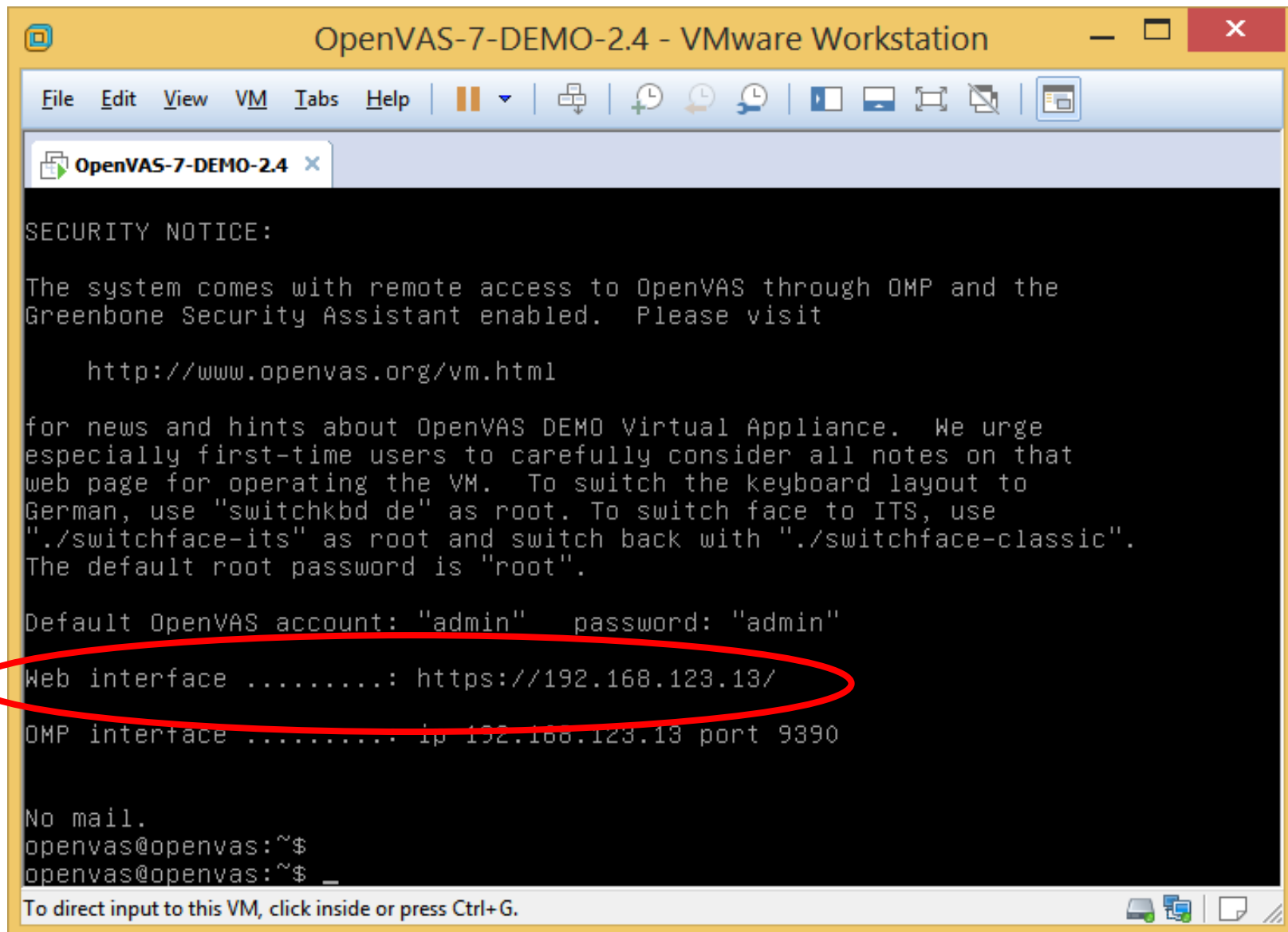
Werkzeuge Nessus/OpenVAS

- NESSUS, 2005 unter proprietäre Lizenz gestellt.
 - 2014 5.2 55.000 Schwachstellen untersucht.
 - u.a. auch Compliance-Checks
- Alternative weiterentwickelt unter GPL – OPENVAS (Open Vulnerability Assessment System, <https://www.openvas.org/>)
 - Integriert u.a.auch Nmap
 - Läuft auf Unix
 - Bedienung über Web-Interface
 - Konfiguration über CERT-Feed
 - Hinweise auf CVEs
- Installation auf eigenem PC oder im kleinen Netz
- Beschreibung zur Entwicklung von OpenVAS:
<http://www.heise.de/ix/artikel/Der-Erbe-waechst-958563.html>

Werkzeuge Nessus/OpenVAS

- Weiterentwicklung durch Greenbone Networks
- 2025 Version 23.20.1
- Empfohlen vom BSI
- *OpenVAS – Scanner jetzt eingebaut in Greenbone Vulnerability Management (GVM)*
- 1.8.2023 > 120.000 Schwachstellen.
- Greenbone Community Edition mit Greenbone Community Feed (daneben Enterprise Feed)
 - <https://greenbone.github.io/docs/latest/index.html>

Werkzeuge Nessus/OpenVAS Demo



```
OpenVAS-7-DEMO-2.4 - VMware Workstation
File Edit View VM Tabs Help
OpenVAS-7-DEMO-2.4 x
SECURITY NOTICE:
The system comes with remote access to OpenVAS through OMP and the
Greenbone Security Assistant enabled. Please visit
    http://www.openvas.org/vm.html
for news and hints about OpenVAS DEMO Virtual Appliance. We urge
especially first-time users to carefully consider all notes on that
web page for operating the VM. To switch the keyboard layout to
German, use "switchkbd de" as root. To switch face to ITS, use
"./switchface-its" as root and switch back with "./switchface-classic".
The default root password is "root".
Default OpenVAS account: "admin" password: "admin"
Web interface .....: https://192.168.123.13/
OMP interface ..... ip 192.168.123.13 port 9390
No mail.
openvas@openvas:~$
openvas@openvas:~$ _
To direct input to this VM, click inside or press Ctrl+G.
```

Werkzeuge Nessus/OpenVAS Demo



Aufgaben 1 - 3 von 3 (gesamt: 3)

Refresh alle 30 Sek.

Filter: apply_overrides=1 rows=10 permission=any owner=any

Name	Status	Berichte		Schweregrad	Trend	Aktionen
		Gesamt	Letzter			
Immediate scan of IP 127.0.0.1	Abgeschlossen	1 (1)	May 3 2015	6.4 (Mittel)		
Immediate scan of IP 192.168.123.13	Abgeschlossen	1 (1)	May 3 2015	6.4 (Mittel)		
Immediate scan of IP localhost	Abgeschlossen	1 (1)	May 3 2015	4.3 (Mittel)		

(Angewandter Filter: apply_overrides=1 rows=10 permission=any owner=any first=1 sort=name)

1 - 3 von 3 (gesamt: 3)

Willkommen neue Anwender!

Um die umfangreichen Möglichkeiten dieser Anwendung kennenzulernen und um schnell erste Ergebnisse zu erzielen, helfe ich mit Hinweisen und Abkürzungen.

Ich erscheine automatisch dort, wo noch keine oder nur wenige Objekte vorliegen. Und verschwinde wieder, wenn mehr als 3 Objekte vorliegen. Ich kann aber über dieses Icon jederzeit wieder aktiviert werden.

Wenn Sie Hilfe bei der Erstellung neuer Scanaufgaben aber auch mehr Optionen wünschen, können Sie "Erweiterter Aufgaben-Wizard" oben in diesem Fenster auswählen, wo momentan "Aufgaben-Wizard", markiert mit einem kleinen Pfeil, steht.

Für detaillierte Information zu den Funktionen steht das integrierte Hilfe-System zur Verfügung. Dieses steht jederzeit kontext-bezogen über das Hilfe-Icon bereit: ?.

**Schnellstart: Unmittelbar eine IP-Adresse scannen**
IP-Adresse oder Hostname:

Für diese Abkürzung werde ich folgendes durchführen:

1. Erstellen eines neuen Ziels mit voreingestellter Port-Liste
2. Erstellen einer neuen Aufgabe mit diesem Ziel und voreingestellter Scan-Konfiguration
3. Direktes Starten dieser Scan-Aufgabe
4. Wechseln der Ansicht auf Seitenaktualisierung alle 30 Sekunden so dass man sich zurücklehnen und dem Scan-Fortschritt zuschauen kann

Im Grunde muss man sich aber nicht zurücklehnen. Sobald der Scan-Fortschritt über 1% liegt kann man bereits über den Link in der Spalte "Berichte Gesamt" in die Details des Scan-Berichts springen und die bisher gesammelten Ergebnisse einsehen.

Durch Anklicken des "Neue Aufgabe"-Icons kann man Aufgaben auch selbst erstellen. Hierfür wird jedoch auch ein Ziel benötigt, welches erstellt werden kann, indem man auf der Ziele-Seite aus den Konfigurations-Menü auf das Icon "Neues Ziel" klickt.

Scan-Management

Asset-Management

SecInfo-Management

Konfiguration

Extras

Administration

Hilfe

Berichte



1 - 3 von 3 (gesamt: 3)



Refresh alle 30 Sek.



Filter: apply_overrides=1 rows=10 permission=any owner=any



Datum	Status	Aufgabe	Schweregrad 	Scan-Ergebnisse					Aktionen
				Hoch	Mittel	Niedrig	Log	Falsch Pos.	
Sun May 3 15:33:24 2015	Abgeschlossen	Immediate scan of IP 127.0.0.1	6.4 (Mittel)	0	5	0	19	0	
Sun May 3 15:32:58 2015	Abgeschlossen	Immediate scan of IP localhost	4.3 (Mittel)	0	4	0	20	0	
Sun May 3 15:32:40 2015	Abgeschlossen	Immediate scan of IP 192.168.123.13	5.4 (Mittel)	0	5	0	19	0	

(Angewandter Filter: apply_overrides=1 rows=10 permission=any owner=any sort=reverse=date first=1)



1 - 3 von 3 (gesamt: 3)



Scan-Management

Asset-Management

SecInfo-Management

Konfiguration

Extras

Administration

Hilfe

Aufgaben-Details



Refresh alle 30 Sek.

**Name:** Immediate scan of IP 192.168.123.13

ID: 6966b247-1115-4021-bdb9-42ca65537b65

Kommentar:

Erstellt: Sun May 3 15:32:40 2015

Scan-Konfiguration: Full and fast

Zuletzt geändert: Sun May 3 15:32:43 2015

Benachrichtigungen:

Zeitplan: (Fälligkeit: abgelaufen)

Ziel: Target for immediate scan of IP 192.168.123.13

Reihenfolge der Ziel-Hosts: N/A

Netzwerk-Quell-Interface:

Slave:

Status: Abgeschlossen

Berichte: 1 (Abgeschlossen: 1, Letzter: May 3 2015)

Zu Assets hinzufügen: ja

Änderbare Aufgabe: nein

Notizen: 0

Übersteuerungen: 0

Scan-Intensität

Maximal gleichzeitig ausgeführte NVT pro Host: 10

Maximal gleichzeitig gescannte Hosts: 30

Benutzer-Tags für "Immediate scan of IP 192.168.123.13": keine



Berechtigungen für "Immediate scan of IP 192.168.123.13": keine

Leserechte vergeben an Benutzer



Name	Beschreibung	Aktionen
------	--------------	----------

Scan-Management

Asset-Management

SecInfo-Management

Konfiguration

Extras

Administration

Hilfe

▼ Bericht: Ergebnisse 1 - 24 von 24 (gesamt: 24)

PDF

Abgeschlossen

Filter: sort-reverse=severity result_hosts_only=1 min_cvss_bas

Schwachstelle	Schweregrad	Host	Ort	Aktionen
Raritan Power IQ SQL Injection Vulnerability	6.4 (Mittel)	192.168.123.13	general/tcp	 
Check for SSL Weak Ciphers	4.3 (Mittel)	192.168.123.13	443/tcp	 
POODLE SSLv3 Protocol CBC ciphers Information Disclosure Vulnerability	4.3 (Mittel)	192.168.123.13	443/tcp	 
Check for SSL Weak Ciphers	4.3 (Mittel)	192.168.123.13	9390/tcp	 
POODLE SSLv3 Protocol CBC ciphers Information Disclosure Vulnerability	4.3 (Mittel)	192.168.123.13	9390/tcp	 
CPE Inventory	0.0 (Log)	192.168.123.13	general/CPE-T	 
OS fingerprinting	0.0 (Log)	192.168.123.13	general/tcp	 
DIRB (NASL wrapper)	0.0 (Log)	192.168.123.13	general/tcp	 
arachni (NASL wrapper)	0.0 (Log)	192.168.123.13	general/tcp	 
Nikto (NASL wrapper)	0.0 (Log)	192.168.123.13	general/tcp	 
Traceroute	0.0 (Log)	192.168.123.13	general/tcp	 
Services	0.0 (Log)	192.168.123.13	80/tcp	 
Identify unknown services with nmap	0.0 (Log)	192.168.123.13	80/tcp	 
wapiti (NASL wrapper)	0.0 (Log)	192.168.123.13	80/tcp	 
Identify unknown services with nmap	0.0 (Log)	192.168.123.13	111/tcp	 
Services	0.0 (Log)	192.168.123.13	443/tcp	 

Scan-Management

Asset-Management

SecInfo-Management

Konfiguration

Extras

Administration

Hilfe

Ergebnis-Details ? ☰ ⬇

Aufgabe: [Immediate scan of IP 192.168.123.13](#)

ID: 5eb9abec-6533-4861-9491-a41ca2d820a5

Schwachstelle	Schweregrad	Host	Ort	Aktionen
Raritan Power IQ SQL Injection Vulnerability	6.4 (Mittel)	192.168.123.13	general/tcp	 

Zusammenfassung

Raritan Power IQ SQL Injection Vulnerability

Ergebnis zur Schwachstellenerkennung

Schwachstelle wurde gemäß der Methode zur Schwachstellenerkennung erkannt.

Auswirkungen

Successful exploitation will allow attacker to inject or manipulate SQL queries in the back-end database, allowing for the manipulation or disclosure of arbitrary data.

LösungInstall the patch from Raritan at <https://www.raritan.com/support/product/poweriq/security-patches>**Betroffene Software/OS**

Raritan Power IQ 4.2.2, 4.1.3 and below.

Schwachstellen-Einblick

Raritan PowerIQ is vulnerable to SQL injection. A remote attacker could send specially-crafted SQL statements to the /license/records script using the sort or dir parameter, which could allow the attacker to view, add, modify or delete information in the back-end database.

Methode zur Schwachstellenerkennung

Perform a time-based blind SQL injection request.

Details: [Raritan Power IQ SQL Injection Vulnerability \(OID: 1.3.6.1.4.1.25623.1.0.105922\)](#)

Benutzte Version: \$Revision: 673 \$

Verweise

Name: Raritan Power IQ SQL Injection Vulnerability

ID: 1.3.6.1.4.1.25623.1.0.105922

Konfiguration:

Zuletzt geändert: Wed Sep 17 10:01:04 2014

Familie: Web application abuses

Erstellt: Fri Aug 15 09:50:19 2014

OID: 1.3.6.1.4.1.25623.1.0.105922

Version: \$Revision: 673 \$

Notizen: 0

Übersteuerungen: 0

Zusammenfassung

Raritan Power IQ SQL Injection Vulnerability

Betroffene Software/OS

Raritan Power IQ 4.2.2, 4.1.3 and below.

Schwachstellen-Bewertung

CVSS-Basissscore:  6.4CVSS-Basisvektor: [AV:N/AC:L/Au:N/C:P/I:P/A:N](#)

Schwachstellen-Einblick

Raritan PowerIQ is vulnerable to SQL injection. A remote attacker could send specially-crafted SQL statements to the `/license/records` script using the `sort` or `dir` parameter, which could allow the attacker to view, add, modify or delete information in the back-end database.

Methode zur Schwachstellenerkennung

Perform a time-based blind SQL injection request.

Auswirkungen

Successful exploitation will allow attacker to inject or manipulate SQL queries in the back-end database, allowing for the manipulation or disclosure of arbitrary data.

Lösung

Schwachstelle	Schweregrad		Host	Ort	Aktionen
Check for SSL Weak Ciphers	4.3 (Mittel)		192.168.123.13	443/tcp	 

Zusammenfassung

This routine search for weak SSL ciphers offered by a service.

Ergebnis zur Schwachstellenerkennung

Weak ciphers offered by this service:

SSL3_RSA_RC4_128_SHA
TLS1_RSA_RC4_128_SHA

Lösung

The configuration of this services should be changed so that it does not support the listed weak ciphers anymore.

Schwachstellen-Einblick

These rules are applied for the evaluation of the cryptographic strength:

- Any SSL/TLS using no cipher is considered weak.
- All SSLv2 ciphers are considered weak due to a design flaw within the SSLv2 protocol.
- RC4 is considered to be weak.
- Ciphers using 64 bit or less are considered to be vulnerable to brute force methods and therefore considered as weak.
- 1024 bit RSA authentication is considered to be insecure and therefore as weak.
- CBC ciphers in TLS < 1.2 are considered to be vulnerable to the BEAST or Lucky 13 attacks
- Any cipher considered to be secure for only the next 10 years is considered as medium
- Any other cipher is considered as strong

Methode zur Schwachstellenerkennung

Details: [Check for SSL Weak Ciphers \(OID: 1.3.6.1.4.1.25623.1.0.103440\)](#)

Benutzte Version: \$Revision: 733 \$

Name: Check for SSL Weak Ciphers

ID: 1.3.6.1.4.1.25623.1.0.103440

Konfiguration:

Zuletzt geändert: Mon Oct 6 07:23:48 2014

Familie: General

Erstellt: Thu Mar 1 16:16:10 2012

OID: 1.3.6.1.4.1.25623.1.0.103440

Version: \$Revision: 733 \$

Notizen: 0

Übersteuerungen: 0

Zusammenfassung

This routine search for weak SSL ciphers offered by a service.

Schwachstellen-Bewertung

CVSS-Basisscore:  4.3CVSS-Basisvektor: [AV:N/AC:M/Au:N/C:P/I:N/A:N](#)

Schwachstellen-Einblick

These rules are applied for the evaluation of the cryptographic strength:

- Any SSL/TLS using no cipher is considered weak.
- All SSLv2 ciphers are considered weak due to a design flaw within the SSLv2 protocol.
- RC4 is considered to be weak.
- Ciphers using 64 bit or less are considered to be vulnerable to brute force methods and therefore considered as weak.
- 1024 bit RSA authentication is considered to be insecure and therefore as weak.
- CBC ciphers in TLS < 1.2 are considered to be vulnerable to the BEAST or Lucky 13 attacks
- Any cipher considered to be secure for only the next 10 years is considered as medium
- Any other cipher is considered as strong

Lösung

The configuration of this services should be changed so that it does not support the listed weak ciphers anymore.

Schwachstelle	Schweregrad	Host	Ort	Aktionen
---------------	-------------	------	-----	----------

[POODLE SSLv3 Protocol CBC ciphers Information Disclosure Vulnerability](#)

4.3 (Mittel)

192.168.123.13

443/tcp



Zusammenfassung

This host is installed with OpenSSL and is prone to information disclosure vulnerability.

Ergebnis zur Schwachstellenerkennung

Schwachstelle wurde gemäß der Methode zur Schwachstellenerkennung erkannt.

Auswirkungen

Successful exploitation will allow a man-in-the-middle attackers gain access to the plain text data stream.

Impact Level: Application

Lösung

Vendor released a patch to address this vulnerabiliy, For updates contact vendor or refer to <https://www.openssl.org>

NOTE: The only correct way to fix POODLE is to disable SSL v3.0

Betroffene Software/OS

OpenSSL through 1.0.1i

Schwachstellen-Einblick

The flaw is due to the block cipher padding not being deterministic and not covered by the Message Authentication Code

Methode zur Schwachstellenerkennung

Send a SSLv3 request and check the response.

Details: [POODLE SSLv3 Protocol CBC ciphers Information Disclosure Vulnerability \(OID: 1.3.6.1.4.1.25623.1.0.802087\)](#)

Benutzte Version: \$Revision: 787 \$

Verweise

CVE: [CVE-2014-3566](#)

BID: 70574

CERT: [DFN-CERT-2014-1717](#) , [DFN-CERT-2014-1680](#) , [DFN-CERT-2014-1632](#) , [DFN-CERT-2014-1564](#) , [DFN-CERT-2014-1542](#) , [DFN-CERT-2014-1414](#) , [DFN-CERT-2014-1366](#) , [DFN-CERT-2014-1354](#)

Anderer: <http://osvdb.com/113251>

<https://www.openssl.org/~bodo/ssl-poodle.pdf>

<https://www.imperialviolet.org/2014/10/14/poodle.html>



Name: POODLE SSLv3 Protocol CBC ciphers Information Disclosure Vulnerability

ID: 1.3.6.1.4.1.25623.1.0.802087

Zuletzt geändert: Tue Nov 4 16:25:34 2014

Erstellt: Thu Oct 16 11:59:43 2014

Konfiguration:

Familie: General

OID: 1.3.6.1.4.1.25623.1.0.802087

Version: \$Revision: 787 \$

Notizen: 0

Übersteuerungen: 0

Zusammenfassung

This host is installed with OpenSSL and is prone to information disclosure vulnerability.

Betroffene Software/OS

OpenSSL through 1.0.1i

Schwachstellen-Bewertung

CVSS-Basisscore:  4.3

CVSS-Basisvektor: [AV:N/AC:M/Au:N/C:P/I:N/A:N](#)

Schwachstellen-Einblick

The flaw is due to the block cipher padding not being deterministic and not covered by the Message Authentication Code

Methode zur Schwachstellenerkennung

Send a SSLv3 request and check the response.

Auswirkungen

Successful exploitation will allow a man-in-the-middle attackers gain access to the plain text data stream.

Impact Level: Application

Zusammenfassung

This host is installed with OpenSSL and is prone to information disclosure vulnerability.

Betroffene Software/OS

OpenSSL through 1.0.1i

Schwachstellen-Bewertung

CVSS-Basisscore:  4.3

CVSS-Basisvektor: AV:N/AC:M/Au:N/C:P/I:N/A:N

Schwachstellen-Einblick

The flaw is due to the block cipher padding not being deterministic and not covered by the Message Authentication Code

Methode zur Schwachstellenerkennung

Send a SSLv3 request and check the response.

Auswirkungen

Successful exploitation will allow a man-in-the-middle attackers gain access to the plain text data stream.

Impact Level: Application

Lösung

Vendor released a patch to address this vulnerabiliy, For updates contact vendor or refer to <https://www.openssl.org>

NOTE: The only correct way to fix POODLE is to disable SSL v3.0

Verweise

CVE: [CVE-2014-3566](#)

BID: [70574](#)

CERT: [DFN-CERT-2014-1717](#), [DFN-CERT-2014-1680](#), [DFN-CERT-2014-1632](#), [DFN-CERT-2014-1564](#), [DFN-CERT-2014-1542](#), [DFN-CERT-2014-1541](#), [DFN-CERT-2014-1366](#), [DFN-CERT-2014-1354](#)

Name: CVE-2014-3566

CWE-ID: CWE-310

ID: CVE-2014-3566

Veröffentlicht: 2014-10-14T20:55:02.137-04:00

Zuletzt geändert: 2014-12-11T22:01:45.237-05:00

Zuletzt aktualisiert: 2015-01-14T08:04:00.000+0000

Beschreibung

The SSL protocol 3.0, as used in OpenSSL through 1.0.1i and other products, uses nondeterministic CBC padding, which makes it easier for man-in-the-middle attackers to obtain cleartext data via a padding-oracle attack, aka the "POODLE" issue.

CVSS

Base score	 4.3 (AV:N/AC:M/Au:N/C:P/I:N/A:N)
Access vector	NETWORK
Access Complexity	MEDIUM
Authentication	NONE
Confidentiality impact	PARTIAL
Integrity impact	NONE
Availability impact	NONE
Source	http://nvd.nist.gov
Generated	2014-10-15T14:51:12.403-04:00

Verweise

CERT

TA14-290A

<http://www.us-cert.gov/ncas/alerts/TA14-290A>

CERT-VN

VU#577193

<http://www.kb.cert.org/vuls/id/577193>

CONFIRM

<https://www.suse.com/support/kb/doc.php?id=7015773>

<https://www.suse.com/support/kb/doc.php?id=7015773>

CONFIRM

https://www.openssl.org/news/secadv_20141015.txt

https://www.openssl.org/news/secadv_20141015.txt

MISC

<https://www.openssl.org/~bodo/ssl-poodle.pdf>

<https://www.openssl.org/~bodo/ssl-poodle.pdf>

DFN-CERT-Advisory-Details ?

Name:	DFN-CERT-2014-1717	ID:	DFN-CERT-2014-1717
Titel:	OpenSSL: Mehrere Schwachstellen ermöglichen u.a. Denial-of-Service-Angriffe (Linux, Fedora)	Erstellt:	2014-12-29T08:48:26Z
Advisory-Link:	https://openvas.dfn-cert.de/adv/DFN-CERT-2014-1717/	Zuletzt geändert:	2014-12-29T09:36:42Z
Schweregrad:	 6.8		

Zusammenfassung

Mehrere Schwachstellen in OpenSSL ermöglichen einem entfernten, nicht authentisierten Angreifer die Durchführung von Denial-of-Service- und Man-in-the-Middle-Angriffen, das Umgehen von Sicherheitsvorkehrungen, das Ausführen von Programmcode sowie das Ausspähen von Informationen. Für die Distributionen Fedora 20, Fedora 21 und für Fedora EPEL 7 stehen Sicherheitsupdates für mingw-openssl zur Verfügung, welche mit der Version openssl-1.0.1j-3.fc22rn synchronisiert wurden. Für Fedora EPEL 7 werden die Schwachstellen CVE-2014-3509 und CVE-2014-3566 nicht benannt.

CVE-Verweise

- [CVE-2014-3566](#)
- [CVE-2014-3511](#)
- [CVE-2014-3510](#)
- [CVE-2014-3509](#)
- [CVE-2014-3508](#)
- [CVE-2014-3507](#)
- [CVE-2014-3506](#)
- [CVE-2014-3505](#)
- [CVE-2014-3470](#)
- [CVE-2014-0224](#)
- [CVE-2014-0221](#)
- [CVE-2014-0195](#)
- [CVE-2014-0198](#)
- [CVE-2010-5298](#)

Scan-Management

Asset-Management

SecInfo-Management

Konfiguration

Extras

Administration

Hilfe

Ergebnis-Details ? ☰ ↓

Aufgabe: [Immediate scan of IP 192.168.123.13](#)

ID: b861a4fa-5166-4df1-87d2-1d46398c083e

Schwachstelle	Schweregrad	Host	Ort	Aktionen
OS fingerprinting	0.0 (Log)	192.168.123.13	general/tcp	 

Zusammenfassung

This script performs ICMP based OS fingerprinting (as described by Ofir Arkin and Fyodor Yarochkin in Phrack #57). It can be used to determine remote operating system version.

Ergebnis zur Schwachstellenerkennung

ICMP based OS fingerprint results: (69% confidence)

HP JetDirect

Log-Methode

Details: [OS fingerprinting \(OID: 1.3.6.1.4.1.25623.1.0.102002\)](#)

Benutzte Version: \$Revision: 43 \$

Verweise

Anderer: <http://www.phrack.org/issues.html?issue=57&id=7#article>

Benutzer-Tags für dieses Ergebnis: keine ★ ?

Scan-Management

Asset-Management

SecInfo-Management

Konfiguration

Extras

Administration

Hilfe

NVT-Details ?

Name: OS fingerprinting

ID: 1.3.6.1.4.1.25623.1.0.102002

Konfiguration:

Zuletzt geändert: Mon Nov 4 19:51:40 2013

Familie: Product detection

Erstellt: Tue May 19 10:05:50 2009

OID: 1.3.6.1.4.1.25623.1.0.102002

Version: \$Revision: 43 \$

Notizen: 0

Übersteuerungen: 0

Zusammenfassung

This script performs ICMP based OS fingerprinting (as described by Ofir Arkin and Fyodor Yarochkin in Phrack #57). It can be used to determine remote operating system version.

Schwachstellen-Bewertung

CVSS-Basisscore: 0.0

CVSS-Basisvektor: AV:N/AC:L/Au:N/C:N/I:N/A:N

Verweise

Anderer: <http://www.phrack.org/issues.html?issue=57&id=7#article>

Vorgaben

Name	Standardwert	Aktionen
Timeout	Standard	

Benutzer-Tags für "OS fingerprinting": keine



Scan-Management

Asset-Management

SecInfo-Management

Konfiguration

Extras

Administration

Hilfe

CVSS-Basiscore-Rechner?

Aus Metriken:

Access Vector: Network ▼

Access Complexity: Low ▼

Authentication: None ▼

Confidentiality: None ▼

Integrity: None ▼

Availability: None ▼

Berechnen

Aus Vektor:

AV:N/AC:L/Au:N/C:N/I:N/A:N

Berechnen

Basisvektor: AV:N/AC:L/Au:N/C:N/I:N/A:N

Basiscore: 0.0

CVSS Common Vulnerability Scoring System

- **CVSS Base Vectors**

- (AV:[L,A,N]/AC:[H,M,L]/Au:[N,S,M]/C:[N,P,C]/I:[N,P,C]/A:[N,P,C])

- **Metric:** AV = AccessVector (Related exploit range)

L = Local access, A = Adjacent network, N = Network

- **Metric:** AC = AccessComplexity (Required attack complexity)

H = High, M = Medium, L = Low

- **Metric:** Au = Authentication (Level of authentication needed to exploit)

N= None, S= Requires single instance, M= multiple

- **Metric:** C = ConfImpact (Confidentiality impact)

N = None, P = Partial, C = Complete

- **Metric:** I = IntegImpact (Integrity impact)

N = None, P = Partial, C = Complete

- **Metric:** A = AvailImpact (Availability impact)<>

N = None, P = Partial, C = Complete

CVSS Common Vulnerability Scoring System II

- Quellen dazu
- <https://nvd.nist.gov/vuln-metrics/cvss/vector-v2>
- Neben Basisvektor auch
 - Temporal Vector
 - + Exploitability, RemediationLevel, ReportConfidence
 - Environmental Vector
 - + Collateral Damage Potential, Target Distribution, System Confidentiality/Integrity/Availability Requirement

Ergebnis-Details ? ☰ ⬇

Aufgabe: [Immediate scan of IP 192.168.123.13](#)

ID: 89e03426-217f-4869-8d3e-241a75636456

Schwachstelle	Schweregrad	Host	Ort	Aktionen
Services	0.0 (Log)	192.168.123.13	80/tcp	🔍 ⭐

Zusammenfassung

This plugin attempts to guess which service is running on the remote ports. For instance, it searches for a web server which could listen on another port than 80 and set the results in the plugins knowledge base.

Ergebnis zur Schwachstellenerkennung

An unknown service is running on this port.
It is usually reserved for HTTP

Log-MethodeDetails: [Services \(OID: 1.3.6.1.4.1.25623.1.0.10330\)](#)

Benutzte Version: \$Revision: 69 \$

Benutzer-Tags für dieses Ergebnis: keine ★ ?

OpenVAS SecInfo-Management (Stand 2015)

- 37.577 NVTs – Network Vulnerability Test
- 67.928 CVEs - Common Vulnerabilities and Exposures
- 194.619 CPEs - Common Platform Enumeration
- 27.098 OVAL-Defs - Open Vulnerability and Assessment Language
- 2.971 DFN-CERT-Advisories
- Insgesamt 330.193 Schwachstellen (ggf mehrfach benannt).

OpenVAS SecInfo-Management

Stand 2017

- > 50.000 NVTs – Network Vulnerability Test
- 87.924 CVEs - Common Vulnerabilities and Exposures

Stand 2024

- >150.000 Vulnerability Tests
- 237.725 CVEs

IT-Sicherheit - SNORT

Prof. Dr. Johannes Freudenmann (DHBW Karlsruhe)
Masterprogramm Informatik

www.dhbw.de

Einführung

- IDS – Intrusion Detection System
- IPS – Intrusion Prevention System
IDS & aktiver Schutz vor aktuellen Angriffen
- Kategorien
 - NIDS Network IDS
Analysiert Datenverkehr im Netzwerk
Abgleich mit Signaturen aus Datenbank
 - HIDS Host IDS
Analysiert aktuelles System
Untersucht System Log Meldungen
 - Hybrides IDS – Kombination.

Strategien zur Erkennung

– Pattern

- Signaturen bekannter Angriffe

– Anomalie

- Nicht normales Verhalten
- Lernphase

– Vorteile/Nachteile

+

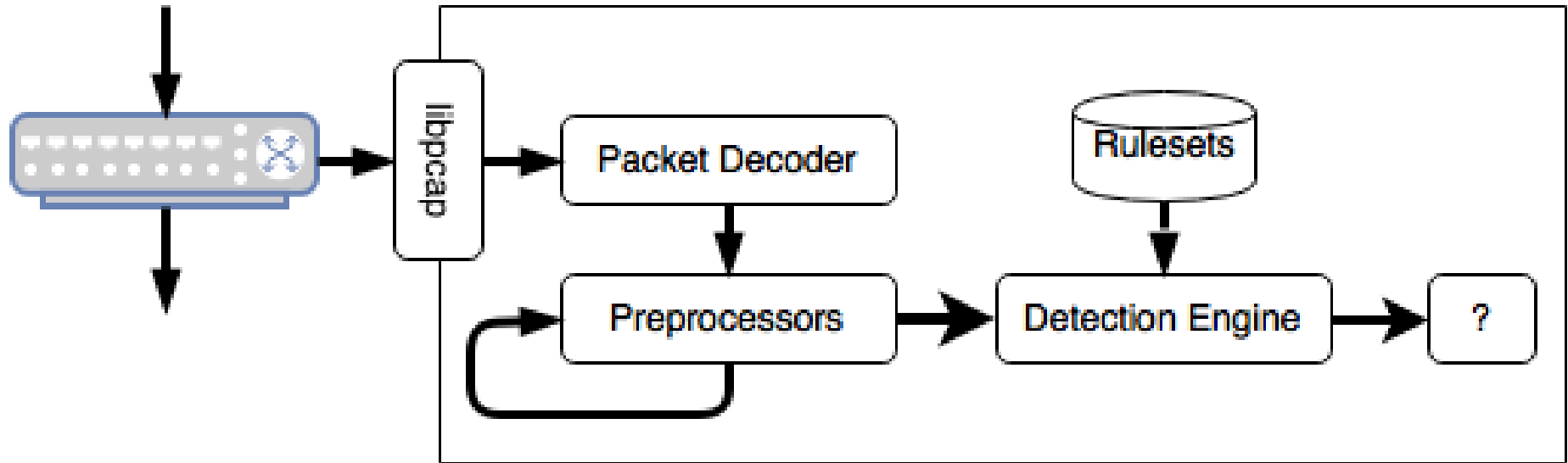
–
- Hilft nicht bei 0-Day
- false positives

Werkzeuge SNORT

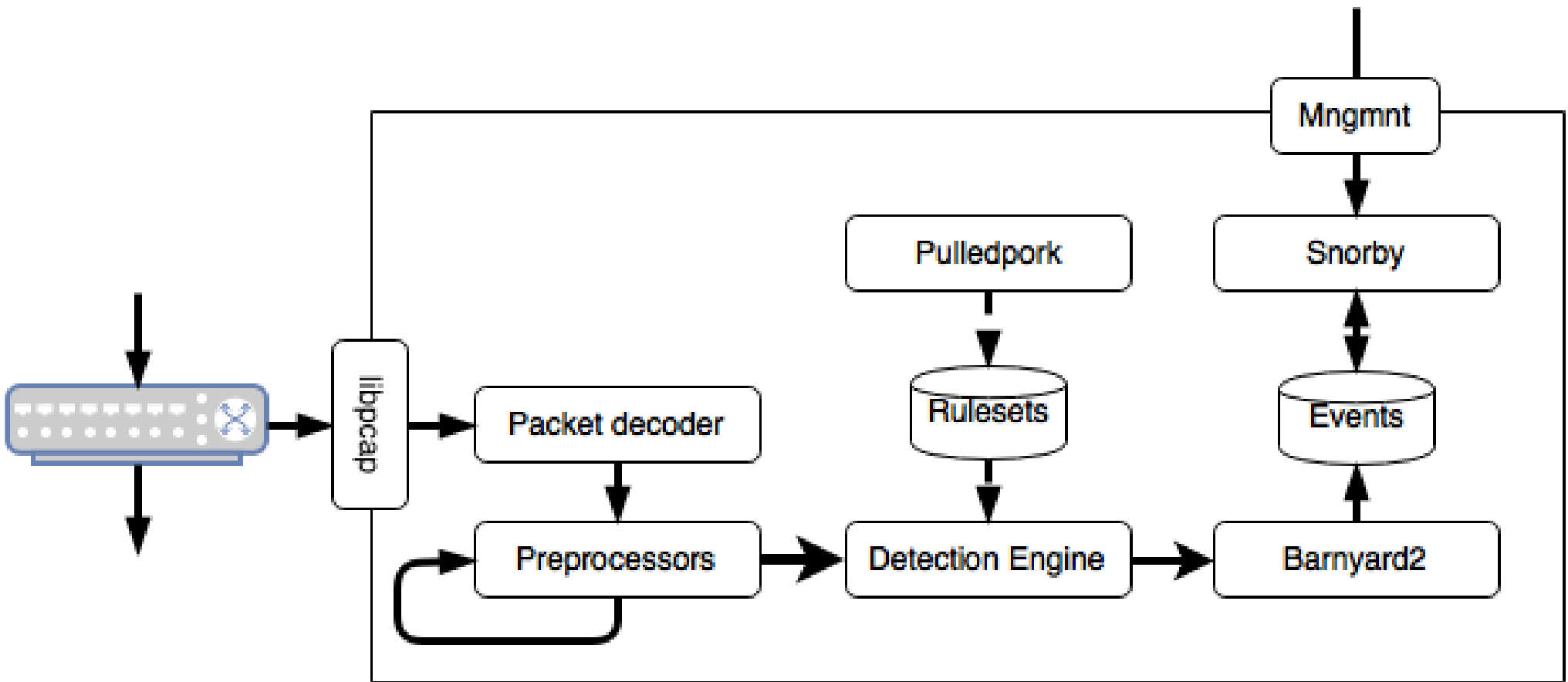


- NIDS & NIPS
 - Schwerpunkt Pattern, aber auch Anomalie
 - Dynamische Regeln
 - Erfahrung notwendig für die Nutzung
-
- 1998 Entwickler Martin Rösch, 1999
 - Ab 2001 Unterstützung Chris Green
 - 2003-2013 Sourcefire Inc
 - 2009 – eine der besten Open Source SW aller Zeiten
 - Seit Ende 2013 weiterentwickelt von Cisco.
 - Seit 2021 Snort 3 – neu implementiert in C++

SNORT Basissystem



SNORT mit Ergänzungen





IT-Sicherheit / Prof. Dr. Freudenmann

Start SNORT

```
root@snort29:~# snort -v
Running in packet dump mode

--== Initializing Snort ==--
Initializing Output Plugins!
pcap DAQ configured to passive.
Acquiring network traffic from "eth0".
Decoding Ethernet

--== Initialization Complete ==--

-*> Snort! <*-
o''')~ Version 2.9.8.0 GRE (Build 229)
  ''') By Martin Roesch & The Snort Team: http://www.snort.org/contact#team
Copyright (C) 2014-2015 Cisco and/or its affiliates. All rights reserved.

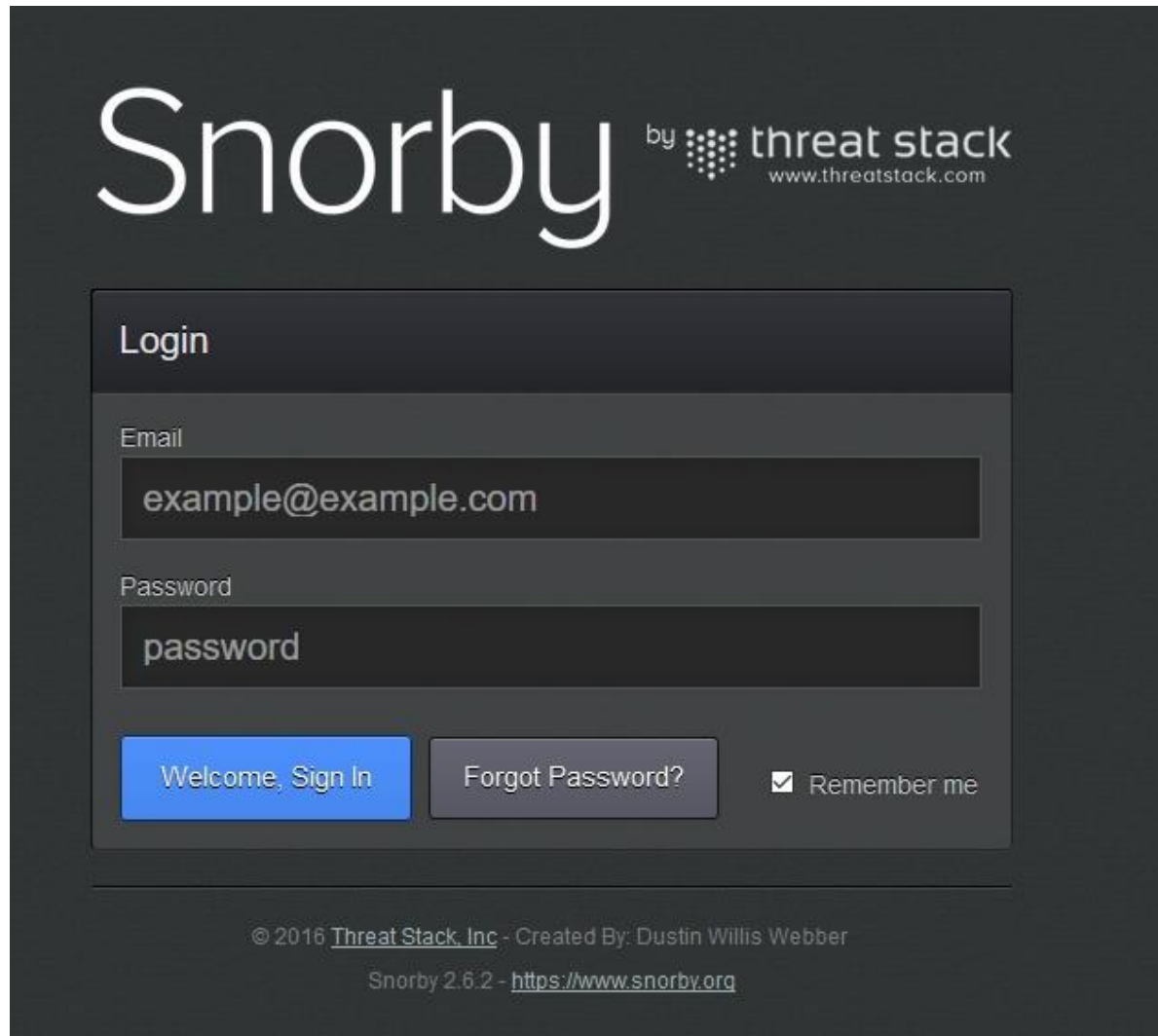
Copyright (C) 1998-2013 Sourcefire, Inc., et al.
Using libpcap version 1.6.2
Using PCRE version: 8.35 2014-04-04
Using ZLIB version: 1.2.8

Commencing packet processing (pid=6309)
```

SNORT Start

- Command Line Tool
 - Viele Konfigurationsmöglichkeiten
 - Sniffer Mode
 - Packet Logger Mode
 - NIDS Mode
 - Aktiv und Passiv einsetzbar
Snort-Mode „Inline“ oder „Passive“

Snorby - GUI

The image shows the Snorby login interface. At the top, the word "Snorby" is displayed in a large, white, sans-serif font. To its right, the text "by threat stack" is shown in a smaller font, with a logo consisting of a grid of dots. Below the "Snorby" text, the word "Login" is centered in a white font. The login form consists of two input fields: "Email" and "Password". The "Email" field contains the text "example@example.com" and the "Password" field contains the text "password". Below the "Email" field, there is a blue button labeled "Welcome, Sign In". To the right of this button is a grey button labeled "Forgot Password?". To the right of the "Forgot Password?" button is a checkbox labeled "Remember me". At the bottom of the form, there is a copyright notice: "© 2016 Threat Stack, Inc - Created By: Dustin Willis Webber". Below the copyright notice, there is a version number and a URL: "Snorby 2.6.2 - https://www.snorby.org".

Snorby by threat stack
www.threatstack.com

Login

Email
example@example.com

Password
password

Welcome, Sign In Forgot Password? ☒ Remember me

© 2016 Threat Stack, Inc - Created By: Dustin Willis Webber
Snorby 2.6.2 - <https://www.snorby.org>

Dashboard

My Queue (0)

Events

Sensors

Search

Administration

Dashboard

More Options

LAST 24 TODAY YESTERDAY LAST WEEK THIS MONTH THIS QUARTER THIS YEAR

Updated: 09/05/16 10:07 AM UTC



Sensors

Severities

Protocols

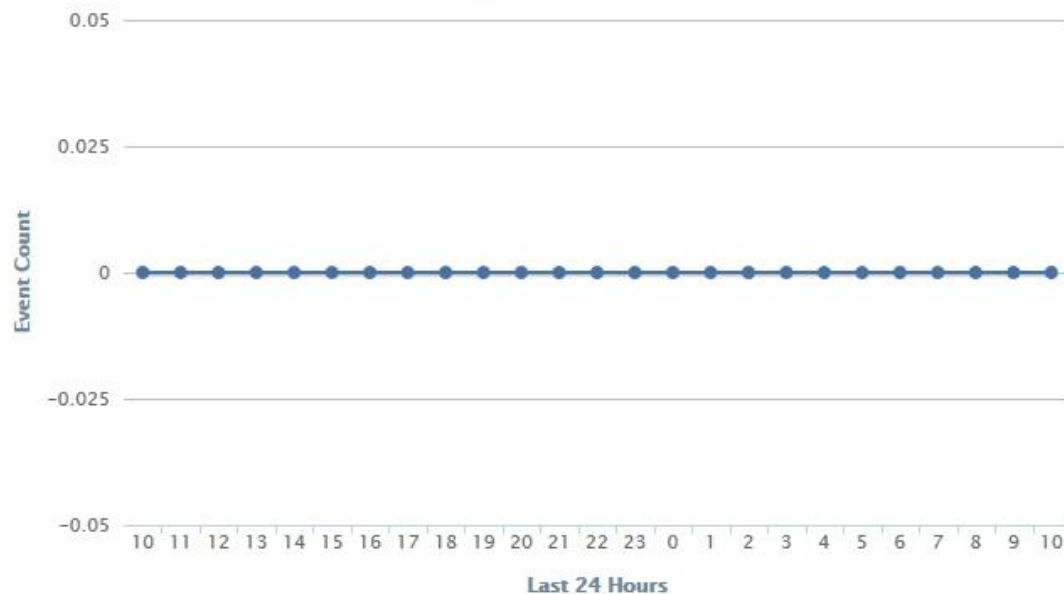
Signatures

Sources

Destinations

Event Count vs Time By Sensor

snort29



TOP 5 SENSOR

snort29 330

TOP 5 ACTIVE USERS

Administrator 0

LAST 5 UNIQUE EVENTS

http_inspect: LONG HEADER 330

ANALYST CLASSIFIED EVENTS

Unauthorized Root Access 0

Unauthorized User Access 0

Attempted Unauthorized... 0

Denial of Service Attack 0

Policy Violation 0

Reconnaissance 0

Virus Infection 0

False Positive 0

LAST 24 TODAY YESTERDAY LAST WEEK THIS MONTH THIS QUARTER THIS YEAR

Updated: 09/05/16 06:00 AM UTC



Sensors

Severities

Protocols

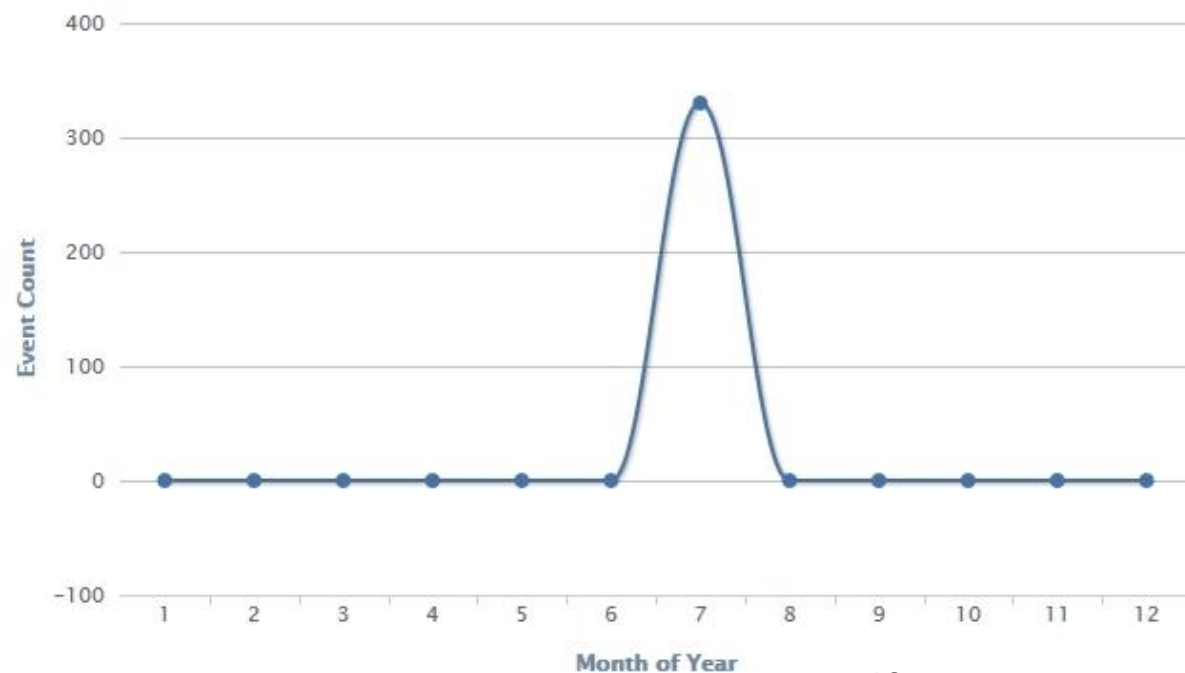
Signatures

Sources

Destinations

Event Count vs Time By Sensor

snort29



TOP 5 SENSOR

snort29 330

TOP 5 ACTIVE USERS

Administrator 0

LAST 5 UNIQUE EVENTS

http_inspect: LONG HEADER 330

ANALYST CLASSIFIED EVENTS

Unauthorized Root Access 0

Unauthorized User Access 0

Attempted Unauthorized... 0

Denial of Service Attack 0

Policy Violation 0

Reconnaissance 0

Virus Infection 0

False Positive 0

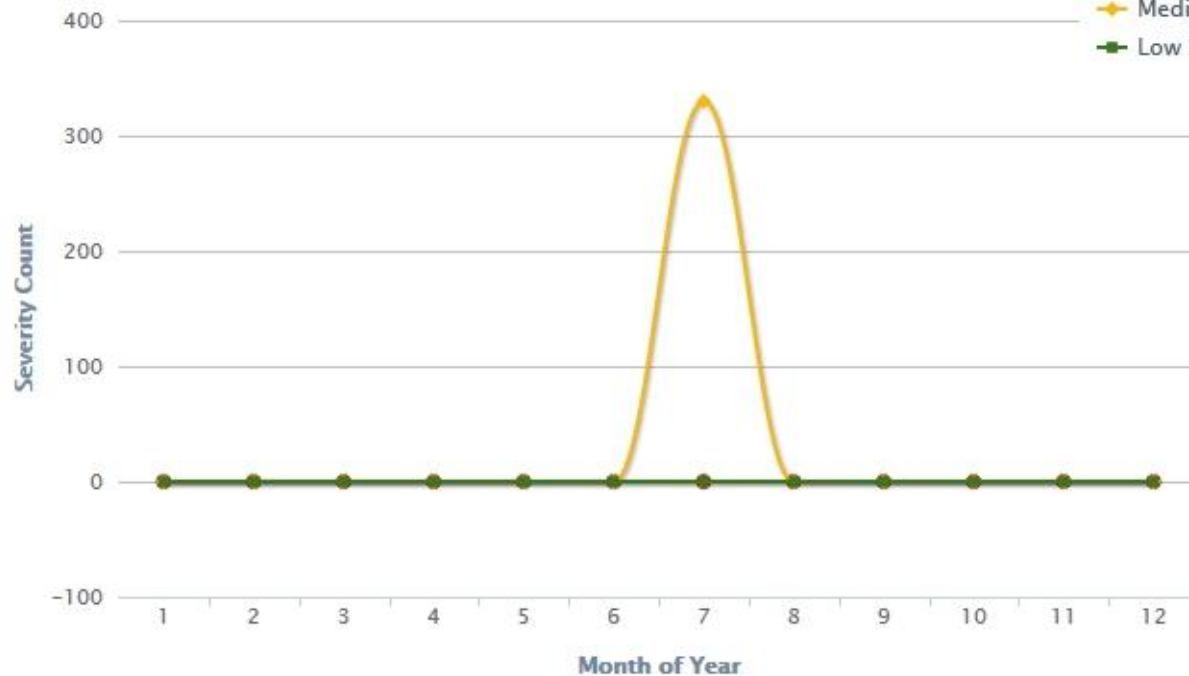
LAST 24 TODAY YESTERDAY LAST WEEK THIS MONTH THIS QUARTER THIS YEAR

Updated: 09/05/16 06:00 AM UTC

Sensors **Severities** Protocols Signatures Sources Destinations

Severity Count vs Time

High Severity
Medium Severity
Low Severity



TOP 5 SENSOR

snort29 330

TOP 5 ACTIVE USERS

 Administrator 0

LAST 5 UNIQUE EVENTS

http_inspect: LONG HEADER 330

ANALYST CLASSIFIED EVENTS

Unauthorized Root Access 0

Unauthorized User Access 0

Attempted Unauthorized... 0

Denial of Service Attack 0

Policy Violation 0

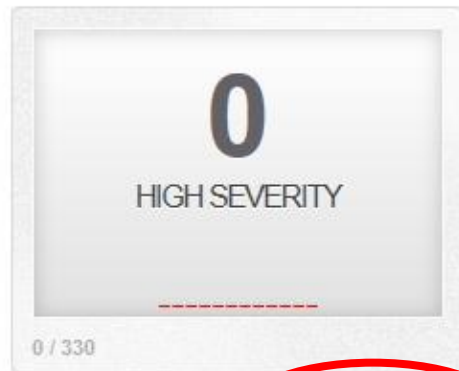
Reconnaissance 0

Virus Infection 0

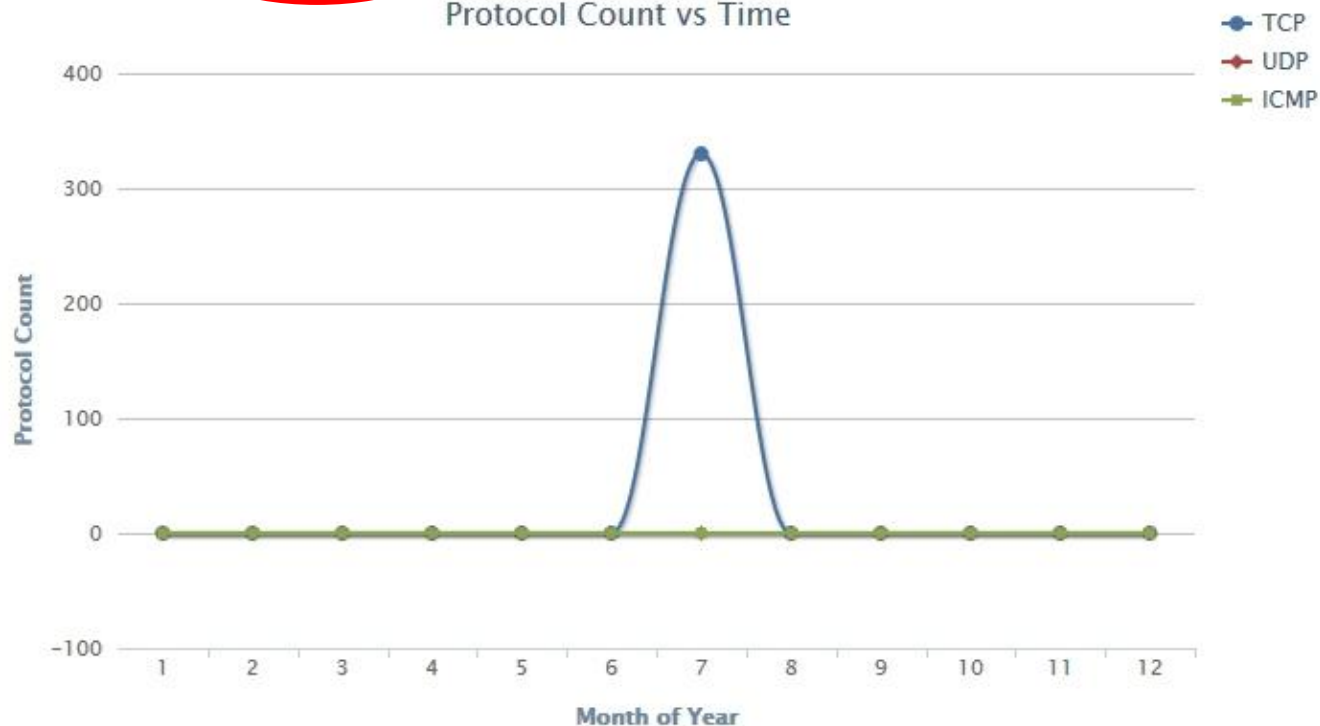
False Positive 0

LAST 24 TODAY YESTERDAY LAST WEEK THIS MONTH THIS QUARTER THIS YEAR

Updated: 09/05/16 11:00 AM UTC

Sensors Severities **Protocols** Signatures Sources Destinations

Protocol Count vs Time



TOP 5 SENSOR

snort29 330

TOP 5 ACTIVE USERS

 Administrator 0

LAST 5 UNIQUE EVENTS

http_inspect: LONG HEADER 330

ANALYST CLASSIFIED EVENTS

Unauthorized Root Access 0

Unauthorized User Access 0

Attempted Unauthorized... 0

Denial of Service Attack 0

Policy Violation 0

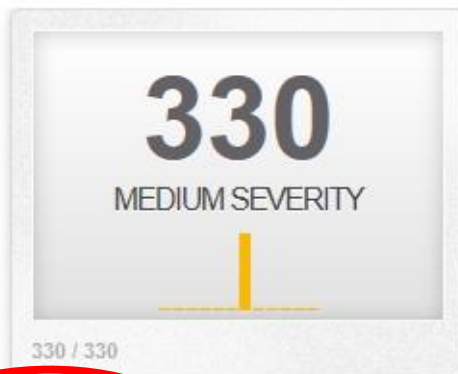
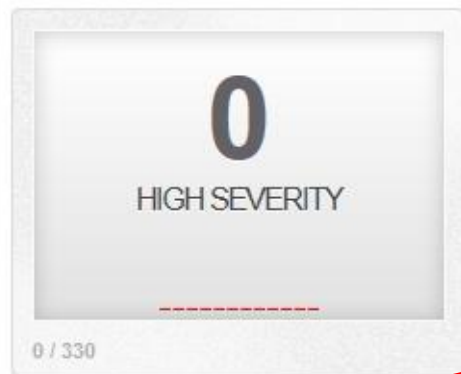
Reconnaissance 0

Virus Infection 0

False Positive 0

LAST 24 TODAY YESTERDAY LAST WEEK THIS MONTH THIS QUARTER THIS YEAR

Updated: 09/05/16 06:00 AM UTC



Sensors

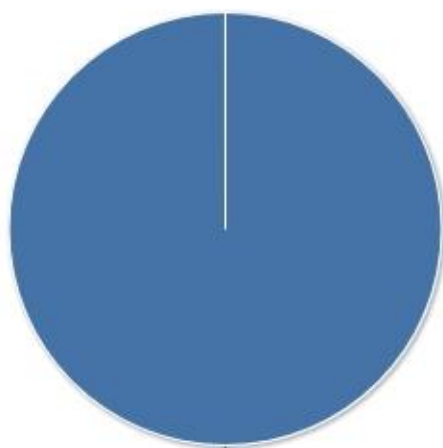
Severities

Protocols

Signatures

Sources

Destinations



http_inspect: LONG HEADER... (100%)

TOP 5 SENSOR

snort29 330

TOP 5 ACTIVE USERS

Administrator 0

LAST 5 UNIQUE EVENTS

http_inspect: LONG HEADER 330

ANALYST CLASSIFIED EVENTS

Unauthorized Root Access 0

Unauthorized User Access 0

Attempted Unauthorized... 0

Denial of Service Attack 0

Policy Violation 0

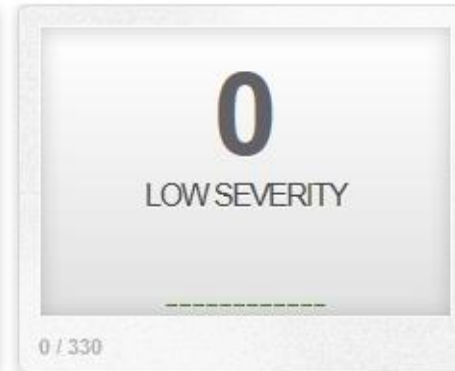
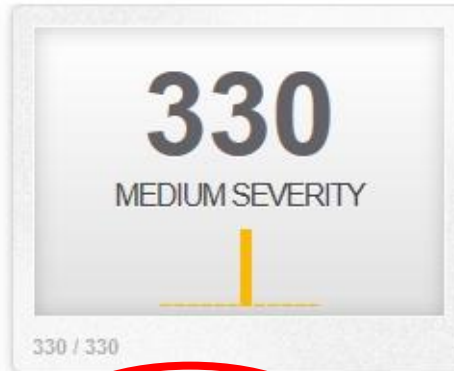
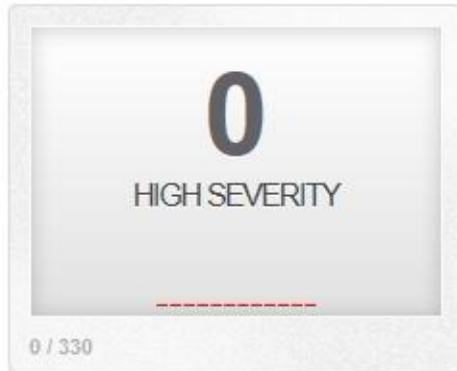
Reconnaissance 0

Virus Infection 0

False Positive 0

LAST 24 TODAY YESTERDAY LAST WEEK THIS MONTH THIS QUARTER THIS YEAR

Updated: 09/05/16 06:00 AM UTC



Sensors

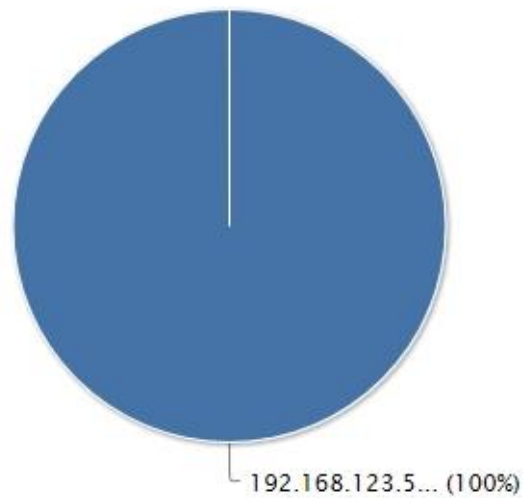
Severities

Protocols

Signatures

Sources

Destinations



TOP 5 SENSOR

snort29 330

TOP 5 ACTIVE USERS

 Administrator 0

LAST 5 UNIQUE EVENTS

http_inspect: LONG HEADER 330

ANALYST CLASSIFIED EVENTS

Unauthorized Root Access 0

Unauthorized User Access 0

Attempted Unauthorized... 0

Denial of Service Attack 0

Policy Violation 0

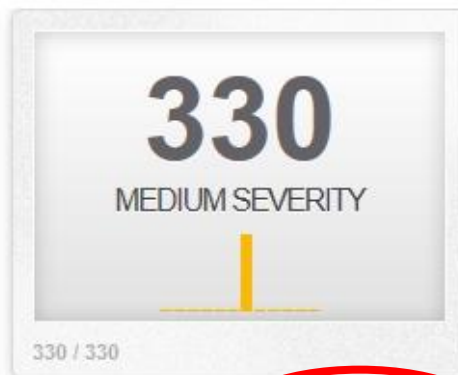
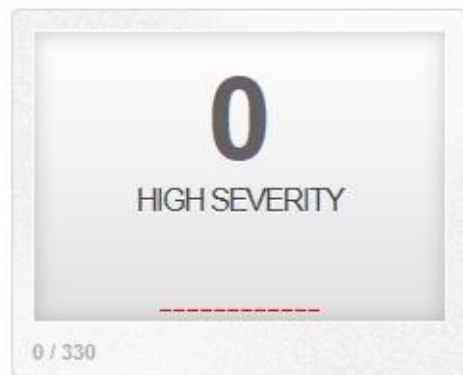
Reconnaissance 0

Virus Infection 0

False Positive 0

LAST 24 TODAY YESTERDAY LAST WEEK THIS MONTH THIS QUARTER THIS YEAR

Updated: 09/05/16 06:00 AM UTC



Sensors

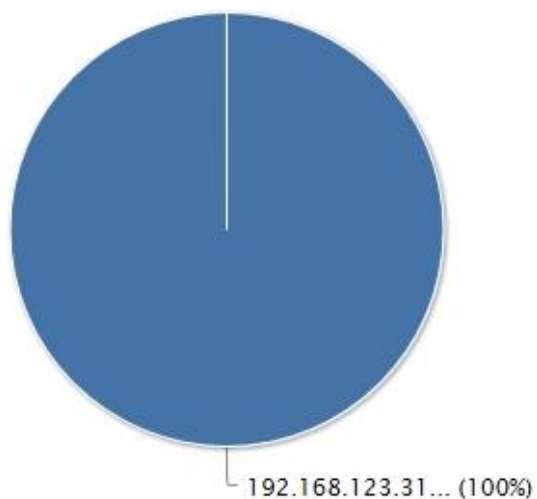
Severities

Protocols

Signatures

Sources

Destinations



TOP 5 SENSOR

snort29 330

TOP 5 ACTIVE USERS

 Administrator 0

LAST 5 UNIQUE EVENTS

http_inspect: LONG HEADER 330

ANALYST CLASSIFIED EVENTS

Unauthorized Root Access 0

Unauthorized User Access 0

Attempted Unauthorized... 0

Denial of Service Attack 0

Policy Violation 0

Reconnaissance 0

Virus Infection 0

False Positive 0

Snorby Event View Classify

The screenshot shows the Snorby web interface. At the top, the Snorby logo is on the left, and 'SPONSORED BY threat stack' is in the center. On the right, it says 'Welcome Administrator' with links for 'Settings' and 'Log out'. Below this is a navigation bar with tabs: 'Dashboard', 'My Queue (1)', 'Events', 'Sensors', 'Search', and 'Administration'. The 'Events' tab is selected and circled in red. Below the navigation bar, the 'Listing Sessions' section shows '(1 unique undclassified sessions)'. A table lists sessions with columns: 'Sev.', 'Sensor', 'Source IP', 'Destination IP', and 'Event Signature'. One session is listed with severity '2' (yellow square), sensor 'snort29', source IP '192.168.123.5', destination IP '192.168.123.31', and event signature 'http_inspect: LONG HEADER'. To the right of the table, there are buttons for 'Hotkeys', 'Classify Event(s)' (circled in red), and 'Filter Options'. A dropdown menu is open from the 'Classify Event(s)' button, showing a list of classification options: 'Unauthorized Root Access' (f1), 'Unauthorized User Access' (f2), 'Attempted Unauthorized Access' (f3), 'Denial of Service Attack' (f4), 'Policy Violation' (f5), 'Reconnaissance' (f6), 'Virus Infection' (f7), 'False Positive' (f8), and 'Unclassified' (ctrl+shift+u). On the far right, a 'Sessions' summary box shows '330' sessions for '2016'.

Snorby 2.6.2 - <https://www.snorby.org/>

By: Dustin Willis Webber

Listing Sessions (1 unique undclassified sessions)

Hotkeys

Classify Event(s)

Filter Options

☐	Sev.	Sensor	Source IP	Destination IP	Event Signature	Timestamp	Sessions
☐	★	2 snort29	192.168.123.5	192.168.123.31	http_inspect: LONG HEADER	07/06/2016	330

IP Header Information

View All Sessions

Perform Mass Classification

Event Export Options

Permalink

Source	Destination	Ver	Hlen	Tos	Len	ID	Flags	Off	TTL	Proto	Csum
192.168.123.5	192.168.123.31	4	5	0	905	26860	0	0	128	6	5901

Signature Information

Generator ID	Sig. ID	Sig. Revision	Activity (330/330)	Category	Sig Info
119	19	1	100.00%	bad-unknown	Query Signature Database

TCP Header Information

Src Port	Dst Port	Seq	Ack	Off	Res	Flags	Win	Csum	URP
4440	80	2530059464	2979320266	5	0	24	260	14017	0

References

Type	Value
cve	2009-4873

Payload

Hex

Ascii

```
00000000: 47 45 54 20 2f 69 6d 61 67 65 73 2f 6d 65 6e 75 2d 61 72 72 6f 77 2e 70 6e 67 GET./images/menu-arrow.png
000001A: 3f 31 33 32 38 34 35 37 33 34 39 20 48 54 54 50 2f 31 2e 31 0d 0a 48 6f 73 74 ?1328457349.HTTP/1.1..Host
0000034: 3a 20 31 39 32 2e 31 36 38 2e 31 32 33 2e 33 31 0d 0a 55 73 65 72 2d 41 67 65 :.192.168.123.31..User-Age
000004E: 6e 74 3a 20 4d 6f 7a 69 6c 6c 61 2f 35 2e 30 20 28 57 69 6e 64 6f 77 73 20 4e nt:.Mozilla/5.0.(Windows.N
0000068: 54 20 31 30 2e 30 3b 20 57 4f 57 36 34 3b 20 72 76 3a 34 38 2e 30 29 20 47 65 T.10.0;.WOW64;.rv:48.0).Ge
0000082: 63 6b 6f 2f 32 30 31 30 30 31 30 31 20 46 69 72 65 66 6f 78 2f 34 38 2e 30 0d cko/20100101.Firefox/48.0.
000009C: 0a 41 63 63 65 70 74 3a 20 2a 2f 2a 0d 0a 41 63 63 65 70 74 2d 4c 61 6e 67 75 .Accept:/*/*..Accept-Langu
```



Snort

Home

Snort Signature Information

Rule

--

Sid

119-19

--

Summary:

This event is generated when the http_inspect preprocessor detects anomalous network traffic.

--

Impact:

Unknown. This is an indication of anomalous behaviour between networked assets.

--

Detailed Information:

This event is generated when the http_inspect preprocessor detects anomalous network traffic.

In particular, the preprocessor has detected a long client header in an HTTP request.

This event can be controlled using the ((http_inspect)) configuration options.

--

Affected Systems:

All networked systems.

--

Attack Scenarios:

--

Ease of Attack:

Simple.

Snorby Search

Snorby Advanced Search More Options

Match of the following rules:

☒	Choose a query term...	is	Enter search value	- +
☒		is	Enter search value	- +
☒		is	Enter search value	- +

- Source Address
- TCP Source Port
- UDP Source Port
- Destination Address
- TCP Destination Port
- UDP Destination Port
- Classification
- Signature
- Signature Name
- Classified By

Snorby 2.6.2 - <https://www.snorby.org> © 2016 Threat Stack, Inc - Created By: Dustin Willis Webber

Snorby Administration

Snorby
SPONSORED BY
threat stack
<https://threatstack.com>

Welcome Administrator | [Settings](#) | [Log out](#)

Dashboard | My Queue (0) | Events | Sensors | Search | **Administration**

General Settings

Company name

Snorby.org

Company email (this email will be used as the report sender)

snorby@snorby.org

Signature lookup url (user \$\$sid\$\$ and \$\$gid\$\$ for the get request parameters)

http://rootedyour.com/snortsid?sid=\$\$gid\$\$:\$\$sid\$\$

☐ Enable snorby update notifications

(Notification reminder when a new Snorby build is release using <http://snorby.org/version>)

☐ Enable packet capture support

(Enable the Snorby Packet Capture Plugin)

☒ Daily reports

(Send a report summarizing the captured traffic daily.)

☒ Weekly reports

(Send a report summarizing the captured traffic weekly)

☒ Monthly reports

(Send a report summarizing the captured traffic monthly)

☒ Address lookups

(This option enables the analyst to perform basic queries on source addresses using external sources.)

☐ Enable global event notifications

(Show new event notifications globally. Event count since last check)

☐ Geoip

(Display GeoIP information on the events list)

☐ Prune database when event count is greater than

500,000

(Prune the database automatically when the event count exceeds your specified limit.)

Save Settings

Cancel

General Settings

Classifications

Sensors

Lookup Sources

Asset Name Manager

Severities

Signatures

Users

Worker & Job Queue ctrl+3

Snorby 2.6.2 - <https://www.snorby.org> © 2016 Threat Stack, Inc - Created By: Dustin Willis Webber

Listing Signatures

 Filter Signatures

Sev.	Signature Name	Event Count	
2	http_inspect LONG HEADER	100.00%	View
2	SERVER-IIS bdir.htr access	0.00%	View
3	ICMP test detected	0.00%	View
2	SERVER-WEBAPP carbo.dll access	0.00%	View
1	SERVER-OTHER Putty Server key exchange buffer overflow attempt	0.00%	View
2	SERVER-MAIL Novell NetMail APPEND command buffer overflow attempt	0.00%	View
1	BROWSER-PLUGINS CCRP FolderTreeView ActiveX clsid access	0.00%	View
1	BROWSER-PLUGINS Oracle ORADC ActiveX clsid access	0.00%	View
1	BROWSER-PLUGINS Oracle ORADC ActiveX function call access	0.00%	View
3	NETBIOS DCERPC NCACN-IP-TCP brightstor-arc ReserveGroup attempt	0.00%	View
1	SERVER-IIS cmd.exe access	0.00%	View
3	NETBIOS DCERPC NCACN-IP-TCP brightstor-arc ClientDBMiniAgentClose attempt	0.00%	View
1	SERVER-IIS cmd? access	0.00%	View
1	NETBIOS DCERPC NCACN-IP-TCP brightstor QSIGetQueuePath_Function_45 overflow attempt	0.00%	View
1	NETBIOS DCERPC NCACN-IP-TCP brightstor ASRemotePFC overflow attempt	0.00%	View
2	SERVER-IIS codebrowser Exair access	0.00%	View
2	SERVER-IIS codebrowser SDK access	0.00%	View
1	NETBIOS DCERPC NCACN-IP-TCP brightstor-arc2 ASDBLoginToComputer overflow attempt	0.00%	View
1	FILE-IMAGE Oracle Java Virtual Machine malformed GIF buffer overflow attempt	0.00%	View
1	BROWSER-FIREFOX Mozilla Firefox query interface suspicious function call access attempt	0.00%	View

1	SERVER-OTHER Peercast ORFET parameter overflow attempt	0.00%	View
1	BROWSER-FIREFOX Mozilla Firefox query interface suspicious function call access attempt	0.00%	View
1	FILE-IMAGE Oracle Java Virtual Machine malformed GIF buffer overflow attempt	0.00%	View
1	NETBIOS DCERPC NCACN-IP-TCP brightstor-arc2 ASDBLoginToComputer overflow attempt	0.00%	View
2	SERVER-IIS codebrowser SDK access	0.00%	View
2	SERVER-IIS codebrowser Exair access	0.00%	View
1	NETBIOS DCERPC NCACN-IP-TCP brightstor ASRemotePFC overflow attempt	0.00%	View
1	NETBIOS DCERPC NCACN-IP-TCP brightstor QSIGetQueuePath_Function_45 overflow attempt	0.00%	View
1	SERVER-IIS cmd? access	0.00%	View
3	NETBIOS DCERPC NCACN-IP-TCP brightstor-arc ClientDBMiniAgentClose attempt	0.00%	View
1	SERVER-IIS cmd.exe access	0.00%	View
3	NETBIOS DCERPC NCACN-IP-TCP brightstor-arc ReserveGroup attempt	0.00%	View
1	BROWSER-PLUGINS Oracle ORADC ActiveX function call access	0.00%	View
1	BROWSER-PLUGINS Oracle ORADC ActiveX clsid access	0.00%	View
1	BROWSER-PLUGINS CCRP FolderTreeView ActiveX clsid access	0.00%	View
2	SERVER-MAIL Novell NetMail APPEND command buffer overflow attempt	0.00%	View
1	SERVER-OTHER Putty Server key exchange buffer overflow attempt	0.00%	View
2	SERVER-WEBAPP carbo.dll access	0.00%	View
3	ICMP test detected	0.00%	View
2	SERVER-IIS bdir.htr access	0.00%	View

[First](#)
[Previous](#)
[...](#)
[1131](#)
[1132](#)
[1133](#)
[1134](#)
[1135](#)
[1136](#)
[1137](#)
[1138](#)
[1139](#)

Detection Engine - Rules

Rule Header

Alert tcp 1.1.1.1 any -> 2.2.2.2 any

Alert tcp 1.1.1.1 any -> 2.2.2.2 any

Alert tcp 1.1.1.1 any -> 2.2.2.2 any

Rule Options

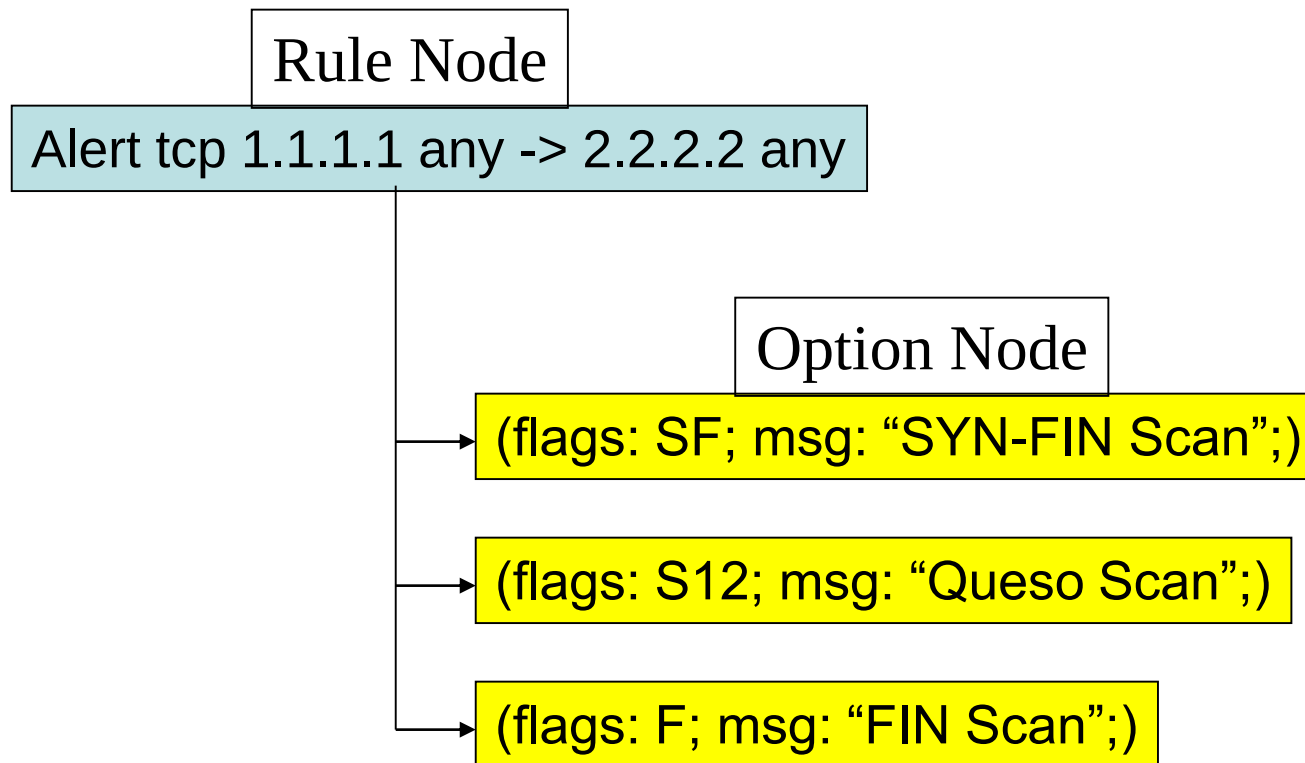
(flags: SF; msg: "SYN-FIN Scan";)

(flags: S12; msg: "Queso Scan";)

(flags: F; msg: "FIN Scan";)

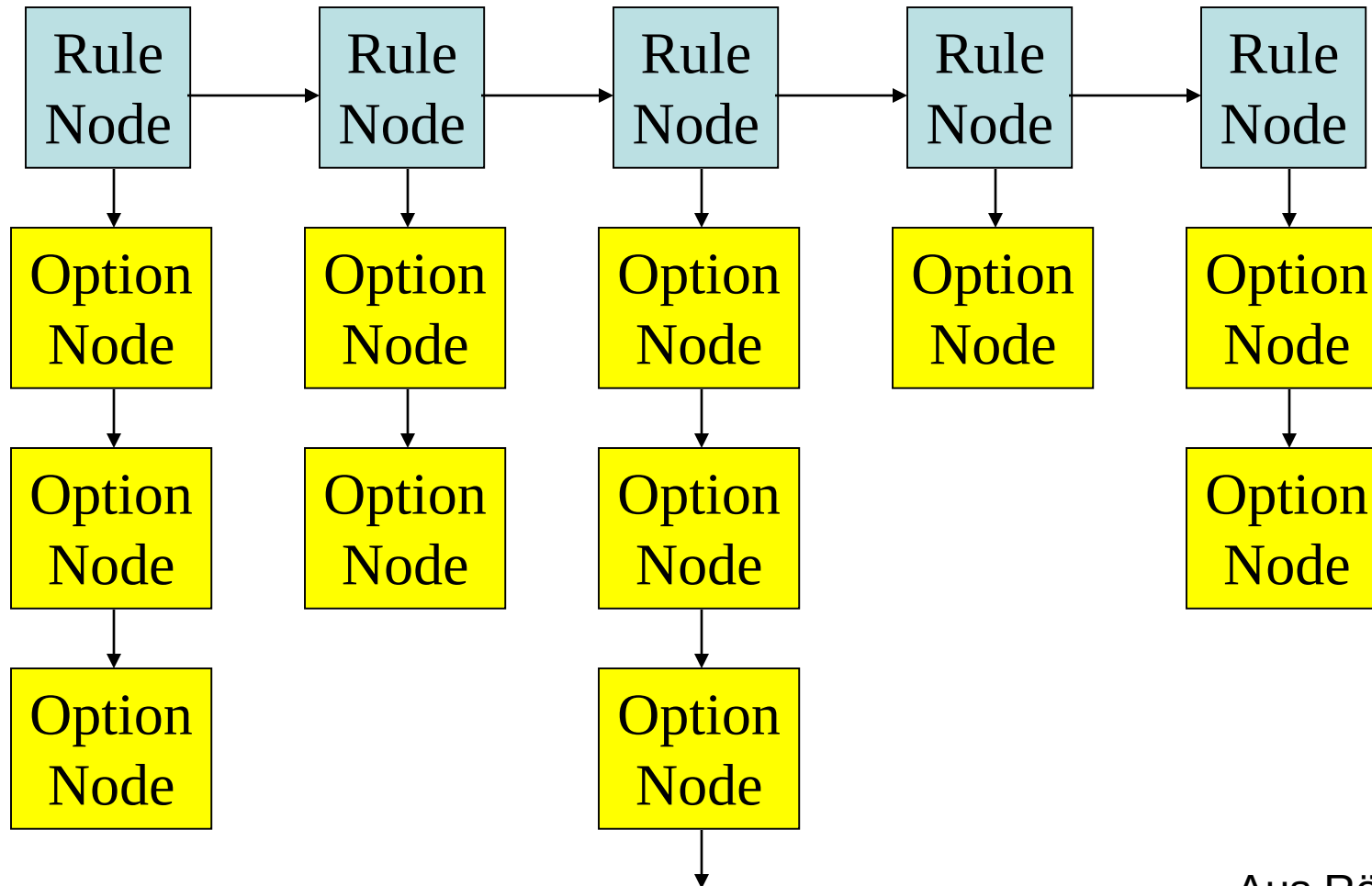
Aus Rösch 2008 Snort

Detection Engine – Interne Repräsentation



Aus Rösch 2008 Snort

Detection Engine - Gesamtsicht



Aus Rösch 2008 Snort

Heartbleed

- alert tcp \$HOME_NET [21 ,25 ,443 ,465 ,636 ,992 ,993 ,995 ,2484] -> \$EXTERNAL_NET any
(msg:' SERVER - OTHER OpenSSL TLSv1 .1 large
heartbeat response - possible ssl heartbleed attempt '
flow : to_client , established ;
content: '|18 03 02| ' ; depth :3; byte_test :2 > ,128,0,
relative ;
metadata : policy balanced - ips drop ,
policy security -ips drop , ruleset community , service
ssl;
reference : cve, 2014-0160; classtype : attempted - recon ;
sid :30517; rev :8;)

Directory Traversal Nginx

- alert tcp \ \$EXTERNAL_NET any -> \ \$HOME_NET \ \$HTTP_PORTS
(msg:' SERVER -WEBAPP nginx URI processing security
bypass attempt '
flow : to_server, established ;
content : '/' '../' ; depth :40; offset :5;
metadata : service http ;
reference : bugtraq ,63814;
reference :cve ,2013-4547;
reference :url , osvdb.org/show/osvdb/100015;
classtype : attempted - user ;
sid:33581; rev :1;)

DNS Cache Poisoning

- alert udp \ \$EXTERNAL_NET 53 -> \ \$HOME_NET any
(msg:' PROTOCOL -DNS large number of NXDOMAIN
replies - possible DNS cache poisoning';
flow : to_client ;
byte_test :1 ,& ,2 ,3; byte_test :1 ,& ,1 ,3; byte_test:1 ,&
,128 ,2;
detection_filter : track by_src , count 1000 , seconds 5;
metadata : service dns;
reference :cve ,2008-1447; reference :cve, 2009-0233;
reference :url , technet.microsoft.com/en-
us/security/bulletin/MS09-008;
reference :url , www.kb.cert.org/vuls/id/800113;
classtype :misc - attack ;
sid :13948; rev :11;)

Werkzeuge SNORT Referenzen

- KURUNDKAR, GD, NA NAIK und SD KHAMITKAR [2012]. „Network intrusion detection using Snort“. In: International Journal of Engineering Research and Applications 2.2, S. 1288–1296
- <https://www.snort.org/>
- M. Roesch. Snort: Lightweight intrusion detection for networks. In Proceedings of the 1999 USENIX LISA Systems Administration Conference, November 1999.
- <http://www.cisco.com/c/en/us/about/corporate-strategy-office/acquisitions/sourcefire.html>
- C. Kopetschny: Installation und Integration des Intrusion Detection Systems Snort, SARB DHBW Karlsruhe, 2016
- <https://www.heise.de/news/Snort-3-Mit-Multithreading-dem-Angreifer-auf-der-Spur-5032068.html>

IT-Sicherheit

Passwords in Windows

Prof. Dr. Johannes Freudenmann (DHBW Karlsruhe)

www.dhbw.de

Introduction

- Passwords Standard Method for Authentication
- How to Recover Passwords if lost or attack them
 - Guess or look while typing (keylogger)
 - Social Engineering
 - Brute Force
 - All combinations
 - Dictionary – Ramius Cracking Dictionary 4,14 GB
 - **CrackStation's Password Cracking Dictionary 15 GB**
(<https://crackstation.net/crackstation-wordlist-password-cracking-dictionary.htm>)

General things

- Hash is stored not the Password itself
 - PWD extended to 16 Byte (2x8 LMHash, NTHash)
 - MD5, 32 Byte long
- Brute force cracking trivial below 2^{30} Hashes to compute
- Brute force nearly impossible above 2^{50} Hashes.

Complexity of cracking a password

- 26 letters, 10 numerals, (special characters)
 - 62++ different possibilities for each char
 - 6 char long 56.800.235.584
 - 8 char long 218.340.105.584.896
- One PWD-Test (calculate a Hash) lasts
 - about 1 μ s on 1Ghz-CPU.
 - Much less with special hardware
 - All Hashes with 6 char 0,6574 d
 - All Hashes with 8 char 6,9235 a
- Calculate once: storage needed
 - Store Hash&Pwd. Sort hashes.
 - 6 char: 16+6 each entry: 1.250 GByte
 - Sorted, arranged by hash (ca. 40*60 Mrd Ops)
 - Find Pwd corresponding to hash immediately (40 Ops)

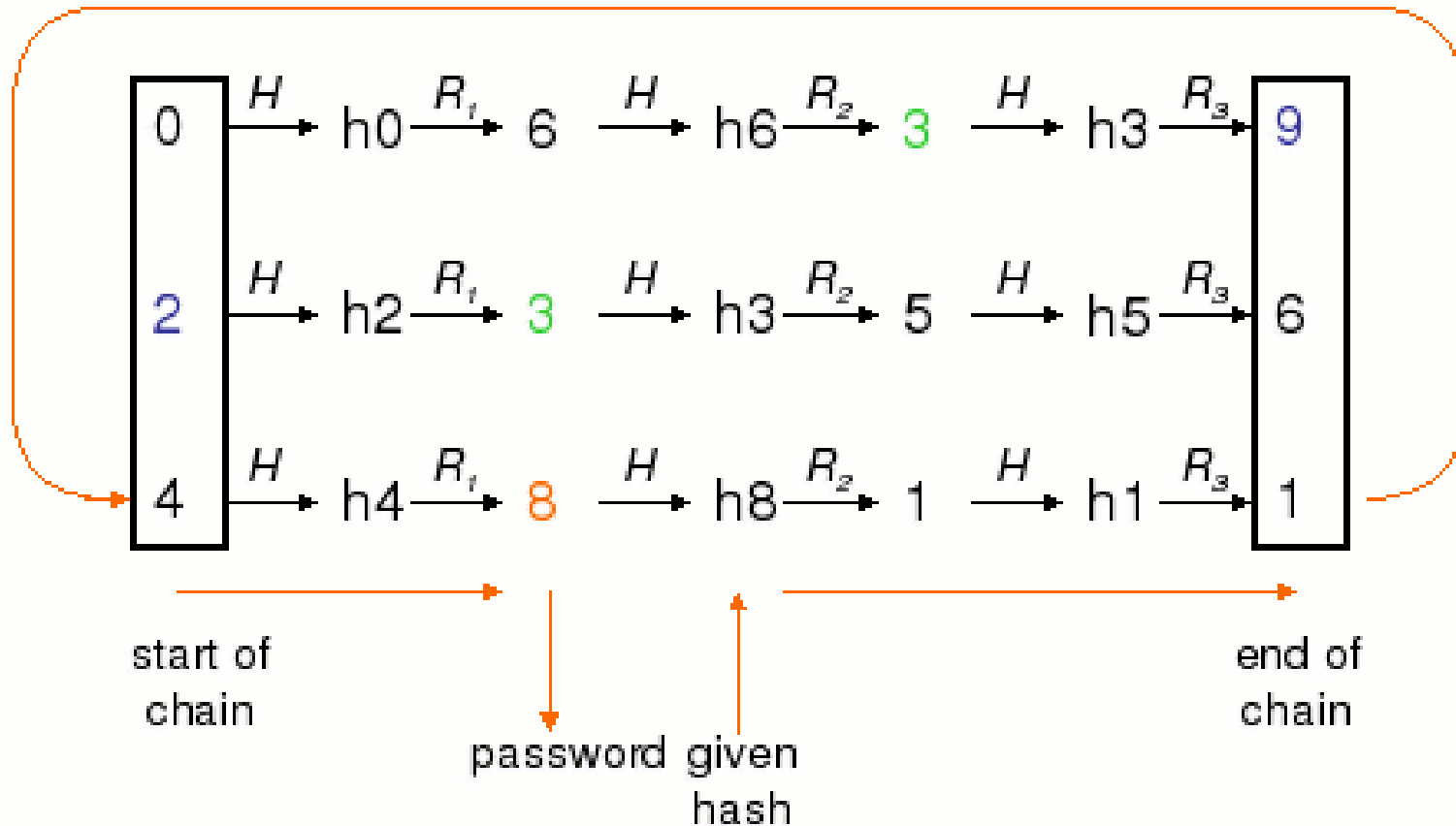
Example: Get a table of all Hashes

- Example: 6 char
- Time: 0,6574 d, disk storage: 1.250 GByte.
- Compute in parallel: 100 PC – 10 min.
- Every PC has about 13 GByte of data
- Network bandwidth: 180 Mbit/s

Problem memory resources

- >1 TeraByte not convenient to distribute.
- Too big even with only 6 chars.
- improvements:
 - Instead of HpHpHpHpHpHp -> H_spppppppH_e reduction to 30%, but more to compute
 - Rainbowtables: even more to compute but reduction of memory by an order of 10.000, **(time-memory-tradeoff)**

Rainbow-Tables



- Stored in memory only Start and End of chain.
- Chainlength about 10.000 values.
- Example Rainbow-Table for pwds 0..9

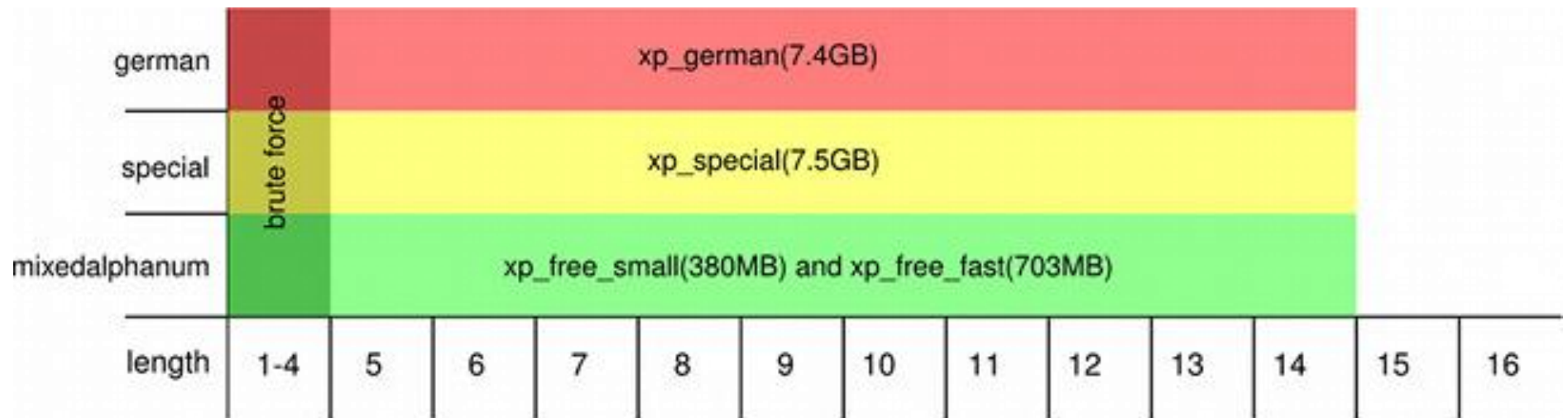
State: Rainbow-Tables (Oct 2013)

- LMHash (bereits vor Nov 2007) - complete
 - 29,2 GB – all PWD up tp 14 chars (2x 7)
(Upper, Lower, Numeric, 14 special symbols)
 - 38,8 GB (rar), 66 GB - all PWD up tp 14 chars
(upper, lower, numeric, 32 special symbols)
- MD5
 - 50,1 GB – all Pwd up to 6 chars (Nov 2007)
(upper, lower, numeric, 38 special symbols)
 - 13,4 GB – all Pwd up to 8 chars (Nov 2007, lower)
 - 86 GB - pwd up to 7 chars (Mai 2010)
(upper, lower, numeric, 32 symbols)
 - 1.049 GB - pwd up to 8 chars (Juni 2012)
(upper. lower, numeric, 32 symbols)
 - 1.009 GB - pwd up to 9 chars (Oct 2013, upper. lower, numeric)

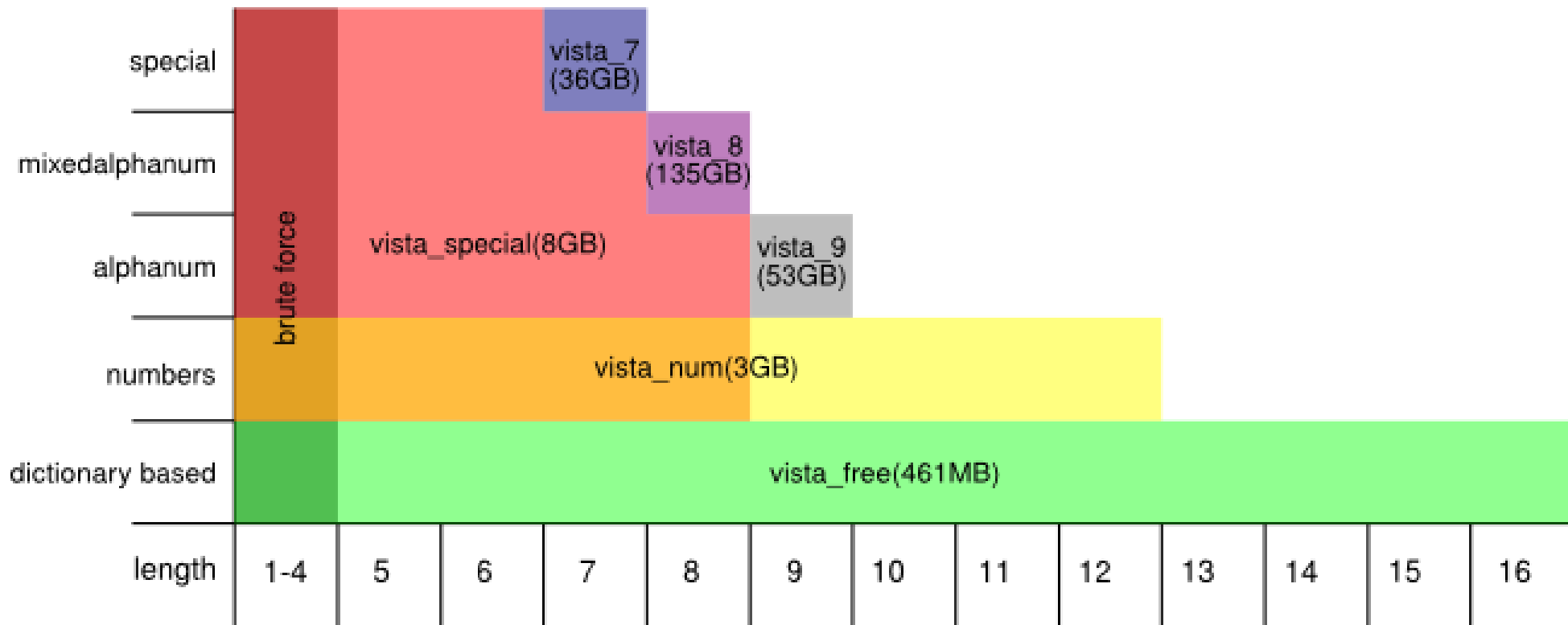
State Rainbow-Tables (Oct 2013) II

- SHA1
 - 36,9 GB – all Pwd up to 7 chars (Nov 2007, upper, lower, numeric)
 - 86 GB – all Pwd up to 7 chars (Oct 2013)
(upper, lower, numeric, special, space)
- NTLM (normal Hash of XP/Vista/Win7)
 - 123 GB – all pwd up to 9 chars (Nov 2007, lower, numeric)
Chain 50000
 - 135 GB - Pwd up to 8 chars (Mai 2010)
(upper, lower, numeric, space)
 - 1050 GB - Pwd up to 8 chars (Juni 2012)
(upper, lower, numeric, special, space)
 - 1009 GB - Pwd up to 9 chars (Oct 2013, upper, lower, numeric)
- Free Rainbow Project.
 - 5/2010: 417 PCs online, 1700 Ghz CPUs
 - 6/2012: 2482 PCs, 18449 GIPS
 - 10/2013: 3440 PCs, 16832 GIOPS

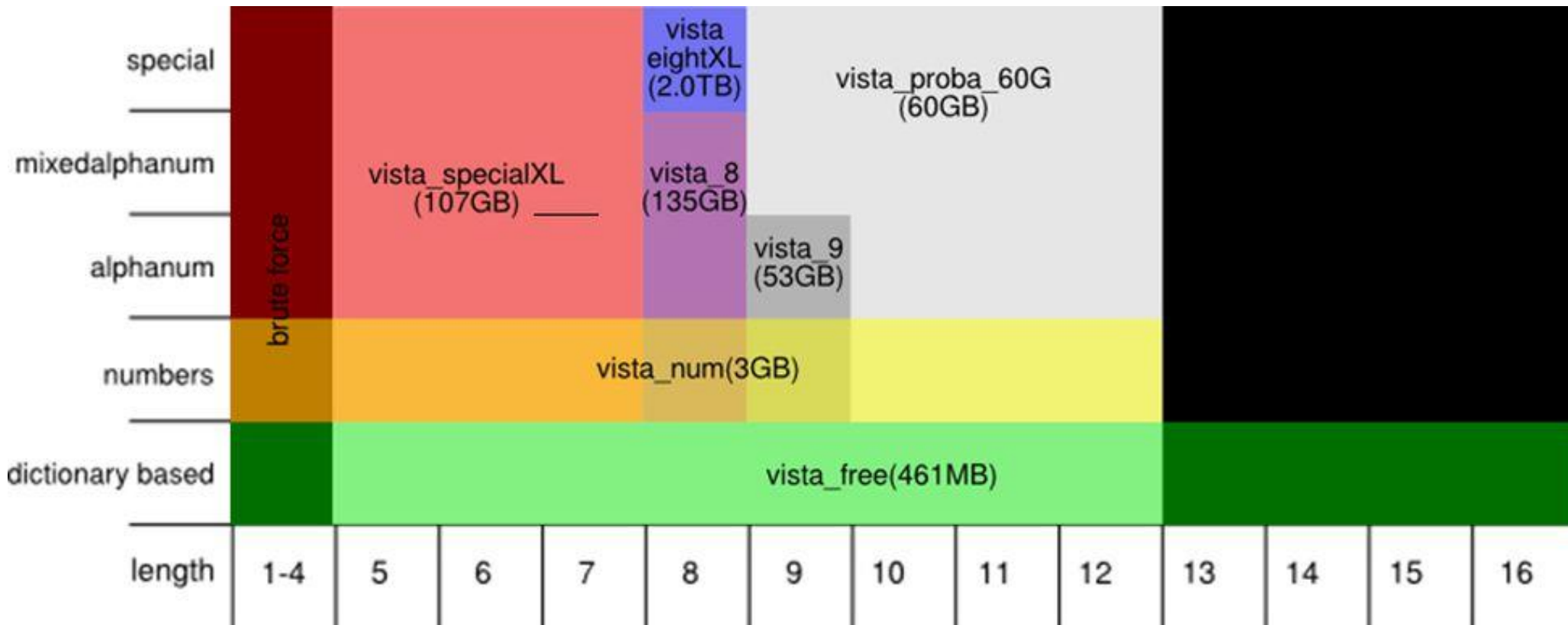
State III (Mai 2010)



State IV (Mai 2010)



State V (October 2013, Objective Securite)



Rainbow Tables – aktuelle Info.

- <https://project-rainbowcrack.com/index.htm>
- <http://project-rainbowcrack.com/buy.php>
- <http://project-rainbowcrack.com/buy.htm>
- <https://freerainbowtables.com/>

Demo

- s. Programm von Philippe Oechslin
 - Ophcrack 2.4.1
 - Upper/lower, numeric LMHashes
 - runtime max: 40 min (2400 sec)
 - 4 Tables altogether 388 MB
 - Chain length 10.000
- online example:
diverse...
<https://www.onlinehashcrack.com/>
- Generate pwd:
<http://www.tobtu.com/lmntlm.php>

Advice

- Don't use LMHashes.
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\Lsa\"no lmhash"=dword:00000001
- Build your Password
 - At least 9 characters, better 12 chars.
 - Upper **and** Lower **and** Numeric **and** Symbol.
 - Don't forget password and backup your data
 - Also be aware of
 - Social engineering
 - Key logger
 -

Password

- cracking time

Time it takes a hacker to brute force your password in 2025

Hardware: 12 x RTX 5090 | Password hash: bcrypt (10)

Number of Characters	Numbers Only	Lowercase Letters	Upper and Lowercase Letters	Numbers, Upper and Lowercase Letters	Numbers, Upper and Lowercase Letters, Symbols
4	Instantly	Instantly	Instantly	Instantly	Instantly
5	Instantly	Instantly	57 minutes	2 hours	4 hours
6	Instantly	46 minutes	2 days	6 days	2 weeks
7	Instantly	20 hours	4 months	1 year	2 years
8	Instantly	3 weeks	15 years	62 years	164 years
9	2 hours	2 years	791 years	3k years	11k years
10	1 day	40 years	41k years	238k years	803k years
11	1 weeks	1k years	2m years	14m years	56m years
12	3 months	27k years	111m years	917m years	3bn years
13	3 years	705k years	5bn years	56bn years	275bn years
14	28 years	18m years	300bn years	3tn years	19tn years
15	284 years	477m years	15tn years	218tn years	1qd years
16	2k years	12bn years	812tn years	13qd years	94qd years
17	28k years	322bn years	42qd years	840qd years	6qn years
18	284k years	8tn years	2qn years	52qn years	463qn years



Password cracking time

hic hier genommen

Number of Characters	Numbers Only	Lowercase Letters	Upper and Lowercase Letters	Numbers, Upper and Lowercase Letters	Numbers, Upper and Lowercase Letters, Symbols	Hardware
8	4 hours	10 months	219 years	896 years	2k years	RTX 4090
8	3 hours	8 months	172 years	703 years	1k years	RTX 5090x1
8	22 mins	1 month	23 years	93 years	246 years	RTX 5090x8
8	15 mins	3 weeks	15 years	62 years	164 years	RTX 5090x12
8	51 mins	2 months	52 years	212 years	559 years	A100 x8
8	34 mins	2 months	35 years	141 years	373 years	A100 x12
8	Instantly	1 hour	2 weeks	2 months	5 months	A100 x10,000 (ChatGPT 3)
8	Instantly	43 mins	1 weeks	1 month	3 months	A100 x20,000 (ChatGPT 4)

- *Max time required to crack randomly generated 8-character bcrypt work factor 10 password hashes of various complexity on different hardware.*

Quelle: <https://www.hivesystems.com/blog/are-your-passwords-in-the-green>

Situation in Linux

- Up to now no rainbowtables, because of salt
 - Salt: 12bit, 2 char.
 - Extend the length of the password.
 - 4.000x – 65.000x more expensive
- Password cracking time
 - Special hardware
 - Georgia-Tech: graphic cards cluster.
 - 8 char pwd less than 2 h (Sutter, 2010)
 - 12 char about 17.134 a.

Links

- <https://project-rainbowcrack.com/index.htm>
 - Nicht kostenlos!
- (Rainbow Tables der community
<https://freerainbowtables.com/>
Projekt eingestellt)

- Vergleich & Bewertung von Mechanismen
 - eher weniger Tiefe
 - Zeug wie SNORT-Regel schreiben muss man nicht können, aber Einsatzgebiet, Stärken, Schwächen sollen bekannt sein